



# NIST Generative AI Profile

Companion Guide for VMware Cloud Foundation 9.1

June 2026

# Table of Contents

Disclaimer..... 10

Version..... 11

Introduction..... 11

Third Party Identifiers and Mappings ..... 11

Coverage Levels ..... 11

Controls.....12

    Control GOVERN 1.1 ..... 12

    Control GOVERN 1.2 ..... 13

    Control GOVERN 1.3 ..... 14

    Control GOVERN 1.4 ..... 15

    Control GOVERN 1.5 ..... 16

    Control GOVERN 1.6 ..... 17

    Control GOVERN 1.7 ..... 21

    Control GOVERN 2.1 ..... 22

    Control GOVERN 3.2 ..... 23

    Control GOVERN 4.1 ..... 24

    Control GOVERN 4.2 ..... 25

    Control GOVERN 4.3 ..... 26

    Control GOVERN 5.1 ..... 27

    Control GOVERN 6.1 ..... 28

    Control GOVERN 6.2 ..... 29

    Control GV-1.1-001 ..... 30

    Control GV-1.2-001 ..... 31

    Control GV-1.2-002 ..... 32

    Control GV-1.3-002 ..... 33

    Control GV-1.3-003 ..... 34

    Control GV-1.3-004 ..... 35

    Control GV-1.3-005 ..... 36

    Control GV-1.3-006 ..... 37

    Control GV-1.3-007 ..... 38

    Control GV-1.4-001 ..... 40

    Control GV-1.4-002 ..... 41

    Control GV-1.5-001 ..... 42

|                    |    |
|--------------------|----|
| Control GV-1.5-002 | 43 |
| Control GV-1.5-003 | 44 |
| Control GV-1.6-001 | 47 |
| Control GV-1.6-002 | 51 |
| Control GV-1.7-001 | 55 |
| Control GV-2.1-001 | 56 |
| Control GV-2.1-002 | 57 |
| Control GV-2.1-003 | 58 |
| Control GV-2.1-004 | 59 |
| Control GV-2.1-005 | 60 |
| Control GV-3.2-001 | 61 |
| Control GV-3.2-003 | 62 |
| Control GV-3.2-004 | 63 |
| Control GV-3.2-005 | 64 |
| Control GV-4.1-001 | 65 |
| Control GV-4.1-002 | 66 |
| Control GV-4.1-003 | 67 |
| Control GV-4.2-001 | 68 |
| Control GV-4.2-002 | 69 |
| Control GV-4.2-003 | 70 |
| Control GV-4.3-002 | 71 |
| Control GV-4.3-003 | 77 |
| Control GV-5.1-001 | 78 |
| Control GV-5.1-002 | 79 |
| Control GV-6.1-001 | 80 |
| Control GV-6.1-002 | 81 |
| Control GV-6.1-003 | 82 |
| Control GV-6.1-004 | 83 |
| Control GV-6.1-005 | 85 |
| Control GV-6.1-006 | 86 |
| Control GV-6.1-007 | 87 |
| Control GV-6.1-008 | 88 |
| Control GV-6.1-009 | 89 |
| Control GV-6.1-010 | 90 |

|                     |     |
|---------------------|-----|
| Control GV-6.2-001  | 91  |
| Control GV-6.2-002  | 92  |
| Control GV-6.2-003  | 93  |
| Control GV-6.2-004  | 94  |
| Control GV-6.2-005  | 100 |
| Control GV-6.2-006  | 101 |
| Control GV-6.2-007  | 102 |
| Control MANAGE 1.3  | 103 |
| Control MANAGE 2.2  | 104 |
| Control MANAGE 2.3  | 105 |
| Control MANAGE 2.4  | 109 |
| Control MANAGE 3.1  | 110 |
| Control MANAGE 3.2  | 111 |
| Control MANAGE 4.1  | 114 |
| Control MANAGE 4.2  | 115 |
| Control MANAGE 4.3  | 116 |
| Control MAP 1.1     | 117 |
| Control MAP 1.2     | 118 |
| Control MAP 2.1     | 119 |
| Control MAP 2.2     | 120 |
| Control MAP 2.3     | 121 |
| Control MAP 3.4     | 123 |
| Control MAP 4.1     | 124 |
| Control MAP 5.1     | 125 |
| Control MAP 5.2     | 126 |
| Control MEASURE 1.1 | 127 |
| Control MEASURE 1.3 | 128 |
| Control MEASURE 2.2 | 129 |
| Control MEASURE 2.3 | 130 |
| Control MEASURE 2.5 | 132 |
| Control MEASURE 2.6 | 133 |
| Control MEASURE 2.7 | 135 |
| Control MEASURE 2.8 | 137 |
| Control MEASURE 2.9 | 138 |

|                      |     |
|----------------------|-----|
| Control MEASURE 2.10 | 139 |
| Control MEASURE 2.11 | 140 |
| Control MEASURE 2.12 | 141 |
| Control MEASURE 2.13 | 142 |
| Control MEASURE 3.2  | 143 |
| Control MEASURE 3.3  | 144 |
| Control MEASURE 4.2  | 145 |
| Control MG-1.3-001   | 146 |
| Control MG-1.3-002   | 147 |
| Control MG-2.2-001   | 149 |
| Control MG-2.2-002   | 150 |
| Control MG-2.2-003   | 152 |
| Control MG-2.2-004   | 154 |
| Control MG-2.2-005   | 155 |
| Control MG-2.2-006   | 156 |
| Control MG-2.2-007   | 157 |
| Control MG-2.2-008   | 158 |
| Control MG-2.3-001   | 159 |
| Control MG-2.4-001   | 160 |
| Control MG-2.4-002   | 161 |
| Control MG-2.4-003   | 162 |
| Control MG-2.4-004   | 164 |
| Control MG-3.1-001   | 165 |
| Control MG-3.1-002   | 169 |
| Control MG-3.1-003   | 170 |
| Control MG-3.1-004   | 171 |
| Control MG-3.1-005   | 172 |
| Control MG-3.2-003   | 173 |
| Control MG-3.2-004   | 174 |
| Control MG-3.2-005   | 175 |
| Control MG-3.2-006   | 176 |
| Control MG-3.2-007   | 180 |
| Control MG-3.2-008   | 181 |
| Control MG-3.2-009   | 182 |

|                    |     |
|--------------------|-----|
| Control MG-4.1-001 | 183 |
| Control MG-4.1-002 | 184 |
| Control MG-4.1-003 | 185 |
| Control MG-4.1-005 | 186 |
| Control MG-4.1-006 | 187 |
| Control MG-4.1-007 | 189 |
| Control MG-4.2-001 | 192 |
| Control MG-4.2-002 | 193 |
| Control MG-4.3-001 | 194 |
| Control MG-4.3-002 | 195 |
| Control MG-4.3-003 | 196 |
| Control MP-1.1-001 | 198 |
| Control MP-1.1-002 | 199 |
| Control MP-1.1-003 | 200 |
| Control MP-1.1-004 | 201 |
| Control MP-1.2-001 | 202 |
| Control MP-1.2-002 | 203 |
| Control MP-2.1-001 | 204 |
| Control MP-2.1-002 | 205 |
| Control MP-2.2-001 | 207 |
| Control MP-2.2-002 | 208 |
| Control MP-2.3-001 | 211 |
| Control MP-2.3-002 | 212 |
| Control MP-2.3-003 | 215 |
| Control MP-2.3-004 | 216 |
| Control MP-2.3-005 | 217 |
| Control MP-3.4-001 | 218 |
| Control MP-3.4-002 | 219 |
| Control MP-3.4-003 | 220 |
| Control MP-3.4-004 | 221 |
| Control MP-3.4-005 | 222 |
| Control MP-3.4-006 | 223 |
| Control MP-4.1-001 | 224 |
| Control MP-4.1-002 | 227 |

|                    |     |
|--------------------|-----|
| Control MP-4.1-003 | 228 |
| Control MP-4.1-004 | 229 |
| Control MP-4.1-005 | 230 |
| Control MP-4.1-006 | 231 |
| Control MP-4.1-007 | 234 |
| Control MP-4.1-008 | 235 |
| Control MP-4.1-009 | 236 |
| Control MP-4.1-010 | 238 |
| Control MP-5.1-001 | 239 |
| Control MP-5.1-002 | 240 |
| Control MP-5.1-003 | 241 |
| Control MP-5.1-004 | 242 |
| Control MP-5.1-005 | 243 |
| Control MP-5.1-006 | 244 |
| Control MP-5.2-001 | 245 |
| Control MP-5.2-002 | 246 |
| Control MS-1.1-001 | 247 |
| Control MS-1.1-002 | 249 |
| Control MS-1.1-003 | 251 |
| Control MS-1.1-004 | 252 |
| Control MS-1.1-005 | 253 |
| Control MS-1.1-006 | 254 |
| Control MS-1.1-007 | 255 |
| Control MS-1.1-008 | 258 |
| Control MS-1.1-009 | 259 |
| Control MS-1.3-001 | 260 |
| Control MS-1.3-002 | 261 |
| Control MS-1.3-003 | 262 |
| Control MS-2.2-001 | 266 |
| Control MS-2.2-002 | 267 |
| Control MS-2.2-003 | 268 |
| Control MS-2.2-004 | 269 |
| Control MS-2.3-001 | 270 |
| Control MS-2.3-002 | 276 |

|                     |     |
|---------------------|-----|
| Control MS-2.3-003  | 277 |
| Control MS-2.3-004  | 278 |
| Control MS-2.5-001  | 279 |
| Control MS-2.5-002  | 280 |
| Control MS-2.5-003  | 281 |
| Control MS-2.5-004  | 282 |
| Control MS-2.5-005  | 283 |
| Control MS-2.5-006  | 284 |
| Control MS-2.6-001  | 285 |
| Control MS-2.6-002  | 286 |
| Control MS-2.6-003  | 287 |
| Control MS-2.6-004  | 288 |
| Control MS-2.6-005  | 289 |
| Control MS-2.6-006  | 290 |
| Control MS-2.6-007  | 291 |
| Control MS-2.7-001  | 294 |
| Control MS-2.7-002  | 296 |
| Control MS-2.7-003  | 297 |
| Control MS-2.7-004  | 298 |
| Control MS-2.7-005  | 299 |
| Control MS-2.7-006  | 302 |
| Control MS-2.7-007  | 304 |
| Control MS-2.7-008  | 305 |
| Control MS-2.7-009  | 307 |
| Control MS-2.8-001  | 308 |
| Control MS-2.8-002  | 309 |
| Control MS-2.8-003  | 310 |
| Control MS-2.8-004  | 311 |
| Control MS-2.9-001  | 312 |
| Control MS-2.9-002  | 313 |
| Control MS-2.10-001 | 314 |
| Control MS-2.10-002 | 315 |
| Control MS-2.10-003 | 316 |
| Control MS-2.11-001 | 317 |



|                     |     |
|---------------------|-----|
| Control MS-2.11-002 | 318 |
| Control MS-2.11-003 | 319 |
| Control MS-2.11-004 | 320 |
| Control MS-2.11-005 | 321 |
| Control MS-2.12-001 | 322 |
| Control MS-2.12-002 | 323 |
| Control MS-2.12-003 | 324 |
| Control MS-2.12-004 | 325 |
| Control MS-3.2-001  | 326 |
| Control MS-3.3-001  | 327 |
| Control MS-3.3-003  | 328 |
| Control MS-3.3-004  | 329 |
| Control MS-3.3-005  | 330 |
| Control MS-4.2-001  | 331 |
| Control MS-4.2-002  | 332 |
| Control MS-4.2-003  | 333 |
| Control MS-4.2-004  | 334 |
| Control MS-4.2-005  | 335 |

## Disclaimer

This document is intended to provide general guidance for organizations that are considering Broadcom solutions. The information contained in this document is for educational and informational purposes only. This document is not intended to provide advice and is provided “AS IS.” Broadcom makes no claims, promises, or guarantees about the accuracy, completeness, or adequacy of the information contained herein. Organizations should engage appropriate legal, business, technical, and audit expertise within their specific organization for review of requirements and effectiveness of implementations.

## Version

910-20260612-01

## Introduction

This document describes how VMware Cloud Foundation (VCF) 9.1 and the separately licensed advanced services assessed alongside it, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, and VMware Avi Load Balancer, can support organizations aligning with the NIST Generative Artificial Intelligence Profile (NIST AI 600-1). The Generative AI Profile is a cross-sectoral profile of the NIST AI Risk Management Framework. It identifies risks that are unique to or exacerbated by generative AI and suggests actions for managing them, organized under the AI RMF functions, categories, and subcategories. Each assessed product is reported separately for every control, with VCF covering the full platform, including its consumption services and Private AI Services capabilities. The responsibility for identifying the organization's AI risk profile and applying the profile's suggested actions remains with the organization.

<https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf>

This guidance evolves. Please check the current revision at: <https://bcm.tech/vcf-compliance>

## Third Party Identifiers and Mappings

This document includes regulatory compliance and security control identifiers from external sources as a convenience to end users. This does not constitute endorsement, in either direction.

There is not a one-to-one mapping of product capabilities to third-party controls. A product capability, or set of capabilities, may be applicable to multiple controls. Conversely, a control may be satisfied with the use of multiple capabilities.

Control identifier numbers have been included from the Secure Controls Framework, version 2026.1, under the terms of the Creative Commons Attribution-NoDerivatives 4.0 International Public License. No modifications have been made to the control identifier numbers under the terms of the license.

<https://securecontrolsframework.com/>

## Coverage Levels

Each control entry below carries the framework control text, the SCF control or controls it maps to, and an Aggregate Coverage line showing the strongest position any one of the assessed products holds for that control. Products that meet or contribute to the control follow as subsections, each with its own coverage level and response. Products the control does not apply to are listed together at the end of the entry, with a brief explanation. The coverage levels are:

- **Meets** -- the product directly provides the capability described in the control. No additional organizational process, external product, or human activity is needed beyond configuring the product itself.
- **Contributes** -- the product provides technical capabilities that help satisfy the control, but the control also requires something outside the product to be fully met, such as an organizational process, human activity, or an additional tool.
- **Not Applicable** -- the control does not apply to the product. Physical facility controls, staffing decisions, organizational governance processes, and domains the product does not operate in fall here.
- **Not Supported** -- the control is relevant to the product's domain (infrastructure, networking, security), but the product lacks the specific capability the control requires.
- **Not Assessed** -- the control has not yet been evaluated against the product.

## Controls

### Control GOVERN 1.1

> Legal and regulatory requirements involving AI are understood, managed, and documented.

**SCF Controls:** CPL-01, GOV-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 1.2

> The characteristics of trustworthy AI are integrated into organizational policies, processes, procedures, and practices.

**SCF Controls:** AAT-01, GOV-01, OPS-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GOVERN 1.3

> Processes, procedures, and practices are in place to determine the needed level of risk management activities based on the organization's risk tolerance.

**SCF Controls:** OPS-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 1.4

> The risk management process and its outcomes are established through transparent policies, procedures, and other controls based on organizational risk priorities.

**SCF Controls:** AAT-07, RSK-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 1.5

> Ongoing monitoring and periodic review of the risk management process and its outcomes are planned and organizational roles and responsibilities clearly defined, including determining the frequency of periodic review.

**SCF Controls:** AAT-08, HRS-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GOVERN 1.6

> Mechanisms are in place to inventory AI systems and are resourced according to organizational risk priorities.

**SCF Controls:** AAT-02, AST-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 1.7

> Processes and procedures are in place for decommissioning and phasing out AI systems safely and in a manner that does not increase risks or decrease the organization's trustworthiness.

**SCF Controls:** AAT-01, AST-30

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 2.1

> Roles and responsibilities and lines of communication related to mapping, measuring, and managing AI risks are documented and are clear to individuals and teams throughout the organization.

**SCF Controls:** AAT-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) supports differentiated roles and responsibilities across the AI workload lifecycle through platform-level access controls layered on the VCF identity model. Platform administrators manage infrastructure setup: they deploy infrastructure, configure GPU-accelerated workload domains, and add the PAIS supervisor service to the supervisor before any AI workloads can be deployed. This role controls the foundational infrastructure on which AI operations depend.

Organization administrators control namespace imports and grant permissions for AI catalog items. The organization administrator token is required for API calls that import namespaces into VCF Automation organizations, centralizing oversight of which AI capabilities are exposed. Organization administrators must grant permissions before users can request AI catalog items, providing a gatekeeping function over AI deployments.

DevOps engineers are scoped to project and namespace membership for provisioning GPU-accelerated VMware Kubernetes Service (VKS) clusters and related infrastructure. Data scientists and MLOps engineers provision models and retrieval-augmented generation (RAG) applications through PAIS. The MLOps role carries specific validation responsibilities: MLOps engineers validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the model gallery, including testing inference functionality and evaluating performance and safety against business use cases.

Access to PAIS is authorized through OIDC groups specified in the authorizedGroups configuration, tying role enforcement to VCF SSO. Namespace-scoped permissions confine each role's actions to assigned boundaries within the platform.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 3.2

> Policies and procedures are in place to define and differentiate roles and responsibilities for human-AI configurations and oversight of AI systems.

**SCF Controls:** AAT-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) supports differentiated roles and responsibilities across the AI workload lifecycle through platform-level access controls layered on the VCF identity model. Platform administrators manage infrastructure setup: they deploy infrastructure, configure GPU-accelerated workload domains, and add the PAIS supervisor service to the supervisor before any AI workloads can be deployed. This role controls the foundational infrastructure on which AI operations depend.

Organization administrators control namespace imports and grant permissions for AI catalog items. The organization administrator token is required for API calls that import namespaces into VCF Automation organizations, centralizing oversight of which AI capabilities are exposed. Organization administrators must grant permissions before users can request AI catalog items, providing a gatekeeping function over AI deployments.

DevOps engineers are scoped to project and namespace membership for provisioning GPU-accelerated VMware Kubernetes Service (VKS) clusters and related infrastructure. Data scientists and MLOps engineers provision models and retrieval-augmented generation (RAG) applications through PAIS. The MLOps role carries specific validation responsibilities: MLOps engineers validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the model gallery, including testing inference functionality and evaluating performance and safety against business use cases.

Access to PAIS is authorized through OIDC groups specified in the `authorizedGroups` configuration, tying role enforcement to VCF SSO. Namespace-scoped permissions confine each role's actions to assigned boundaries within the platform.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 4.1

> Organizational policies and practices are in place to foster a critical thinking and safety-first mindset in the design, development, deployment, and uses of AI systems to minimize potential negative impacts. Continued on next page

**SCF Controls:** AAT-01, GOV-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GOVERN 4.2

> Organizational teams document the risks and potential impacts of the AI technology they design, develop, deploy, evaluate, and use, and they communicate about the impacts more broadly.

**SCF Controls:** AAT-07.2, AAT-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 4.3

> Organizational practices are in place to enable AI testing, identification of incidents, and information sharing.

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 5.1

> Organizational policies and practices are in place to collect, consider, prioritize, and integrate feedback from those external to the team that developed or deployed the AI system regarding the potential individual and societal impacts related to AI risks.

**SCF Controls:** AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 6.1

> Policies and procedures are in place that address AI risks associated with third-party entities, including risks of infringement of a third-party's intellectual property or other rights.

**SCF Controls:** AAT-01, AAT-12

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GOVERN 6.2

> Contingency processes are in place to handle failures or incidents in third-party data or AI systems deemed to be high-risk.

**SCF Controls:** AAT-01, AAT-10, AAT-11.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-1.1-001**

> Align GAI development and use with applicable laws and regulations, including those related to data privacy, copyright and intellectual property law.

**SCF Controls:** CPL-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.2-001

> Establish transparency policies and processes for documenting the origin and history of training data and generated data for GAI applications to advance digital content transparency, while balancing the proprietary nature of training approaches.

**SCF Controls:** AAT-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.2-002

> Establish policies to evaluate risk-relevant capabilities of GAI and robustness of safety measures, both prior to deployment and on an ongoing basis, through internal and external evaluations.

**SCF Controls:** AAT-01, GOV-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV-1.3-002

> Establish minimum thresholds for performance or assurance criteria and review as part of deployment approval (“go/”no-go”) policies, procedures, and processes, with reviewed processes and approval thresholds reflecting measurement of GAI capabilities and risks.

**SCF Controls:** GOV-05, GOV-05.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.3-003

> Establish a test plan and response policy, before developing highly capable models, to periodically evaluate whether the model may misuse CBRN information or capabilities and/or offensive cyber capabilities.

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV-1.3-004

> Obtain input from stakeholder communities to identify unacceptable use, in accordance with activities in the AI RMF Map function.

**SCF Controls:** GOV-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-1.3-005**

> Maintain an updated hierarchy of identified and expected GAI risks connected to contexts of GAI model advancement and use, potentially including specialized risk levels for GAI systems that address issues such as model collapse and algorithmic monoculture.

**SCF Controls:** AAT-01, AAT-02.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.3-006

> Reevaluate organizational risk tolerances to account for unacceptable negative risk (such as where significant negative impacts are imminent, severe harms are actually occurring, or large-scale risks could occur); and broad GAI negative risks, including: Immature safety or risk cultures related to AI and GAI design, development and deployment, public information integrity risks, including impacts on democratic processes, unknown long-term performance characteristics of GAI.

**SCF Controls:** AAT-10.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.3-007

> Devise a plan to halt development or deployment of a GAI system that poses unacceptable negative risk.

**SCF Controls:** AAT-18.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides AI-specific mechanisms that support an organization's risk response process for AI systems. MLOps engineers validate ML models onboarded to PAIS against the security, privacy, and technical requirements of the organization, providing a structured gate for remediation when an existing model is identified as risky and a replacement must be vetted before publication. When remediation requires substituting a model, operators can deploy completion or embedding model endpoints and use A/B testing to compare the behavior of candidate models against the incumbent in real-world settings, supporting empirical evaluation of the replacement before full rollout. Embedding model selection is recommended to be based on empirical evaluation using the organization's own data rather than relying solely on benchmarks.

Health and performance metrics for PAIS components running in a VCF Automation namespace can be visualized in observability platforms such as Grafana and VCF Operations. MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications through these observability surfaces to detect anomalies that warrant a risk response. PAIS observability is configured through a Prometheus runtime with a specified storage class and a configurable metrics retention period, with a default of 14 days, giving risk responders historical context for investigation. Metrics collection is activated by enabling the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` CR.

Organizational processes for prioritizing AI risks based on assessments, coordinating remediation across stakeholders, and tracking risk closure remain organizational responsibilities outside the scope of PAIS infrastructure capabilities. General platform resilience inherited from VCF is covered under VCF Coverage and is not a PAIS-specific contribution to this control.

### VMware vDefend (Contributes)

VMware vDefend contributes to prioritizing, responding to, and remediating security risks affecting AI workloads running on VCF by providing severity-based threat prioritization, multiple response mechanisms, and policy-based remediation at the network layer.

**Prioritization.** Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low), helping security teams focus first on the most urgent risks to AI workloads. The Security Services Platform Campaign Impact Score measures the overall severity of correlated threat campaigns on a scale from 0 through 100, with scores calculated using the confidence level of each constituent detection and higher scores indicating higher-priority campaigns for triage. Malware Prevention's Process Analysis Report classifies risk estimates and flags artifacts as High risk when they represent a critical risk requiring priority attention. vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping lower-priority severity data (Low and Informational) first and retaining Critical and High severity events, so that the most significant detections are preserved for triage and response.

**Response.** When security risks to AI workloads are identified, vDefend provides multiple response options calibrated to the situation. Administrators can deploy microsegmentation rules to isolate affected AI workloads, adjust IDS/IPS profiles to address newly identified threat patterns, or modify Gateway Firewall policies to restrict traffic at the perimeter. The Security Intelligence threat visualization canvas supports rapid threat containment by identifying compromised assets and guiding microsegmentation policy updates. Intelligent Assist analyzes detected anomalies and recommends remediation policies; remediation rules are added using the naming convention prefix 'ai-' and are not enabled by default, requiring an analyst or administrator to review and manually enable them after due diligence and verification. When Intelligent Assist determines that a given anomaly cannot be remediated, it indicates this automatically, allowing analysts to focus on actionable findings. Security Intelligence retains the IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations, providing an audit trail of response actions taken.

Remediation. The Security Intelligence recommendation engine generates firewall policy recommendations based on observed traffic patterns between virtual machines. These recommendations can be published as firewall policies applied to environment category pairs, enabling organizations to close segmentation gaps identified during risk assessments. Administrators can designate high-priority applications and groups through prioritized collections, focusing Security Intelligence's flow analysis on the AI workloads most critical to protect.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.4-001

> Establish policies and mechanisms to prevent GAI systems from generating CSAM, NCII or content that violates the law.

**SCF Controls:** GOV-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV-1.4-002

> Establish transparent acceptable use policies for GAI that address illegal use or applications of GAI.

**SCF Controls:** GOV-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.5-001

> Define organizational responsibilities for periodic review of content provenance and incident monitoring for GAI systems.

**SCF Controls:** AAT-08, AAT-12.1, HRS-03

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.5-002

> Establish organizational policies and procedures for after action reviews of GAI system incident response and incident disclosures, to identify gaps; Update incident response and incident disclosure processes as required.

**SCF Controls:** AAT-01, GOV-02, OPS-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.5-003

> Maintain a document retention policy to keep history for test, evaluation, validation, and verification (TEVV), and digital content transparency methods for GAI.

**SCF Controls:** AAT-01, AAT-10, DCH-18

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

### VMware vDefend (Contributes)

VMware vDefend provides configurable data retention capabilities for the security telemetry and flow data it collects, contributing to an organization's ability to retain security-relevant data in accordance with statutory, regulatory, and contractual obligations.

Security Services Platform, which underpins Network Detection and Response (NDR) and related analytics services, offers control over flow data retention. Flow data is retained for 30 days by default via the flow-data-retention setting. If storage capacity is insufficient to handle flow volume from workloads, some flow metadata may be lost, flow ingestion may be paused, or data retention may be reduced dynamically to stay within available storage. Administrators can monitor retention health through the `ssp_flow_storage.avg_flow_storage_ratio` metric, which reports the ratio of current retention days to predicted full days for flow storage, and through the `ssp_analytics_storage.avg_predicted_tabl_retention_days` metric, which tracks predicted retention for the correlated flow visualization table (default 30 days). Security Services Platform persistent storage collects data even when the License Hub is offline, providing resilience against brief service interruptions that might otherwise affect data continuity.

Network Detection and Response retains detection events and campaign data for 12 months, providing a fixed retention window for threat detection artifacts.

For organizations using cloud-connected vDefend features, Security Services Platform maintains defined retention periods for data collected under active service subscriptions: IDS events and other network events, VM identifiers, rules and policies, conversation history, and security profiles are retained for one year during an active subscription, and for 90 days following subscription expiration.

Administrators should note that when the Malware Prevention Service feature is deleted, all previously gathered data analytics are permanently removed. Organizations with compliance-driven retention requirements should account for this before decommissioning that service.

These retention controls allow organizations to align vDefend's security data storage with their compliance requirements. The broader scope of media and data retention across the full infrastructure stack, including operational data, log archives, backup snapshots, and storage-level data protection, is handled by other VCF components such as VCF Operations, VCF Log Management, and vSAN Data Protection.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides configurable retention mechanisms that allow administrators to align disaster recovery and cyber recovery data with retention obligations. PNR snapshot schedules define a retention policy that determines how long each snapshot is retained, with hourly, daily, weekly, and monthly cadences and a maximum retention duration of three years. Administrators can also select predefined retention templates that combine recovery point objective (RPO) and snapshot retention parameters for quick configuration of protection groups.

For vSphere Replication, the retention policy determines the expiration of point-in-time copies, and storage consumption drops after all point-in-time copies referring to the original disk are expired. Administrators configure the number of retention slots and the spacing between recovery points, so older instances expire automatically once the configured limit is exceeded.

Cyber Recovery snapshot schedules in PNR follow the same retention model, defining a retention policy that controls how long each snapshot is retained. Administrators should account for storage capacity when configuring longer retention schedules, since extended retention periods increase storage consumption on the underlying datastores.

These retention controls allow organizations to align disaster recovery and cyber recovery data retention with applicable statutory, regulatory, and contractual obligations. PNR provides the technical mechanisms; determining the specific retention durations that satisfy each obligation is an organizational policy decision.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) provides configurable backup retention controls that support an organization's data retention requirements for its managed databases. These controls do not define retention obligations, which come from the organization's legal and compliance functions, but they provide the technical means to implement those obligations for PostgreSQL, MySQL, SQL Server, and MinIO data.

Retention periods are configured through Data Service Policies in the DSM administration interface. Each policy supports a backup-retention-period setting that defines the duration for which backups are kept. When multiple policies apply to a namespace, DSM aggregates the retention constraints by selecting the more restrictive minimum and maximum retention day values, producing a resultant retention window that reflects all applicable policies. Data service policies can also be tailored to specific requirements and enforced across different tenants, giving administrators a consistent mechanism for applying retention standards in multi-tenant deployments.

For deleted databases, DSM retains automated backups according to the configured retention period and exposes an Archives tab in the administration interface where administrators can access and adjust the retention period of retained backups. This allows organizations to maintain access to backup data even after a database instance has been removed, supporting retention obligations that outlast the operational lifetime of a specific database. When a database is deleted, automated backups continue to be retained until the retention policy is met.

DSM also supports point-in-time restore within the backup retention period, enabling recovery to any point within the retained window. On-demand backups behave differently from automated backups: they are permanent and do not expire automatically. On-demand backups remain in the backup storage location until an administrator manually deletes them, which means they can consume storage quota indefinitely and require separate tracking for retention compliance.

Data service policies also define backup storage locations (S3-compatible targets) alongside retention duration. If a data service policy that is in use is deleted, the data services associated with that policy become non-compliant, alerting administrators to a configuration gap.

Meeting this control fully requires the organization to determine the applicable retention periods, communicate those requirements to DSM administrators, and configure policies accordingly. DSM does not automatically derive retention

obligations from regulatory or contractual sources. Its retention controls also cover only the database data it manages and do not address retention of all media and data types that may fall within an organization's broader retention obligations.

Not applicable for this control: VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control GV-1.6-001

> Enumerate organizational GAI systems for incorporation into AI system inventory and adjust AI system inventory requirements to account for GAI risks.

**SCF Controls:** AAT-02, AST-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The `RetrievePropertiesEx` method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization

maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure



state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.6-002

> Define any inventory exemptions in organizational policies for GAI systems embedded into application software.

**SCF Controls:** AAT-02, AST-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to asset inventory processes by maintaining a detailed, real-time inventory of technology assets across compute, storage, and networking layers.

VMware vCenter maintains the authoritative inventory of all managed objects in the environment. The vSphere inventory organizes objects in a hierarchical structure beginning at the root folder and extending through datacenters, clusters, hosts, virtual machines, networks, and datastores. Each object carries metadata including configuration details, resource allocations, and operational state. Administrators can extend this metadata by defining custom attributes, which store organization-specific fields against any inventory object in vCenter. Custom attribute values are held centrally by vCenter rather than within the individual objects, allowing teams to annotate VMs, hosts, datastores, and other inventory items with organization-defined information such as ownership, classification, or business justification details. This inventory reflects the live state of the environment as objects are created, modified, or removed. Multiple vCenter instances can be linked for centralized inventory management across workload domains.

Programmatic access to the full inventory is available through the vSphere Web Services API. The Property Collector service uses Property Filter Specifications to identify inventory elements either directly or through object property traversal. The RetrievePropertiesEx method collects properties from inventory objects, allowing external systems and automation scripts to enumerate assets, gather configuration details, and build reports at whatever level of granularity is needed. The SimpleClient sample application demonstrates how to connect to a vCenter instance and obtain a listing of top-level inventory entities along with their properties and references.

VCF Operations extends inventory visibility by retrieving inventory details from each vCenter, including associated clusters, VMware ESX hosts, datastores, and virtual machines. Discovered objects are grouped logically in detailed inventory lists, and the inventory management interface supports sorting, searching, and object tagging to organize assets at scale. Custom object groups are containers that collect data from included objects and report on the data collected, allowing administrators to create dashboards and widgets that display resource information for grouped assets. VCF Operations also applies policies to newly discovered objects, such as objects added to an object group. ResourceAttribute elements define the metrics that appear in the monitoring interface, each identified by a Metric Key, providing continuous visibility into asset utilization, capacity, and health. The vSphere Compute Inventory Dashboard provides interactive views of clusters, hosts, and virtual machines associated with any selected object.

For application-level visibility, the VCF Operations Service Discovery adapter discovers running applications and services along with their CPU and memory metrics. Discovery rules can be defined using object types including metrics, relationships, properties, object names, and tag-based criteria. Discovered applications can be grouped by object type and selected attributes through Application Definition criteria, and the results can be exported in CSV format for use in external asset tracking systems.

VCF Automation adds a consumption-oriented layer to asset tracking. Projects link users, catalog items, and infrastructure resources where deployments are provisioned. The Overview tab displays infrastructure and consumption metrics across the organization. Resources visible in inventory views are scoped by the rights and project roles assigned to each user, providing role-appropriate visibility for audit and review. When catalog items are deployed, they are provisioned against the infrastructure available to the selected project, creating a traceable relationship between the request, the deployment, and the underlying resources. Provider accounts can create and track assets including virtual machines, catalogs, templates, and media. Organizations in VCF Automation support policy-based governance on resource usage, allowing IT teams to monitor resource consumption, control permissions, and provide managed services with network isolation. Each organization maintains a secure boundary from other organizations. Resource quota policies can be defined through the Policies API to

limit resources consumed by each user, project, or organization. Day 2 Action policies restrict which users have access to specific lifecycle operations on deployed resources. Tags within VCF Automation express capabilities and constraints that define deployments, and cloud administrators can place constraint tags on projects to exercise governance over resource provisioning, supporting asset classification and controlled placement of workloads across the infrastructure.

For integration with external asset registries, VCF provides multiple paths. The Management Pack for ServiceNow in VCF Operations discovers and synchronizes asset details including CPU count, CPU speed, CPU type, disk space, RAM, serial number, manufacturer, model ID, OS version, IP address, and vCenter reference through the ServiceNow Table API and CMDB Meta API. These properties are marked as required discovery fields, keeping the external CMDB aligned with the actual virtual infrastructure. VCF Operations for Networks supports adding ServiceNow as a CMDB data source to fetch configuration items and their relationships. VCF Automation also integrates with ServiceNow for ITSM and CMDB synchronization, configurable through extensibility action scripts or through VCF Operations Orchestrator Client hosted workflows. The ServiceNow ITSM Plug-in for VCF Automation captures extensive asset metadata, including resource name, operational status, project assignment, storage details, account and region information, endpoint type, zone, environment, and custom properties. The plug-in stores machine resource records in custom ServiceNow CMDB tables that track creation timestamps, deployment IDs, machine IDs, entitled users, and network schema. Deployment records similarly capture blueprint version, project ID, catalog ID, organization ID, operational status, owner, requester, and expiration tracking. The plug-in supports day-2 resource lifecycle actions such as Add Disk, Resize, Power On/Off, Create Snapshot, and Delete, and maintains CMDB accuracy through reconciliation.

Software asset tracking is supported through vSphere Lifecycle Manager, where software depots contain both the payloads and metadata for software updates. VCF Lifecycle Management tracks different versions of software components to help maintain compatibility across the infrastructure. The VCF Operations API includes methods to register associated products with their product name, version, and deployment details, contributing to a software-level view of the environment.

The Consumption layer of VCF extends asset inventory to containerized workloads running on VMware Kubernetes Service (VKS) and vSphere Supervisor. The Kubernetes API server maintains a live registry of every object within a cluster or Supervisor namespace, covering pods, deployments, services, ConfigMaps, Secrets, PersistentVolumeClaims, CustomResourceDefinitions, and other resource types. Every resource carries standard metadata including name, namespace, labels, annotations, creation timestamp, and owning references that administrators can query or export at any level of granularity. Labels and annotations allow teams to attach arbitrary metadata to any Kubernetes resource, such as application name, business unit, or data classification, and these fields are queryable via label selectors, supporting filtered inventory exports by category. Supervisor namespaces map to vCenter namespaces, associating Kubernetes workloads with the organizational units defined during provisioning, and resource quotas and limit ranges attached to each namespace record the allocated capacity and support tracking of resource consumption by application or team.

For workloads that consume specialized hardware such as accelerators or dedicated network devices, the Kubernetes Device Plugin framework provides hardware-level asset visibility within VKS clusters. Administrators or device owners use DeviceClasses to define sets of devices available in the cluster, and workloads claim specific hardware resources by creating ResourceClaims that filter for device parameters declared in a DeviceClass. Monitoring agents for device plugin resources discover which devices are in use on each node and collect metadata that associates each device allocation with the specific container consuming it, extending hardware asset tracking to the workload level.

The Harbor Registry Supervisor Service provides an inventory mechanism for container images and artifacts. Harbor organizes images in a Projects structure by team or application and secures them with policies and role-based access control, allowing administrators to track which container images are authorized for use within the environment. Container images deployed through VCF consumption paths should be scanned, signed, and approved according to organizational software supply chain policies before use; digital certificates and validation mechanisms support supply chain assurance of images and artifacts. Where GitOps practices are in use, the Argo CD Supervisor Service extends this inventory capability by recording application synchronization events with timestamps, capturing the resource group, kind, namespace, name, sync status, and health status of each synchronized resource. Git repositories serve as the single source of truth for desired application and infrastructure

state in a GitOps workflow, and infrastructure as code stored in version control creates a durable audit log of every authorized change to that state.

These capabilities give VCF a strong technical foundation for tracking virtual infrastructure assets with accurate, real-time data at multiple levels of granularity. However, the broader requirements of this control, including business justification tracking, organization-defined accountability information, and formal review and audit processes for the full scope of technology assets, applications, services, and data, require organizational policies and processes that operate alongside the platform's inventory capabilities.

### **VMware vDefend (Contributes)**

VMware vDefend's Security Services Platform (SSP) maintains an inventory of network-visible workloads organized into a hierarchical asset collection spanning regions, zones, environments, applications, and application tiers. The Publish Inventory Assets tab in SSP displays infrastructure asset details including asset names, asset types, IP addresses, and total VM counts for assets sourced from imported CSV files, discovered services, or published infrastructure assets, providing accurate, granular records of network-visible assets.

Platform Inventory monitoring supports ongoing inventory accuracy through several mechanisms. Administrators can filter infrastructure assets by Name and Status, identifying assets that are timed out or out of sync. The inventory hierarchy view shows regions, zones, and VMs so administrators can verify correct definition. SSP Inventory displays assigned tags for each infrastructure asset, and environment rows can be expanded to view tag assignments and confirm hierarchy accuracy. The platform also collects and displays VM tags with their respective scopes, supporting classification and tracking. Published applications and their application types are verifiable in the Inventory > Applications interface.

SSP identifies and publishes application assets, classifying them as either critical or regular applications. Application Asset Collections represent groups of workloads delivering enterprise software functions. Security Intelligence within SSP displays application associations for compute entities, indicating the tiers within each application to which a given compute entity belongs. Administering compute entity classifications in Security Intelligence requires appropriate privileges, supporting access control over classification changes. Consistent naming conventions are recommended when preparing inventory data for import, and the Asset Prefix setting enables standardized naming during segmentation planning and monitoring.

In disconnected mode, usage files include an `asset_id` field providing a unique asset identifier, supporting asset tracking in environments without continuous connectivity.

vDefend's inventory scope is limited to network-visible workloads and does not replace enterprise-wide TAASD inventory tools, authorized software catalogs with business justification records, or data asset registries required for full AST-02 compliance.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to asset inventory requirements by providing built-in visibility into the database instances, infrastructure resources, and users it manages. This visibility supports tracking and accountability for the subset of technology assets that DSM governs. Organization-wide TAASD inventory across all asset categories requires organizational processes and additional tooling beyond DSM itself.

DSM tracks the association between deployed databases and the infrastructure policies under which they were provisioned. Administrators can review databases and their configuration details through the Databases tab in the Infrastructure Policies view of the DSM Administrator UI, which displays each policy alongside the databases bound to it. Because infrastructure policies define the compute, storage, and networking resources allocated to databases, including allowed VM classes, this view gives administrators a structured picture of how platform resources are being consumed. The About the DSM UI Views section confirms the Infrastructure Policies view lists all policies available in the environment and the databases associated with each.

DSM administrators can define and configure data service policies for the data services DSM manages, supporting compliance with organizational standards across tenants. Each policy can be tailored to specific requirements and assigned to one or more organizations to enforce consistent configurations. For tenant-facing self-service, the DSM Consumption Operator

creates infrastructure policies as cluster-scoped resources in the consumption cluster and requires an `allowedInfrastructurePolicies` list that defines which policies a tenant cluster may use, giving administrators a clear inventory of the policies in scope per cluster. Tenant users create and consume databases under a Supervisor namespace through the VCF Automation Cloud Consumption Interface (CCI), and the DSM portal exposes a Consumption Operator endpoint that provides access to deployment artifacts.

For database-level visibility, the Database Health view in the DSM UI collects metric data for each database instance and cross-references alerts with resolution paths. DSM deploys a Telegraf agent on the Provider Appliance and a local Telegraf agent on each workload cluster to gather VM-level metrics such as CPU, memory, and disk usage, plus engine-specific metrics. DSM can forward metrics to an external Metrics target server, supporting integration with external monitoring or inventory aggregation systems.

For auditors, DSM's inventory-relevant information is accessible through the Administrator UI and is available to personnel with the Admin role. The Databases tab, Infrastructure Policies view, Database Health view, and Consumption Operator policy inventory collectively provide the granularity needed to account for DSM-managed database assets and the policies governing them. The documented DSM user roles (vSphere administrator, VCF Automation organization administrator, VCF Automation project user) clarify which personnel have visibility into which inventory views.

DSM provides resource tracking and visibility within its own management scope. DSM does not perform organization-wide asset discovery and does not inventory physical infrastructure, non-database applications, or data assets outside its management domain. A TAASD inventory program spanning all asset categories requires a CMDB or dedicated asset management solution that can aggregate DSM resource data alongside information from other platform components.

Not applicable for this control: VCF Protection and Recovery, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-1.7-001

> Protocols are put in place to ensure GAI systems are able to be deactivated when necessary.

**SCF Controls:** AAT-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-2.1-001

> Establish organizational roles, policies, and procedures for communicating GAI incidents and performance to AI Actors and downstream stakeholders (including those potentially impacted), via community or official resources (e.g., AI incident database, AVID, CVE, NVD, or OECD AI incident monitor).

**SCF Controls:** AAT-01, AAT-08

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV-2.1-002

> Establish procedures to engage teams for GAI system incident response with diverse composition and responsibilities based on the particular incident type.

**SCF Controls:** AAT-01, AAT-08

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-2.1-003**

> Establish processes to verify the AI Actors conducting GAI incident response tasks demonstrate and maintain the appropriate skills and training.

**SCF Controls:** AAT-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-2.1-004

> When systems may raise national security risks, involve national security professionals in mapping, measuring, and managing those risks.

**SCF Controls:** AAT-01, AAT-09.1, AAT-16.9, GOV-06

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-2.1-005

> Create mechanisms to provide protections for whistleblowers who report, based on reasonable belief, when the organization violates relevant laws or poses a specific and empirically well-substantiated negative risk to public safety (or has already caused harm).

**SCF Controls:** HRS-15

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-3.2-001**

> Policies are in place to bolster oversight of GAI systems with independent evaluations or assessments of GAI models or systems where the type and robustness of evaluations are proportional to the identified risks.

**SCF Controls:** AAT-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-3.2-003**

> Define acceptable use policies for GAI interfaces, modalities, and human-AI configurations (i.e., for chatbots and decision-making tasks), including criteria for the kinds of queries GAI applications should refuse to respond to.

**SCF Controls:** AAT-01, TDA-21

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-3.2-004**

> Establish policies for user feedback mechanisms for GAI systems which include thorough instructions and any mechanisms for recourse.

**SCF Controls:** AAT-01, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-3.2-005

> Engage in threat modeling to anticipate potential risks from GAI systems.

**SCF Controls:** TDA-06.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



### **Control GV-4.1-001**

> Establish policies and procedures that address continual improvement processes for GAI risk measurement. Address general risks associated with a lack of explainability and transparency in GAI systems by using ample documentation and techniques such as: application of gradient-based attributions, occlusion/term reduction, counterfactual prompts and prompt engineering, and analysis of embeddings; Assess and update risk measurement approaches at regular cadences.

**SCF Controls:** AAT-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-4.1-002

> Establish policies, procedures, and processes detailing risk measurement in context of use with standardized measurement protocols and structured public feedback exercises such as AI red-teaming or independent external evaluations.

**SCF Controls:** AAT-01, AAT-02.1, AAT-07.2, AAT-15, AAT-15.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV-4.1-003

> Establish policies, procedures, and processes for oversight functions (e.g., senior leadership, legal, compliance, including internal evaluation) across the GAI lifecycle, from problem formulation and supply chains to system decommission.

**SCF Controls:** AAT-01, AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-4.2-001

> Establish terms of use and terms of service for GAI systems.

**SCF Controls:** AAT-11, HRS-05.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-4.2-002

> Include relevant AI Actors in the GAI system risk identification process.

**SCF Controls:** AAT-02.1, AAT-09, AAT-11, AAT-11.3, RSK-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control GV-4.2-003**

> Verify that downstream GAI system impacts (such as the use of third-party plugins) are included in the impact documentation process.

**SCF Controls:** AAT-07.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-4.3-002

> Establish organizational practices to identify the minimum set of criteria necessary for GAI system incident reporting such as: System ID (auto-generated most likely), Title, Reporter, System/Source, Data Reported, Date of Incident, Description, Impact(s), Stakeholder(s) Impacted.

**SCF Controls:** AAT-01, AAT-16.8, AAT-16.9, MON-01

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX

Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states (Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes `system:monitoring` RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.



VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the pais-controller-manager service, allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.IlmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT\_ENOUGH\_BASELINE, and FAILURE.

The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

### **Control GV-4.3-003**

> Verify information sharing and feedback mechanisms among individuals and organizations regarding any negative impact from GAI systems.

**SCF Controls:** AAT-10, AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-5.1-001

> Allocate time and resources for outreach, feedback, and recourse processes in GAI system development.

**SCF Controls:** AAT-11, AAT-11.1, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-5.1-002

> Document interactions with GAI systems to users prior to interactive activities, particularly in contexts involving more significant risks.

**SCF Controls:** AAT-07.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-001

> Categorize different types of GAI content with associated third-party rights (e.g., copyright, intellectual property, data privacy).

**SCF Controls:** AAT-12, AAT-12.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV-6.1-002

> Conduct joint educational activities and events in collaboration with third parties to promote best practices for managing GAI risks.

**SCF Controls:** SAT-02

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-003

> Develop and validate approaches for measuring the success of content provenance management efforts with third parties (e.g., incidents detected and response times).

**SCF Controls:** AAT-10.17, AAT-12.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-004

> Draft and maintain well-defined contracts and service level agreements (SLAs) that specify content ownership, usage rights, quality standards, security requirements, and content provenance expectations for GAI systems.

**SCF Controls:** AAT-12.1, IAO-03.2, TPM-05

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

### VMware vDefend (Contributes)

VMware vDefend (vDefend) contributes to protecting sensitive and regulated data in support of contracts by enabling microsegmentation through the Distributed Firewall (DFW), which enforces least-privilege network access controls around workloads that collect, process, transmit, or store contract data. In 9.1, privileged labels provide a tamper-proof mechanism for anchoring firewall rules to immutable labels, preventing virtual machines from leaking out of security groups and maintaining the integrity of network isolation boundaries around protected workloads.

DFW packet logs capture rule set, rule ID, direction, protocol, and source and destination addresses and ports, providing an audit trail for traffic flows around workloads handling contract data. The Gateway Firewall extends this protection to north-south traffic flows.

Security Services Platform (SSP) supports a structured approach to coverage: the Application Inventory prioritizes securing critical applications before regular ones, and Security Policies gives operators visibility into protected and unprotected network flows with drill-down into individual flow details. The Security Segmentation report breaks down unique traffic flows

by protection status and workload type, allowing operators to verify that workloads handling contract data are fully covered by policy.

VMware vDefend can identify and control risky application protocols that transport data in clear text, including HTTP, Telnet, FTP, TFTP, LDAP, POP3, and IMAP, supporting detection and restriction of unencrypted data paths. Network Detection and Response (NDR) anonymizes sensitive customer information when sharing telemetry data to the cloud, and SSP stores collected data using encryption at rest.

Data governance obligations, including contractual data handling requirements, access agreements, and regulatory compliance documentation, remain organizational responsibilities outside vDefend's scope.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer mechanisms relevant to protecting sensitive and regulated data in transit at the application delivery tier.

For data in transit, each virtual service that handles encrypted connections is configured with an SSL/TLS profile that specifies the accepted cipher suites and protocol versions. These profiles are configurable per virtual service, allowing organizations to enforce strong cryptographic standards on connections carrying sensitive or regulated data. The System-Secure-HTTP application profile provides an additional layer of protection by enforcing HTTPS, protecting cookies, managing client IP handling, and controlling protocol behavior for HTTP virtual services.

TLS session persistence state is stored in encrypted form at the Service Engine so that session data is not exposed when a client reconnects to a different Service Engine. Communication between Avi Controllers and Service Engines uses encrypted channels.

Avi's Analytics Profile includes a sensitive log profile capability that controls how sensitive data appearing in client requests is handled in application logs. Operators configure this setting to suppress or mask fields that may contain regulated information, reducing the risk of sensitive data being written to log storage in cleartext.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) supports PKIProfile resources that enable certificate-based authentication and encryption for communication with backend services. The RouteBackendExtension custom resource definition provides backend TLS configuration capability, supporting encryption of traffic between Service Engines and backend servers. The System-Standard SSL Profile can be applied through AKO to enable SSL/TLS re-encryption for backend traffic using modern cipher suites.

The Avi Cloud Console Application Rules service allows organizations to protect applications from known vulnerabilities by enabling managed application security rules on their Avi Controllers.

Fully satisfying this control also requires an organizational data classification program that identifies which data is sensitive or regulated under applicable contracts, maps that data to the application flows handled by Avi virtual services, and verifies that Avi's encryption and logging controls are applied to those flows. Avi provides the technical mechanisms; the organizational program determines how and where they are applied.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-005

> Implement a use-cased based supplier risk assessment framework to evaluate and monitor third-party entities' performance and adherence to content provenance standards and technologies to detect anomalies and unauthorized changes; services acquisition and value chain risk management; and legal compliance.

**SCF Controls:** TPM-04.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-006

> Include clauses in contracts which allow an organization to evaluate third-party GAI processes and standards.

**SCF Controls:** TPM-04.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-007

> Inventory all third-party entities with access to organizational content and establish approved GAI technology and service provider lists.

**SCF Controls:** TPM-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-008

> Maintain records of changes to content made by third parties to promote content provenance, including sources, timestamps, metadata.

**SCF Controls:** AAT-12.1, AAT-12.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control GV-6.1-009

> Update and integrate due diligence processes for GAI acquisition and procurement vendor assessments to include intellectual property, data privacy, security, and other risks. For example, update processes to: Address solutions that may rely on embedded GAI technologies; Address ongoing monitoring, assessments, and alerting, dynamic risk assessments, and real-time reporting tools for monitoring third-party GAI risks; Consider policy adjustments across GAI modeling libraries, tools and APIs, fine-tuned models, and embedded tools; Assess GAI vendors, open-source or proprietary GAI tools, or GAI service providers against incident or vulnerability databases.

**SCF Controls:** AAT-01, TPM-01, TPM-04.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.1-010

> Update GAI acceptable use policies to address proprietary and open-source GAI technologies and data, and contractors, consultants, and other third-party personnel.

**SCF Controls:** HRS-05.1, HRS-05.3, TPM-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.2-001

> Document GAI risks associated with system value chain to identify over-reliance on third-party data and to identify fallbacks.

**SCF Controls:** AAT-25, AAT-25.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) defines a structured, multi-stage value chain for creating and deploying AI workloads, with distinct stakeholder roles at each stage. The platform separates responsibilities across VI administrators, organization administrators, MLOps engineers, DevOps engineers, and AI application developers, with each role scoped to a specific phase of the deployment lifecycle.

Infrastructure provisioning begins with VI administrators configuring GPU-accelerated workload domains, namespaces, and VMware Kubernetes Service (VKS) Supervisors in VMware vCenter and VMware ESX. Organization administrators set up the VCF Automation organization. PAIS must be activated in organization namespaces by an organization administrator or MLOps engineer after namespace creation, establishing the foundation before any AI workloads can be deployed.

Model acquisition is registry-driven. A Harbor administrator creates a dedicated Harbor project for PAIS in the private Harbor registry, into which PAIS artifacts are uploaded as part of the installation process. OCI-compliant registries from other vendors are also supported. The Harbor project's user access controls restrict who can push or pull artifacts, creating an auditable record of which images are available and how they arrived. PAIS deployments can run in connected environments with internet access or in disconnected (air-gapped) environments, with disconnected operation requiring the Harbor registry to be pre-populated with the AI catalog images in advance.

Compute provisioning is driven by VCF Automation catalog items created through the Private AI Services Quickstart. The catalog items include AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, and are provisioned by users in selected namespaces. Catalog item visibility is verified per project so that PAIS catalog items are available only to members of the selected project. A machine retrieving information about PAIS must have access to VCF Automation, the VCF Consumption CLI, and kubectl, which scopes the provisioning interfaces to the responsible stakeholder.

PAIS provides a UI and API for AI application developers to interact with deployed models and services. Data scientists and MLOps engineers compose applications by using PAIS Knowledge Bases linked to external data sources such as Microsoft SharePoint sites and Amazon S3 compatible stores. A Knowledge Base data source is created with a specific type that cannot be changed after creation, and one data source can be linked to multiple Knowledge Bases. DevOps engineers visualize PAIS component health and performance metrics in observability platforms such as Grafana and VCF Operations, providing accountability for each stage of the value chain.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.2-002

> Document incidents involving third-party GAI data and systems, including open- data and open-source software.

**SCF Controls:** CFG-04.1, TPM-04

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV-6.2-003

> Establish incident response plans for third-party GAI technologies: Align incident response plans with impacts enumerated in MAP 5.1; Communicate third-party GAI incident response plans to all relevant AI Actors; Define ownership of GAI incident response functions; Rehearse third-party GAI incident response plans at a regular cadence; Improve incident response plans based on retrospective learning; Review incident response plans for alignment with relevant breach reporting, data protection, data privacy, or other laws.

**SCF Controls:** IRO-04, IRO-06, TPM-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.2-004

> Establish policies and procedures for continuous monitoring of third-party GAI systems in deployment.

**SCF Controls:** MON-01

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides enterprise-wide monitoring through integrated tools that span infrastructure health, performance metrics, compliance assessment, log analysis, and alerting.

VCF Operations continuously monitors the operational state of all VCF components to detect conditions that may affect availability or compliance. It collects metrics across compute, storage, and networking resources, and correlates them over time to identify trends that may lead to potential failures. VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. Platform operators can configure alerts, perform log analysis, run infrastructure diagnostics, and review VCF health from a unified interface.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status. Compliance-related alerts are triggered on objects and displayed through a dedicated compliance alert subtype.

The alerting subsystem in VCF Operations supports the full lifecycle of alert management. Administrators can configure and manage alert definitions to monitor infrastructure events and conditions, including performance metrics, log events, and custom conditions configured through the Management Pack Builder. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention. Administrators can create policies to govern how alert definitions are evaluated, including which objects to monitor and what thresholds to apply, and can apply consistent practices to optimize alert behavior across monitored objects.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

VCF Log Management provides centralized log collection and analysis. It ingests logs from VMware vCenter, VMware ESX hosts, NSX, vSAN, VCF Automation, VCF Operations, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture. The platform provides dashboards and analytics for troubleshooting and security investigation. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log forwarding to external SIEM or syslog targets is configurable, with support for TLS encryption to protect log data in transit. The vCenter syslog forwarding API supports TCP, UDP, TLS, and RELP protocols. NSX Manager syslog supports TLS and requires port 6514 for encrypted log transmission.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters to provide real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The vSphere Client provides direct visibility into tasks and events for change tracking and troubleshooting. VCF ships with preconfigured vSphere alarms that are active by default and monitor specific components including the Identity Management Service, Message Bus Configuration Service, ESX Agent Manager, VMware Service Control Agent, vSphere HA host status, and host connection and power state. The vCenter Management Interface provides appliance-level health visibility through an Overall Health badge that reflects one of five states

(Good, Warning, Alert, Critical, or Unknown) across all vCenter components, and notifies administrators of available security patches through Critical or Alert badge indicators when automatic patch checks are enabled.

When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The VCF Automation Monitor tab surfaces deployment health information sourced from VCF Operations, and deployment cards display Last Request Status information that tracks the most recent operation on each deployment (Create, Update, or Delete) and its outcome (Successful, In Progress, or Failed). The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Management Packs extend monitoring to network devices, including sensor monitoring for devices such as switches and routers. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

The VMware Kubernetes Service (VKS) layer of VCF extends enterprise monitoring to container workloads and Kubernetes infrastructure. VKS clusters support MachineHealthCheck objects for both control plane nodes and worker node deployments; administrators manage these through the VCF CLI `vcf cluster machinehealthcheck` command, which supports configuration of unhealthy-condition definitions, maximum unhealthy thresholds (expressed as an absolute number or a percentage), and label selectors to target specific machines. The VCF CLI `vcf cluster machinehealthcheck node get` and `vcf cluster machinehealthcheck control-plane get` commands retrieve node and control plane health status on demand. VKS cluster health conditions, including the Ready and ControlPlaneReady status indicators, reflect the operational state of each cluster and are accessible via `kubectl` and the VCF CLI. The VCF Automation Provider Management UI includes a Services overview interface that exposes VKS cluster management functions and the health status of all cluster elements, giving platform operators a centralized view of the VKS tier. The Kubernetes API server within VKS clusters exposes diagnostic and health check endpoints (`/healthz`, `/livez`, `/readyz`, `/statusz`, and `/metrics`) that external monitoring systems can scrape to track API server availability and readiness; the `kube-apiserver` also emits the `kubernetes_healthchecks_total` counter and `kubernetes_healthcheck` gauge metric, which report structured health check status for components including `etcd` and `autoregister-completion`. Access to these monitoring endpoints is governed by the built-in Kubernetes system:monitoring RBAC group, which grants read access to liveness, readiness, and metrics endpoints while restricting broader cluster access. The Kubernetes Watch API allows monitoring tools to track changes to any API object as a live stream, supporting event-driven monitoring without continuous polling. The Node Problem Detector monitors node health and surfaces node-level problems as Kubernetes events and node conditions that external monitoring systems can consume via the event stream.

For workload-level monitoring within VKS clusters, Prometheus Operator is available as a standard package and defines custom resource definitions to deploy and manage Prometheus and Alertmanager StatefulSets, enabling high-availability alerting configurations. The Prometheus Alertmanager custom resource definition configures alert grouping, inhibition, and routing to external notification systems. The Istio service mesh, also available as a standard package on VKS clusters, provides service-level monitoring alongside its traffic management capabilities. The Dynatrace Operator can be deployed on VKS clusters to automate the deployment, scaling, and maintenance of the Dynatrace monitoring stack. Historical analysis, dashboarding, and alerting on cluster-level metrics require a dedicated monitoring solution configured to scrape the VKS metrics endpoints and subscribe to the Kubernetes event stream. The `vcf cluster support-bundler create` command gathers diagnostic information from Supervisor and VKS clusters when troubleshooting is needed.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as activity success counts. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) includes a built-in observability stack that supplies monitoring data for AI infrastructure and AI workloads. PAIS Controller metrics are exposed at a Prometheus metrics endpoint on the `pais-controller-manager` service,

allowing collection by monitoring systems and visualization in observability platforms such as Grafana. Observability is activated by updating the PAISConfiguration custom resource with optional sections for Prometheus metrics collection and LLM trace forwarding. The Prometheus runtime can be configured with a specified storage class policy and a configurable metrics retention period, giving administrators control over how long monitoring data is stored. A Prometheus server pod must be in a ready and running state for observability to function.

LLM trace data from PAIS can be forwarded to an OpenTelemetry Collector endpoint over http/protobuf or gRPC, providing distributed tracing for AI model inference activity. The observability.llmTraces configuration governs trace forwarding and works alongside the Prometheus metrics pipeline to produce two signals: metrics for health and performance, and traces for inference-level behavior. PAIS Controller metrics include the Model Endpoint Controller and PAIS Configuration Controller, giving monitoring platforms component-level visibility into PAIS operations.

In 9.1, PAIS adds direct integration with VCF Operations. The controller-pod-metrics-streaming setting activates streaming of PAIS controller pod metrics from the Supervisor cluster to VCF Operations, allowing administrators to view PAIS metrics alongside other VCF infrastructure metrics. A Telegraf deployment in the vmware-system-monitoring namespace uses a telegraf-user-config ConfigMap to manage user-configured monitoring endpoints for PAIS. The VCF Consumption CLI connects to the Supervisor endpoint and enables VI administrators to stream metrics from the PAIS controller pod. DevOps engineers can visualize health and performance metrics for PAIS components running in a VCF Automation namespace using Grafana, and MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications and the models used in agents through the same observability platforms.

PAIS supplies the technical monitoring mechanisms this control requires. Enterprise-wide orchestration of monitoring controls, including alert threshold definition, escalation procedures, and integration with a centralized monitoring or log management platform, remain organizational responsibilities.

#### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) supports network security monitoring through multiple integrated capabilities that contribute to enterprise-wide monitoring frameworks.

Security Intelligence, hosted on the Security Services Platform (SSP), provides continuous visibility into network traffic flows across protected workloads. It monitors flows between application pairs, updates the Policy Protection Status for each application to indicate that flows are being monitored, and continuously detects new flows between environment pairs, alerting administrators to unauthorized or unexpected traffic. The Monitor & Plan Overview page presents a consolidated view of pending actions, data collection activity status, network security posture, flow trends, and a summary of suspicious traffic. The Security Intelligence Recommendations monitoring capability checks for changes in the scope of monitored entities every hour when the Monitoring toggle is enabled, allowing administrators to keep policy recommendations current as environments evolve. Segmentation Monitoring provides dedicated views of application and infrastructure flows with configurable time ranges spanning from the last hour to the last month, and displays flows related to detected infrastructure servers in a specified time interval.

The Network Detection and Response (NDR) Sensor checks the status of activated detection features every 15 minutes and updates its configuration accordingly, supporting sustained threat detection coverage. NDR Sensor health status monitoring tracks whether key components, including network traffic capture, file analysis, and data transmission, are operating properly. The NDR Sensor also sends alerts notifying administrators of conditions such as services being down, high CPU, memory, or disk usage, packet drops, or missed heartbeats. NDR provides role-based access control covering triage operations such as viewing detections and campaigns, as well as SIEM configuration management.

The Security Services Platform monitors its own health, with Yellow or Red health status indicators displayed when issues occur in subcomponents. SSP monitoring tracks the status of the flow clustering job that runs every hour and reports suspicious traffic detector execution status after each run, with values such as SUCCESS, NOT\_ENOUGH\_BASELINE, and FAILURE.



The Security dashboard provides a consolidated view for monitoring and configuring security features across network workloads. In federated deployments, the Global Manager provides centralized event management and monitoring for malicious IP blocking activity across all Local Managers.

vDefend generates Unified Security Logs that VCF Log Management can collect and analyze. These logs cover Distributed Firewall, Gateway Firewall, Identity Firewall, FQDN Analysis, TLS Inspection, Intrusion Detection/Prevention System (IDPS), and URL Filtering activity. Broader log aggregation and SIEM correlation for enterprise-wide monitoring remain the responsibility of the SIEM and logging infrastructure deployed alongside vDefend.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides monitoring capabilities specific to the disaster recovery domain and integrates with the broader VCF monitoring ecosystem through dedicated Protection and Recovery dashboards in VCF Operations. VCF Operations collects configuration, component health, and usage information from protection and recovery servers and site pairs, presenting this through an overview dashboard that displays all site pairs, configurations, health scores, and protection and recoverability status for sites and virtual machines. PNR provides default health alerts for protection groups, recovery plans, cloud file systems, recovery SDDCs, and protected sites through VCF Operations, and the dashboards surface alerts informing administrators about configurations and deployments that require attention. Separate dashboard views cover vSAN Snapshots and Replication monitoring, and an Inventory view provides health status, metrics, alerts, and network topology for all monitored objects.

Within its own domain, PNR provides event logging and configurable alarms for replication and recovery operations. Administrators can create alarms that trigger on specified event conditions, with support for email notifications, SNMP traps, or script execution in response. PNR monitors connections between sites by sending periodic ping requests, logs connection check events, and generates alarms when broken connections are detected. The alarm system generates warning-level alerts for expired snapshot schedules, replication errors such as missing VMs, and connectivity issues with protected and target sites. PNR also monitors resource consumption on the Protection and Recovery Server host and raises alarms when configurable resource thresholds are reached.

PNR includes a health monitoring service that checks each health finding every five minutes and records a timestamp at each check. Health findings are tracked with status history that can be reviewed over configurable time periods, defaulting to a 24-hour window. The Protection and Recovery Appliance supports syslog forwarding to a remote syslog server for log analysis and centralized monitoring, allowing appliance-level events to flow into existing log management infrastructure.

The Clean Room Orchestrator, part of PNR's Cyber Recovery capabilities, supports monitoring of clean room events, tasks, and alarms for recovery operations. Clean Room Orchestrator can forward events to VCF Operations, Microsoft Sentinel, or Splunk Cloud for centralized monitoring, supporting organizations that require DR event data to flow into enterprise SIEM and log management platforms as part of a broader monitoring strategy. The Clean Room Orchestrator integrates with endpoint detection and response tools, including CrowdStrike and Carbon Black sensor appliances, for threat detection within isolated recovery environments.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to enterprise-wide monitoring controls through a layered set of observability capabilities covering database health, infrastructure compliance, and event-driven alerting.

DSM provides a built-in monitoring framework that tracks database instance health across multiple dimensions. From the Monitoring tab in the DSM UI or the vSphere Client, administrators and authorized users can view real-time and historical metrics for database VMs, including CPU Health, Data Disk Health, System Disk Health, Max Connections, Active Connections, Write Throughput, Read Throughput, Thread Resource Utilization, Slow Queries per Second, InnoDB Buffer Usage, and InnoDB Reads and Writes. The Monitoring page defaults to the last three hours of aggregated metric data, with the time range adjustable through the Time Range Last dropdown. This visibility supports detection of resource contention, performance degradation, and connectivity anomalies at the database layer.

DSM's alert framework provides configurable thresholds for warning and critical conditions on key health indicators. Administrators and users can set separate warning and critical thresholds for CPU Health, Data Disk Health, System Disk Health, and Max Connections parameters. When thresholds are exceeded, DSM generates typed alerts such as Database Engine Health, Custom Config Health, and Backup Storage Health alerts. DSM monitors database replication status and raises an alert when a secondary database is not replicating data from the primary. DSM also raises an alert when metrics are no longer being received from a cluster, supporting detection of monitoring gaps. Alerts can be activated or deactivated per data service through the "Enable Alerts for DB Alert" setting, providing granular control over which databases are subject to active alerting. For each alert, DSM provides mitigation suggestions to help administrators resolve issues without disrupting database services.

In addition to database-level alerts, DSM generates global infrastructure alerts that surface vCenter integration and infrastructure policy issues. These include `INFRASTRUCTURE_POLICY_VC_ALARMS`, raised when vCenter resource alarms are active; `INFRASTRUCTURE_POLICY_CLUSTER_COMPLIANT` and `INVALID_SUPERVISOR_INFRASTRUCTURE_POLICY_STATUS`, which reflect cluster compliance state; `VCENTER_CONNECTIVITY`, raised when vCenter connectivity fails and triggering troubleshooting steps that include verifying connectivity and checking authentication logs; and `LicensingNotUpdated` and `vCenterBinding` API status alerts that surface license and API integration conditions. A Global Alerts page in the DSM UI provides a centralized view of these alerts during and after installation and ongoing operation.

In 9.1, DSM integrates with VCF Operations to extend observability beyond the DSM UI. When configured, VCF Operations automatically discovers and monitors PostgreSQL and MySQL clusters in the Ready state and displays a Data Services View dashboard showing active alerts and inventory items. VCF Operations presents performance data across three levels: cluster-level for overall health, node-level for infrastructure resource use, and database-level for KPIs including Active Connections, Commits, Rollbacks, and Deadlocks. This integration requires configuring the connection between DSM and VCF Operations before use.

DSM also adds SQL Server as a supported database type, with dedicated monitoring through an integrated InfluxDB instance and Telegraf agents deployed across the provider appliance and SQL Server workload clusters. The monitoring framework supports metrics-based and status-condition-based alerts for SQL Server, covering database engine degradation, non-operational status, and automated or transaction log backup failure conditions.

DSM supports event notification to external systems through a webhook integration. Webhooks transmit alert notifications containing the triggered date, triggered time, triggered user email, task status, previous status, and task type. This allows DSM alerts to feed into centralized monitoring or incident management platforms maintained by the organization. DSM generates plug-in registration logs that administrators can review for vCenter connectivity errors, and DSM's troubleshooting guidance directs administrators to review active vCenter infrastructure alarms and resolve underlying issues identified through the alert system.

Enterprise-wide monitoring requires organizational decisions about monitoring architecture, log aggregation platforms, alerting policies, and operational response procedures that lie outside DSM's scope. DSM provides the data and integration points; the organization must determine how those signals are collected, correlated, and acted upon across the broader environment.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) contributes to enterprise-wide monitoring through application-delivery-layer mechanisms built into the Avi Controller and Service Engines.

The Avi Controller monitors Service Engine metrics and sends alarms and notifications to administrators when resource utilization data exceeds defined thresholds. Administrators configure custom thresholds on Service Engine groups through the Resource Events tab in the Avi UI. The Alert feature processes system events and metrics against user-defined rules and generates alerts that trigger configured actions, including sending an email, a syslog message, or an SNMP trap. Alert notifications can be forwarded to remote syslog servers for integration with centralized log management and monitoring platforms.

ControlScripts extend this event-response capability: a ControlScript can alter Avi configuration or communicate to external systems, including through webhook integrations with external monitoring tools, in response to defined system events. This supports dynamic responses including resource scaling or automated notifications based on health scores from monitoring data.

The Avi Controller and Service Engines track health score changes and SSL certificate expiration events. Avi integrates with external monitoring tools such as Prometheus for metrics collection and analysis. User-Defined Metrics allow administrators to define and extract customized telemetry data for specific compliance or reporting needs through the API. Real-time metrics are available via API but deactivate by default after 30 minutes to conserve resources and must be reactivated when sustained real-time visibility is required.

At the data plane, Avi health monitors track the status of backend servers and Service Engines continuously. Service Engine health monitoring records detailed server operational status, including health monitor name, type, last transition timestamps, rise count, fall count, total checks, and total failed checks. Each health monitor can be assigned its own threshold and timeout period for server health validation. Monitors support HTTP, HTTPS, TCP, and UDP health-check protocols with configurable success and failure thresholds, send intervals, and receive timeouts.

In Kubernetes environments managed by the Avi Kubernetes Operator (AKO), the HealthMonitor custom resource definition (CRD) allows users to define custom health monitoring configurations for backend services with fine-grained control over health check parameters. The Avi Multi-Cluster Kubernetes Operator (AMKO) GlobalDeploymentPolicy supports health monitor references for consistent monitoring across multi-cluster deployments. Within VCF Automation, a HealthMonitor custom resource can create monitors for tracking backend pool member status using TCP, PING, and HTTP check types.

## Control GV-6.2-005

> Establish policies and procedures that address GAI data redundancy, including model weights and other system artifacts.

**SCF Controls:** AAT-01, AAT-09, TDA-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control GV-6.2-006

> Establish policies and procedures to test and manage risks related to rollover and fallback technologies for GAI systems, acknowledging that rollover and fallback may include manual processing.

**SCF Controls:** AAT-25.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control GV-6.2-007

> Review vendor contracts and avoid arbitrary or capricious termination of critical GAI technologies or vendor services and non-standard terms that may amplify or defer liability in unexpected ways and/or contribute to unauthorized data collection by vendors or third-parties (e.g., secondary data use). Consider: Clear assignment of liability and responsibility for incidents, GAI system changes over time (e.g., fine-tuning, drift, decay); Request: Notification and disclosure for serious incidents arising from third-party data and systems; Service Level Agreements (SLAs) in vendor contracts that address incident response, response times, and availability of critical support.

**SCF Controls:** TPM-01, TPM-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MANAGE 1.3

> Responses to the AI risks deemed high priority, as identified by the MAP function, are developed, planned, and documented. Risk response options can include mitigating, transferring, avoiding, or accepting.

**SCF Controls:** AAT-07, AAT-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MANAGE 2.2

> Mechanisms are in place and applied to sustain the value of deployed AI systems.

**SCF Controls:** AAT-01.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MANAGE 2.3

> Procedures are followed to respond to and recover from a previously unknown risk when it is identified.

**SCF Controls:** AAT-17.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to responding to and recovering from previously unknown AI-related risks through vSphere HA (automatic VM restart on host failure), DRS (workload rebalancing), vSAN fault domains (storage resilience), and VM snapshots (point-in-time recovery). If AI infrastructure is affected by a novel threat, these mechanisms support rapid recovery. VCF Operations lifecycle management supports emergency patching of the platform.

The VCF platform's Consumption layer, delivered through VMware Kubernetes Service (VKS) and the Supervisor, extends these capabilities to containerized AI workloads running on Kubernetes and provides observability, containment, and recovery mechanisms relevant to novel AI risks.

**Observability and Detection.** Supervisor integrates with the Continuous Integration and Delivery with Harness supervisor service, which includes a Dynatrace AI engine that automatically detects anomalies, identifies root causes, and surfaces intelligent alerts for workloads including AI workloads. The Kubernetes API server audit log records API server activity for VKS clusters, including changes to workload configurations and access patterns. Pod Security Admission in warn or audit mode generates warnings when pods running in a namespace violate the configured security level, flagging unrestricted capabilities, allowPrivilegeEscalation, or non-standard seccomp profiles, which supports identifying workloads that may pose elevated risk. VKS Cluster Management Policy Insights provide centralized visibility into the governance health of the VKS cluster estate and generate actionable data for troubleshooting policy enforcement issues, including Health alerts for infrastructure-level failures such as an unhealthy policy operator or a failed Gatekeeper installation, Sync signals indicating that policy definitions failed to propagate to target clusters, and Incompatibility warnings when a cluster contains an external Gatekeeper installation not managed by cluster management. MachineHealthCheck monitors node health conditions classified by severity and can trigger automated remediation when nodes hosting AI workloads become unhealthy.

**Containment and Isolation.** When a risk is identified, Kubernetes NetworkPolicy objects enforced by Antrea at the pod level can be applied or updated to isolate the affected namespace or workload from the rest of the cluster. Kubernetes RBAC restricts access to impacted services and, when properly scoped, helps limit privilege escalation. Pod Security Admission enforcement can be tightened on specific namespaces to block workloads that do not meet the required security posture, limiting the scope of a risk involving a compromised or misbehaving AI component. The Kubernetes documentation recommends adopting a zero trust architecture that minimizes attack surfaces, including for internal threats, which supports limiting the lateral spread of a newly identified risk.

**Recovery.** VKS supports deployment rollback and revision history, allowing operators to revert AI workloads to a prior known-good version. The MachineDeployment remediation.maxInFlight parameter controls how many in-flight remediations of unhealthy machines occur simultaneously, expressed as an integer or percentage, limiting disruption during large-scale node replacements. Velero provides workload backup and restore for VKS clusters, enabling restoration of AI workloads to a pre-incident state. The declarative validation feature includes a safety mechanism for downgrade and rollback scenarios, allowing operators to disable the feature and fall back to prior validation behavior during recovery.

**Supply Chain Integrity.** AI and machine learning workloads on VKS clusters require Ubuntu VKr as the operating environment, providing a known software baseline that can be validated and replaced when a vulnerability is identified in the base image. Harbor, an open-source cloud-native private container registry that ships with Supervisor, can be deployed as a Supervisor Service and used as the private registry for VKS clusters. Harbor Registry instances run on the Supervisor with images organized by vSphere Namespace, and all VKS clusters on the same Supervisor automatically trust Harbor and can pull container images from it. In air-gapped environments, Harbor Supervisor Service must be configured as the private registry before upgrading VKS from a private registry, supporting controlled image provenance. Container images and other artifacts can be scanned for known vulnerabilities as part of supply chain security. The Kubernetes Image Policy admission controller

provides an additional enforcement layer by evaluating container images against a remote service before allowing access; the service returns an ImageReview response based on image reference, annotations, and namespace context, enabling operators to block images associated with a newly identified threat across VKS clusters. The Kubernetes Security Response Committee tracks and announces CVEs with security-related announcements via the kube-announce channel, giving operators an authoritative feed for newly identified platform-level risks. VKS cluster management enables governance of the operational consistency and security posture of the VKS cluster estate through policy-driven automation, helping maintain a controlled baseline from which deviations due to a novel risk can be detected.

Identifying novel AI-specific threats and developing response procedures are organizational responsibilities. Incident response plans must cover AI workload categories, personnel must be trained to recognize AI-specific threat indicators, and communication workflows must exist for escalating newly identified risks. VCF and the Consumption layer provide the infrastructure controls for containment and recovery, but the identification and classification of a novel AI risk depends on organizational judgment and monitoring practices built on top of these capabilities.

VMware Private AI Services (PAIS) contributes to responding to and recovering from previously unknown AI-related risks through AI-service-layer mechanisms that operate above the underlying VCF platform's infrastructure resilience.

VCF provides infrastructure-level resilience that supports incident response: vSphere High Availability restarts AI workload VMs on healthy hosts, Distributed Resource Scheduler rebalances workloads when host-level anomalies occur, vMotion migrates running AI workloads without downtime, and snapshot-based recovery enables point-in-time restoration of affected VMs. These capabilities allow rapid response at the infrastructure layer when an AI-related risk is identified.

At the AI service layer, PAIS provides several response mechanisms specific to AI workloads. Organization administrators or MLOps engineers activate PAIS in organization namespaces, and the same roles can deactivate or restrict access when a previously unknown risk is identified. Access to PAIS is gated through OIDC integration over HTTPS with the OIDC provider; restricting OIDC group membership or scope at the identity provider provides an identity-layer cutoff for PAIS service access. MLOps engineers validate ML models onboarded to PAIS against organizational security, privacy, and technical requirements, which helps identify problematic models before deployment and gives operators a basis for re-validation when a new risk surfaces.

For model storage and recovery, PAIS uses a Harbor registry, or another OCI-compliant registry, as the model storage backend, requiring authentication and certificate-based trust for model retrieval. Operators can remove a problematic model or restore a prior model version from the registry without redeploying the underlying infrastructure. PAIS Knowledge Bases support linked data sources including SharePoint sites and S3-compatible stores, with a maximum of ten data sources per knowledge base; an administrator can unlink a data source that is later identified as a risk source. PAIS observability is configured with a Prometheus runtime and a metricsRetention parameter (14 days by default), retaining metrics that support investigation and post-incident analysis when a risk is identified.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to responding to previously unknown AI and Autonomous Technologies-related risks through behavioral detection and automated response mechanisms at the network layer.

Security Intelligence uses a proprietary machine-learning algorithm to identify anomalous compute entity behavior by analyzing traffic flow patterns across the east-west distributed firewall environment. The machine learning runs as a scheduled process that makes inferred infrastructure classifications to establish behavioral baselines. Detected suspicious traffic events are categorized by impact type (Critical, High, Medium, and Low) to support prioritized response activities. The Security Intelligence Campaign view tracks the total number of detections and threats identified under Malicious Activity, providing a running record of security events that helps assess how effectively controls are responding to novel activity. The threat visualization canvas is a tool for rapid threat containment, identifying compromised assets, and updating microsegmentation policy in response to detected events.

The Network Detection and Response (NDR) component extends detection coverage by applying a combination of IDS, malware analysis, and network behavior analytics through the NDR Sensor to detect suspicious activity, lateral movement, and advanced threats. The NDR Sensor exports data to the vDefend Advanced Threat Prevention Cloud Service to enhance

detection capabilities for emerging and previously unknown threats. When the NDR component processes a custom IDS detection without a specified tactic, it defaults to an 'Undetermined' classification rather than discarding the event, flagging it for analyst review. The NDR component also dynamically manages the IDS signature set by deactivating signatures that are consistently false-positive prone, reducing noise and maintaining detection quality.

Intelligent Assist is an AI assistant feature accessible through the NSX Manager UI or Security Services Platform UI that provides analysis support for IDS/IPS events, detections, and campaigns. When threats are identified, Intelligent Assist can recommend remediation policies to support containment of newly identified risks. Remediation rules are added to the Intelligent Assist Remediation policy using the naming convention prefix 'ai-' and are not enabled by default; they require manual review and verification by the analyst or administrator before activation. Not all network anomalies can be remediated automatically; Intelligent Assist determines when remediation is not possible and flags the limitation for the operator. Applied remediation policies can be verified by navigating to Security > IDS/IPS & Malware Prevention > Emergency Threat Rules.

Knowledge-based signatures in vDefend IDS/IPS are limited to attacks that are already known. The behavioral analysis and ML-based anomaly detection in Security Intelligence, combined with the NDR Sensor's multi-method analytics, address this gap by providing visibility into network-layer behavior that falls outside known signature patterns.

Recovery activities beyond network-level containment and policy remediation, such as restoring affected AI systems, validating their integrity, or conducting post-incident recovery planning, fall outside vDefend's scope and require organizational incident response and recovery processes.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) contributes to responding to and recovering from previously unknown AI-related risks through its failover, isolated recovery, and integrated security analysis capabilities.

If an AI workload is affected by a novel threat, PNR's recovery plans can orchestrate failover to a protected site where the workload can resume operations. Recovery plan testing validates that all virtual machines will recover correctly, reducing the risk that an actual disaster recovery event fails to restore critical workloads.

The Cyber Recovery component of PNR provides an isolated clean room environment where AI workloads can be restored and analyzed separately from potentially compromised production infrastructure. Within the clean room, CrowdStrike integration performs behavioral analysis and machine learning-based detection to identify both known and unknown threats in real time, continuously monitoring endpoint activities during recovery validation. CrowdStrike ExPRT (Exploitability and Predictive Risk Technology) ratings assess vulnerability risk based on exploitability likelihood and predicted potential impact, and vulnerability risk scores on a 0-to-10 scale enable prioritization of remediation before workloads are promoted from the clean room to production. Carbon Black integration displays vulnerability analysis results including risk score details and environmental impact information to support remediation of discovered issues.

Replication scheduling with configurable recovery point objectives allows organizations to retain multiple recovery points, making it possible to restore AI workloads to a state that predates a threat materialization.

Identifying novel AI-related risks and developing response procedures are organizational responsibilities. PNR supplies the technical recovery and analysis mechanisms that organizations can incorporate into their incident response processes.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to responding to and recovering from previously unknown AI-related risks by providing backup, restore, high availability, and alerting capabilities for the databases that AI workloads depend on. If AI training data or model artifacts stored in DSM-managed databases are compromised by a novel threat, point-in-time recovery allows restoration to a state before the threat materialized, and automated backups with configurable retention provide multiple recovery points. Database replicas with automatic promotion support continued operation when a primary database is affected. For PostgreSQL workloads, multi-site deployment supports cross-site disaster recovery, including controlled redirection of a secondary instance to a new primary after promotion, with explicit acknowledgment of data-loss risk when demoting a previously blocked primary.

DSM emits a structured catalog of global alerts that help operators detect novel issues affecting database services. Alert types include DATABASE\_ENGINE\_HEALTH\_ALERT for database engine outages, read-only mode, or reduced availability; SYSTEM\_DISK\_HEALTH\_ALERT for system disk health; data-disk warning thresholds; and infrastructure policy alerts such as INFRASTRUCTURE\_POLICY\_ORPHAN\_VM\_FOUND, INFRASTRUCTURE\_POLICY\_VC\_ALARMS, INFRASTRUCTURE\_POLICY\_CLUSTER\_COMPLIANT, INVALID\_SUPERVISOR\_INFRASTRUCTURE\_POLICY\_STATUS, and NetworkOverlap Found. Alerts for database operation failures can be activated or deactivated, and webhooks can be configured to deliver CRITICAL or WARNING alert level information to external response tooling when database parameter thresholds are crossed. Administrators can collect support bundles for the affected cluster to assist in root-cause analysis and recovery.

Identifying novel AI-related risks and developing response and recovery procedures are organizational responsibilities. DSM supplies the technical mechanisms that those response actions act on.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides several application-layer mechanisms that organizations can deploy to respond to previously unknown Artificial Intelligence (AI) and Autonomous Technologies (AAT)-related risks as they are identified.

The Bot Management capability addresses AI-driven bot traffic through a three-step pipeline of detection, classification, and action. Avi Bot Management detects and manages bot traffic, distinguishing between good bots (search engine crawlers, website health monitors, vulnerability scanners) and bad bots (scrapers, spam, click fraud, bot impersonators, botnets), and enforces HTTP security policy actions such as closing connections for dangerous classifications. Bot Management assigns a confidence level to each classification decision of Bot, Human, or Undetermined, allowing policy actions to be tuned to the certainty of the detection. Avi Virtual Service Analytics App Learning classifies application traffic through trusted IP groups, supporting bot categories including Bad Bot, Dangerous Bot, Good Bot, Human, Unknown, and User-defined Bot. WAF Policies attach a Positive Security group to apply learned data and define hit and miss actions; both Application Insights and WAF Positive Security initially gather data through decoupled Learning functionality, enabling the WAF to adapt its enforcement posture as new threat patterns emerge and observed baseline behavior shifts.

The Live Security Threat Intelligence service, available through the Avi Cloud Console, delivers security threat feeds for various attack vectors in real time to protect applications from evolving threats. This is an opt-in service that is disabled by default on the Avi Load Balancer Controller and must be explicitly enabled. The IP Reputation service is used as a source for bot detection and classification, providing protection from bad IPs such as botnets, phishing sources, and spam. Virtual Service Network Security Policy can match on IP Reputation to identify or categorize IP addresses based on associated threats. The User Agent Database Sync capability can be enabled to receive User-Agent updates for threat detection, allowing detection logic to adapt as new bot user-agent patterns are identified. The Service Engine Bot Management feature relies on IP Reputation and L7 GeoDB lookup for threat detection and mitigation.

For Kubernetes-native environments, the Avi Kubernetes Operator (AKO) L7Rule custom resource definition supports a botPolicyRef field to reference a bot policy for bot detection and mitigation, extending Bot Management capabilities to Kubernetes ingress traffic.

Avi Analytics detects anomalies defined as traffic outside the statistical norm for a given time period and assigns an anomaly penalty to flag potential risk. This visibility into abnormal traffic patterns can support early identification of novel AI-driven threats in progress.

## Control MANAGE 2.4

> Mechanisms are in place and applied, and responsibilities are assigned and understood, to supersede, disengage, or deactivate AI systems that demonstrate performance or outcomes inconsistent with intended use.

**SCF Controls:** AAT-15.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MANAGE 3.1

> AI risks and benefits from third-party resources are regularly monitored, and risk controls are applied and documented.

**SCF Controls:** AAT-02, AAT-04.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides a centralized inventory of AI models through the Model Gallery in Harbor Registry. Each model gallery has a unique name and is organized within Harbor projects with configured user access controls. Model revisions are stored as OCI artifacts with immutable manifests, and each revision is assigned a unique digest, giving a verifiable record of every model version in the inventory.

OCI metadata describes model contents and dependencies, supporting identification of compatible platforms and giving visibility into what each model requires. The `vcf pais models list` command retrieves and displays all models available in a model gallery, giving operators a direct inventory view. Model Runtime tracks which models are actively deployed to inference endpoints, distinguishing between stored and deployed models.

For third-party AI components, PAIS validates running AI workloads based on NVIDIA GPU Cloud (NGC) containers, a curated catalog of GPU-optimized, pre-tested containers. In disconnected environments, a Harbor registry stores container images from the NGC catalog, acting as a controlled intermediary that makes third-party AI components visible and trackable within the organization's infrastructure.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MANAGE 3.2

> Pre-trained models which are used for development are monitored as part of AI system regular monitoring and maintenance.

**SCF Controls:** AAT-10.13

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to post-deployment monitoring of AI workloads through VCF Operations, which provides continuous health, performance, and capacity monitoring for the infrastructure hosting those workloads. VCF Operations dashboards surface CPU, memory, storage, and network metrics for VMs running AI workloads. VCF Log Management aggregates and analyzes log data from VMware vCenter, VMware ESX, and NSX components. vCenter alarms provide threshold-based alerting for infrastructure conditions that could affect AI workload availability.

For AI workloads running as containerized applications on VMware Kubernetes Service (VKS) clusters, the platform extends infrastructure-level observability to the Kubernetes layer. VKS clusters provisioned with the automated-monitoring label automatically receive monitoring configuration on each new node, integrating cluster telemetry with VCF Operations. The Prometheus standard package, installable on VKS clusters through the Supervisor Management Proxy Service, deploys kube-state-metrics, node-exporter, pushgateway, Prometheus, and Alertmanager as components. The prometheus-kube-state-metrics component monitors node status and capacity, ReplicaSet compliance, pod status, job and CronJob status, and resource requests and limits, providing continuous metric collection that can be directed at AI inference services or training job pods. Telegraf is available as a standard package that deploys as a Deployment component to scrape metrics from kube-state-metrics and node-exporter and forward them to external observability backends. Monitoring and alerting for Kubernetes deployments is also available through the Argo CD Supervisor Service using Grafana Operator and Prometheus.

Kubernetes-native health probes and status tracking support workload condition detection at the pod level. Liveness and readiness probes can be configured on AI workload containers to detect unresponsive or overloaded model serving instances; a readiness probe removes the pod from service routing when it cannot handle requests, and a liveness probe triggers a container restart when the application becomes unresponsive. The Kubernetes Deployment controller continuously monitors running application instances and automatically replaces instances when nodes fail or are removed from service, providing a self-healing mechanism that addresses machine failure or maintenance. Kubernetes DeploymentStatus exposes observedGeneration and conditions fields with type, status, lastTransitionTime, and reason values, allowing operators to detect rollout failures, stuck deployments, or configuration drift from the expected specification. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly, and generates Policy Insights when configuration conflicts or environmental errors are detected.

For organizations using Harness CI/CD on VKS, Dynatrace integration provides full-stack observability including application performance monitoring, infrastructure monitoring, and digital experience monitoring. The Dynatrace operator automates deployment, scaling, and maintenance of the monitoring stack within VKS clusters, and automatically correlates application deployment service metrics with underlying VKS infrastructure including nodes, pods, and the network. The Dynatrace AI engine detects anomalies, identifies root causes, and provides intelligent alerts. Harness SRM monitors deployed services post-deployment to calculate a real-time health score based on transaction success and latency.

The VCF Automation Monitor tab provides deployment health information drawn from VCF Operations, and deployment cards in the self-service catalog surface deployment state, last request status, and operational history for workload deployments. AI-specific behavior monitoring (model accuracy drift, output quality) requires application-level tooling outside VCF's scope.

VMware Private AI Services (PAIS) provides AI-specific monitoring mechanisms that support continuous post-deployment observation of AI workloads on VCF.

At the PAIS layer, observability is activated by updating the PAISConfiguration custom resource with parameters that enable metrics collection and forward large language model traces to an OpenTelemetry Collector. PAIS deploys a Prometheus server pod for metrics collection that must be ready and running for observability to function, configured with a chosen



storage class and a configurable metrics retention period. PAIS controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance, and the telegraf-user-config ConfigMap in the vmware-system-monitoring namespace manages user-configured monitoring endpoints for PAIS. The PAIS Supervisor Service exposes service-level metrics through `pais.vmware.com` that VI administrators access to monitor the health of the service.

DevOps engineers visualize PAIS health and performance metrics in observability platforms such as Grafana, where dashboards report pod restart frequency, vGPU licensing status, and idle or underutilized GPU devices in passthrough mode. VI administrators visualize PAIS controller pod operation metrics in VCF Operations using the same metrics pipeline. MLOps engineers and application developers track the health, quality, and behavior of AI applications and the models used in agents through Grafana, supporting continuous observation of inference behavior. Model Endpoint deployment status can be verified using the `kubectl get modelendpoints` command, which returns the Ready status for each deployed endpoint, and the `vcf` cluster command-line interface provides cluster provisioning monitoring, registration, and kubeconfig retrieval for VKS clusters that host AI workloads. PAIS deployment leases can be configured to bound how long a deployment can exist, supporting lifecycle oversight of catalog-deployed AI workloads.

Enabling these observability features, defining retention and alerting policy, and acting on monitoring signals are organizational process responsibilities. PAIS provides the monitoring infrastructure and integration points, but continuous post-deployment monitoring as a practice requires the organization to assign operational ownership, review observability data on an ongoing basis, and respond to anomalies in AI workload behavior.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to proactive and continuous monitoring of deployed AI workloads running on VCF through multiple layers of ongoing network-level security monitoring.

Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workloads evolve. It also monitors infrastructure services to detect newly deployed servers. A classification cron job runs automatically at 2:00 AM local time and repeats every 24 hours, evaluating traffic flows from the preceding 30 days to classify compute entities providing network infrastructure services. When the Recommendations Monitoring feature is enabled, Security Intelligence checks every hour for changes in the scope of monitored entities, allowing policy recommendations to remain current as AI workloads change. The Security Intelligence Flow Insights Dashboard supports detection and display of MITRE ATT&CK framework tactics and techniques, showing counts of detected suspicious events per tactic and technique during a selected time period.

Segmentation Monitoring provides dedicated views for environment-level traffic flows, accessible through the Monitor & Plan interface. Administrators can monitor traffic between configured environment pairs, view flows related to detected infrastructure servers within specified time intervals, and export all unique flows to a CSV file for offline analysis or compliance evidence. The Environments monitoring window provides assessment of current security posture and enables improvement actions for environment pairs. When no protection policy is configured for an environment pair, Segmentation Monitoring offers a Run Recommendations option to generate policy recommendations, closing monitoring gaps around AI workloads.

The Security Services Platform (SSP) collects metrics to monitor the readiness and performance of vDefend IDS/IPS in the environment. IDS/IPS engine statistics accessible per host include uptime, alert count, suppressed alerts, alert queue overflow status, engine ID, and last reload timestamp. IDS/IPS monitoring dashboards can be scoped to custom projects, displaying events triggered for that project only. For bare metal deployments, Bare Metal Agents stream metrics and detailed host-level telemetry to the SSP. The NDR Sensor periodically checks the status of activated features on the SSP every 15 minutes and updates its configuration accordingly.

Intelligent Assist provides AI-assisted analysis within the NSX Manager UI and SSP UI, displaying on the IDS/IPS, Detections, and Campaigns pages to help administrators interpret monitoring data.

Malware Prevention Service provides deployment status monitoring at the cluster level and per-node level, displaying deployment errors and individual transport node status. Network Detection and Response (NDR) applies behavioral analysis to detect suspicious activity targeting monitored workloads and correlates events into campaigns for investigation.



Monitoring AI system functionality at the application layer, including model performance, output quality, and behavioral drift, is outside vDefend's domain.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MANAGE 4.1

> Post-deployment AI system monitoring plans are implemented, including mechanisms for capturing and evaluating input from users and other relevant AI actors, appeal and override, decommissioning, incident response, recovery, and change management.

**SCF Controls:** AAT-10.1, AAT-16.5, AAT-16.8

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure for evaluating AI systems for trustworthy behavior, specifically addressing the security dimension of trustworthiness assessment. The validate-then-publish workflow requires MLOps engineers to validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the Model Gallery. This validation includes evaluating models for inference functionality using the Triton Inference Server and examining inference requests for malicious behavior, directly addressing the security evaluation component of trustworthiness.

Deep learning VMs provisioned from PAIS images are isolated evaluation environments where data scientists and MLOps engineers can assess model behavior before production deployment. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so trustworthiness evaluation occurs under conditions comparable to the deployment environment. Model integrity is verified through hash code validation and unique content digests on each revision, stored as OCI artifacts with immutable manifests, providing cryptographic verification that the evaluated model is the same artifact that reaches production.

PAIS does not address the anonymization or disaggregation aspects of this control. Data anonymization, de-identification, and disaggregation of captured and stored data are application-layer data governance activities that fall outside the scope of infrastructure-level platform controls.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MANAGE 4.2

> Measurable activities for continual improvements are integrated into AI system updates and include regular engagement with interested parties, including relevant AI actors.

**SCF Controls:** AAT-07.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

Continuous improvement of Artificial Intelligence and Autonomous Technologies capabilities is an organizational activity carried out by the teams that build, evaluate, and operate AI workloads. VMware Private AI Services (PAIS) is the AI infrastructure layer of VCF and supplies the platform on which those workloads run; it does not perform the improvement cycle itself. The decision to retrain a model, change a data source, adjust a prompt, or retire a capability is made by the data science, MLOps, and product teams that own the workload, governed by their own internal processes.

PAIS supplies platform mechanisms that workload teams can incorporate into their own improvement cycles. A central model gallery is recommended for managing ML models with consistency across deployment targets. Knowledge bases can be created with linked data sources including Microsoft SharePoint sites and Amazon S3 compatible stores, allowing teams to update the context available to model responses without rebuilding the underlying model. Private AI Services Agent Builder maintains a list of approved tools for use in AI agents when connecting to Model Context Protocol (MCP) servers, giving workload owners a mechanism to add or restrict capabilities over time. PAIS can be installed or updated to later versions independently of the core Supervisor Service, allowing platform-level improvements to ship without a full core update. Controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance, so operations teams can feed platform telemetry into their evaluation loops. These are tools that workload teams use; PAIS does not own the improvement decision.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MANAGE 4.3

> Incidents and errors are communicated to relevant AI actors, including affected communities. Processes for tracking, responding to, and recovering from incidents and errors are followed and documented.

**SCF Controls:** AAT-11.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 1.1

> Intended purposes, potentially beneficial uses, contextspecific laws, norms and expectations, and prospective settings in which the AI system will be deployed are understood and documented. Considerations include: the specific set or types of users along with their expectations; potential positive and negative impacts of system uses to individuals, communities, organizations, society, and the planet; assumptions and related limitations about AI system purposes, uses, and risks across the development or product AI lifecycle; and related TEVV and system metrics.

**SCF Controls:** AAT-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 1.2

> Interdisciplinary AI actors, competencies, skills, and capacities for establishing context reflect demographic diversity and broad domain and user experience expertise, and their participation is documented. Opportunities for interdisciplinary collaboration are prioritized.

**SCF Controls:** AAT-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 2.1

> The specific tasks and methods used to implement the tasks that the AI system will support are defined (e.g., classifiers, generative models, recommenders).

**SCF Controls:** AAT-14.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) defines the AI task types the platform supports through a set of catalog items, model and knowledge-base constructs, and namespace activation steps that translate organizational AI scoping decisions into platform configuration. The PAIS catalog in VCF Automation, populated through the Private AI Services Quickstart, exposes a defined set of AI workload patterns to users: AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster. An organization administrator or MLOps engineer must activate PAIS in a namespace before any of these AI workloads can be requested, and catalog item permissions control which task types are visible to which users. AI workloads can run on GPU devices in vGPU or passthrough mode or in CPU-only configurations, allowing the task definitions to match the underlying hardware policy.

For generative AI tasks, PAIS provides Model Endpoints for completion and embedding models, Agent Builder for assembling agents on top of those endpoints, and Knowledge Bases that link to external data sources such as Microsoft SharePoint sites and Amazon S3 compatible stores so that retrieval-augmented generation patterns are scoped to approved corpora. Agent Builder also maintains a list of approved tools when connecting to MCP servers, giving organizations a mechanism to constrain the specialized capabilities an AI agent can invoke. Deployment connectivity mode is itself a defined attribute: PAIS can be installed in connected or disconnected air-gapped environments, with a Harbor registry, or another OCI-compliant registry, holding the model gallery in both modes.

Because PPTDF for this control is Process only, the organization remains responsible for identifying the AI use cases the environment will support, approving task categories, and documenting the operational scope. PAIS supplies the platform mechanisms that enforce those decisions but does not perform the scoping itself.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 2.2

> Information about the AI system's knowledge limits and how system output may be utilized and overseen by humans is documented. Documentation provides sufficient information to assist relevant AI actors when making decisions and taking subsequent actions.

**SCF Controls:** AAT-14.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MAP 2.3

> Scientific integrity and TEVV considerations are identified and documented, including those related to experimental design, data collection and selection (e.g., availability, representativeness, suitability), system trustworthiness, and construct validation.

**SCF Controls:** AAT-10, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

### VMware vDefend (Contributes)

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore

mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 3.4

> Processes for operator and practitioner proficiency with AI system performance and trustworthiness – and relevant technical standards and certifications – are defined, assessed, and documented.

**SCF Controls:** AAT-10.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure for evaluating AI systems for trustworthy behavior, specifically addressing the security dimension of trustworthiness assessment. The validate-then-publish workflow requires MLOps engineers to validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the Model Gallery. This validation includes evaluating models for inference functionality using the Triton Inference Server and examining inference requests for malicious behavior, directly addressing the security evaluation component of trustworthiness.

Deep learning VMs provisioned from PAIS images are isolated evaluation environments where data scientists and MLOps engineers can assess model behavior before production deployment. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so trustworthiness evaluation occurs under conditions comparable to the deployment environment. Model integrity is verified through hash code validation and unique content digests on each revision, stored as OCI artifacts with immutable manifests, providing cryptographic verification that the evaluated model is the same artifact that reaches production.

PAIS does not address the anonymization or disaggregation aspects of this control. Data anonymization, de-identification, and disaggregation of captured and stored data are application-layer data governance activities that fall outside the scope of infrastructure-level platform controls.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 4.1

> Approaches for mapping AI technology and legal risks of its components – including the use of third-party data or software – are in place, followed, and documented, as are risks of infringement of a third party's intellectual property or other rights.

**SCF Controls:** AAT-01, AAT-02.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 5.1

> Likelihood and magnitude of each identified impact (both potentially beneficial and harmful) based on expected use, past uses of AI systems in similar contexts, public incident reports, feedback from those external to the team that developed or deployed the AI system, or other data are identified and documented.

**SCF Controls:** AAT-07.1, AAT-07.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MAP 5.2

> Practices and personnel for supporting regular engagement with relevant AI actors and integrating feedback about positive, negative, and unanticipated impacts are in place and documented.

**SCF Controls:** AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 1.1

> Approaches and metrics for measurement of AI risks enumerated during the MAP function are selected for implementation starting with the most significant AI risks. The risks or trustworthiness characteristics that will not – or cannot – be measured are properly documented.

**SCF Controls:** AAT-07, AAT-16.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MEASURE 1.3

> Internal experts who did not serve as front-line developers for the system and/or independent assessors are involved in regular assessments and updates. Domain experts, users, AI actors external to the team that developed or deployed the AI system, and affected communities are consulted in support of assessments as necessary per organizational risk tolerance.

**SCF Controls:** AAT-11.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MEASURE 2.2

> Evaluations involving human subjects meet applicable requirements (including human subject protection) and are representative of the relevant population.

**SCF Controls:** AAT-17.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.3

> AI system performance or assurance criteria are measured qualitatively or quantitatively and demonstrated for conditions similar to deployment setting(s). Measures are documented.

**SCF Controls:** AAT-20.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to AI implementation documentation by providing documented compute and hardware resource requirements, event log collection mechanisms, and infrastructure configuration references that support the documentation of AI deployment environments. VCF's compatibility guides document supported hardware, VCF Operations tracks infrastructure configuration, and VCF Log Management documents the event collection architecture.

Documenting AI model architecture, training methodology, and decision logic is outside VCF's scope.

VMware Private AI Services (PAIS), formerly Private AI Services, provides documentation and platform features that address several of the listed implementation documentation requirements. For computational and hardware resource requirements (item 6), the platform documents the system architecture of PAIS deployments, including GPU-accelerated workload domain requirements, vGPU profile configurations, VM class definitions for AI workloads, and the NVIDIA GPU and driver compatibility requirements. VI administrators configure vGPU-based VM classes that define the GPU resource allocations available to AI workloads. The PAIS catalog items in VCF Automation, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, document the components users can provision in selected namespaces, and the deployment Overview tab summarizes the installed software and the access points for the application, services, and workstation VM. PAIS setup is documented for both connected and disconnected (air-gapped) deployment models, with a Harbor registry in the Supervisor or another OCI-compliant registry used to store validated ML models.

For event logging mechanisms (item 8), the platform documents multiple logging and telemetry capabilities. Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and GPU driver installation logs in `/var/log/gpu-install.log`, and they provide JupyterLab instances and console logs for verifying component installation and operation. The vLLM inference server logging level is configurable through the `VLLM_LOGGING_LEVEL` environment variable. PAIS Controller pod metrics are exposed at a Prometheus endpoint on the `pais-controller-manager` service and are integrated into observability platforms through Telegraf configuration in the Supervisor instance, with VCF Operations as the documented consuming platform. Deep Learning VMs also expose vGPU performance metrics through Prometheus. PAIS supports LLM traces collection in an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource. Knowledge Base operations track crawled documents, new documents found, deleted documents, modified documents requiring embeddings updates, and skipped documents, and record timing metrics for download, embedding generation, and the overall index operation.

For human oversight measures (item 5) and for interpreting outputs (items 4 and 5), MLOps engineers analyze LLM traces and Prometheus metrics to inspect agent execution flow across components and knowledge base indexing. The PAIS Agent Builder maintains a list of approved tools for use in AI agents and requires examination and approval of MCP server tools and capabilities before they are used by agents. Knowledge Bases are created with linked data sources such as Microsoft SharePoint sites and Amazon S3-compatible stores, which gives implementers a documented data lineage for retrieval-augmented generation outputs. Access to PAIS is controlled through OIDC authorized groups, where user accounts must be members of specified groups to consume the service, and personal access tokens generated from user account settings provide programmatic access to Knowledge Bases and data sources.

Requirements 1 (provider contact details), 2 (characteristics, capabilities, and limitations of the AI system), 3 (errata from initial conformity assessment), and 7 (projected useable lifetime) are documentation obligations carried by model vendors and the deploying organization rather than by the infrastructure platform. PAIS supplies registry and catalog mechanisms that organizations can attach revision and provenance metadata to, but the substantive documentation content for those items is outside the platform's scope.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.5

> The AI system to be deployed is demonstrated to be valid and reliable. Limitations of the generalizability beyond the conditions under which the technology was developed are documented.

**SCF Controls:** AAT-10.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) supports demonstrating model validity, reliability, and intended operation through its validate-then-publish workflow on the Model Gallery. MLOps engineers validate ML models against the security, privacy, and technical requirements of the organization before onboarding them to the gallery, which provides the verification step the control calls for. Before validation can take place, Deep Learning VMs require issuer certificates to be installed to the trust store via the `update-ca-certificates` command, establishing the trusted channel between the validation workstation and the model storage backend.

The Model Gallery is implemented on a private Harbor registry that PAIS integrates with as the model storage backend, requiring authentication and certificate-based trust for model retrieval. A Harbor administrator must create a dedicated PAIS project in the private Harbor registry as part of the deployment workflow, and OCI-compliant registries from other vendors are supported for organizations that already operate a model store. Project-level access controls in Harbor restrict who can upload, retrieve, and publish models, which keeps the gate between validation and production aligned with approved designs.

To support ongoing demonstration that deployed models continue to operate as intended, PAIS metrics are integrated with observability platforms such as Grafana and VCF Operations. Observability is configured during PAIS activation in VCF Automation and must be verified as active in the PAIS instance namespace, and PAIS controller pod metrics are forwarded through Telegraf configuration in the Supervisor instance. The `vcf pais` CLI plug-in distributes the artifact mirroring tool used to move validated content into disconnected environments, helping keep production deployments aligned with the content that was validated upstream.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.6

> The AI system is evaluated regularly for safety risks – as identified in the MAP function. The AI system to be deployed is demonstrated to be safe, its residual negative risk does not exceed the risk tolerance, and it can fail safely, particularly if made to operate beyond its knowledge limits. Safety metrics reflect system reliability and robustness, real-time monitoring, and response times for AI system failures.

**SCF Controls:** AAT-16

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to monitoring deployed AI workloads through VCF Operations, which provides continuous visibility into the health, performance, and capacity of the infrastructure those workloads run on. VCF Operations dashboards display real-time and historical metrics for compute, storage, and networking resources consumed by AI VMs. VCF Log Management aggregates log data across the stack. VMware vCenter alarms trigger on configurable thresholds for CPU, memory, disk, and network conditions.

For AI and autonomous technology workloads deployed as containerized applications on VMware Kubernetes Service (VKS) clusters, the platform provides a layered observability stack. The Prometheus Standard Package, available for deployment on VKS clusters, collects metrics from configured targets at defined intervals, evaluates alerting rules, and forwards alerts to Alertmanager. The package includes prometheus-server, which handles scraping, rule processing, and alerting, as well as prometheus-kube-state-metrics for tracking node status, replica-set compliance, pod and job status, and resource requests and limits across namespaces. For batch inference or training jobs that cannot be scraped directly, Prometheus Pushgateway accepts pushed metrics. Grafana Operator pairs with Prometheus to provide dashboards and configurable alert thresholds, enabling operators to define visual representations of AI workload metrics and receive notifications when behavior deviates from expected patterns.

Monitoring agents for Kubernetes device plugin resources, including GPUs commonly consumed by AI inference and training workloads, can be deployed as DaemonSets on worker nodes to track resource utilization and associate metrics with specific containers. The Kubernetes Node Problem Detector can be extended with custom monitoring scripts written in any language, which allows AI-specific health checks to be added without modifying core Kubernetes components. Kubernetes also provides built-in auditing capabilities for monitoring and recording cluster activities.

Istio, available as a Standard Package for VKS clusters, provides mechanisms to secure, connect, and monitor services. For AI inference services that expose APIs, Istio supplies request rate, latency, and error rate metrics without requiring application-level instrumentation.

Deployments using the Harness CI/CD Supervisor Service can integrate Dynatrace, which automatically instruments applications and infrastructure upon deployment and collects metrics, logs, and traces. The Dynatrace AI engine detects anomalies, identifies root causes, and generates intelligent alerts. The Dynatrace operator automates the deployment, scaling, and maintenance of the monitoring stack within the VKS cluster. Harness Service Reliability Management monitors deployed services post-deployment to calculate a real-time health score based on transaction success and latency.

VKS cluster management proactively monitors the VKS cluster estate to confirm assigned policies are enforced correctly, and generates Policy Insights when configuration conflicts or environmental errors are detected.

Monitoring AI model behavior at the application level, including model drift, inference accuracy, and data distribution shifts, requires organization-defined monitoring logic implemented using these platform tools. VCF and its Kubernetes consumption layer provide the collection, storage, and alerting infrastructure, but the organization must configure the signals to collect, define thresholds for AI-specific behavioral anomalies, and establish processes for reviewing and responding to monitoring data.

VMware Private AI Services (PAIS) provides production monitoring for deployed AI workloads through metrics collection, telemetry, and integration with observability platforms. The Private AI Services controller exposes a Prometheus metrics

endpoint on the pais-controller-manager service, and Private AI Services deployments include a Prometheus server pod that collects metrics for observability platforms. DevOps engineers visualize health and performance metrics for Private AI Services components running in a VCF Automation namespace using observability platforms such as Grafana.

Observability is activated by updating the PAISConfiguration custom resource with parameters that enable metrics collection for observability platforms and LLM traces for the OpenTelemetry (OTel) Collector. When LLM traces collection is activated, MLOps engineers can analyze traces from agents and knowledge base indexing in the OpenTelemetry Collector, supporting observation of model behavior and application health in agentic workflows. Private AI Services supports sending traces to an OpenTelemetry collector over HTTP/protobuf or gRPC.

Operators can monitor Private AI Services deployments in Grafana for pod restart frequency, vGPU licensing status, and idle or underutilized GPU devices in passthrough mode. Private AI Services controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance, which allows VCF Operations to ingest PAIS controller metrics alongside the broader infrastructure telemetry it already collects for GPU-enabled workload domains. Deployment health is verified through Kubernetes pod state of the API, ingress, rex worker, and Prometheus server pods.

MLOps engineers and application developers can perform monitoring and diagnostics of models used in agents through observability platforms like Grafana to track the health, quality, and behavior of AI applications.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to monitoring the functionality and behavior of deployed AI workloads running on VCF by providing continuous network-level behavioral monitoring, threat detection, and AI-assisted security analysis around those workloads.

Security Intelligence, running on the Security Services Platform, provides continuous network-level behavioral monitoring that detects new traffic flows, unauthorized communications, and anomalous activity around deployed systems, including AI workloads. It continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, supporting ongoing policy adjustments. The Segmentation Monitoring Dashboard provides dedicated views for monitoring environment-level traffic flows; when monitoring identifies an environment pair without a configured protection policy, it offers a Run Recommendations option to generate policy recommendations based on observed traffic. Security Intelligence provides Infrastructure, Environment, and Application Monitoring capabilities. The application monitoring view within the Segmentation Monitoring Dashboard surfaces metrics including unprotected flows and applications with unprotected rule hits, providing targeted visibility into workloads, including AI systems, that lack active firewall policy coverage. The Policy Recommendations monitoring capability checks for changes in monitored entity scope every hour when enabled. Security Intelligence also runs a scheduled daily classification job, automatically categorizing compute entities based on traffic flows observed over the prior 30 days.

Intelligent Assist is an AI-assisted analysis feature accessible through the NSX Manager UI and Security Services Platform UI. It provides contextual analysis support on the IDS/IPS, Detections, and Campaigns pages, enabling administrators to investigate security events affecting deployed workloads with AI-driven guidance.

IDS/IPS provides ongoing threat detection through monitoring dashboards scoped to both distributed and gateway deployments. Project-scoped dashboards display events triggered for specific projects, allowing targeted monitoring of AI workload deployments. Network Detection and Response (NDR) applies behavioral analysis to identify suspicious activity targeting monitored workloads. The NDR Sensor periodically checks the status of activated features on the Security Services Platform every 15 minutes and updates its configuration accordingly.

Monitoring AI system functionality at the application layer, including model performance, output quality, and behavioral drift, is outside vDefend's domain and requires additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.7

> AI system security and resilience – as identified in the MAP function – are evaluated and documented.

**SCF Controls:** AAT-10.5

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to evaluating the security and resilience of AI workloads through VCF Operations compliance dashboards that assess infrastructure security posture, configuration drift detection, and health monitoring across the compute, storage, and networking layers that AI workloads depend on. VCF Log Management aggregates event data that supports security assessment. The Security Configuration Guide and DISA STIG provide hardening baselines that can be validated against the infrastructure hosting AI workloads.

The Consumption layer of the VCF platform, delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor, provides pre-deployment evaluation mechanisms for AI and machine learning workloads. DISA STIGs are available for both the Supervisor control plane and VKS cluster VKr images, supplying a structured body of security requirements against which AI workload infrastructure can be evaluated before production deployment. AI and machine learning workloads on Supervisor run on Ubuntu-based Kubernetes release images (VKrs), which are the designated runtime for such workloads in VKS clusters. Cluster readiness assessment is built into the VKS Controller, which reports status conditions covering cluster phase and component health; administrators can query these conditions using kubectl to verify that the infrastructure meets defined readiness criteria before AI workloads are scheduled.

Pod Security Admission is enforced on VKS clusters and provides a pre-execution gate for workload pods. Starting with VKr v1.25, the `kubernetes.security.podSecurityStandard` configuration variable selects Baseline, Restricted, or Privileged profiles to constrain what workload pods can execute. VKS Cluster Management adds a fleet-wide policy governance layer powered by OPA Gatekeeper, with out-of-box security policy templates that mirror industry-standard Pod Security Standards profiles; policies applied at the organization or project level are automatically inherited by all child resources, providing scalable governance across the VKS cluster estate. The VKS Cluster Management Policy Insights capability surfaces health alerts for infrastructure-level failures that would prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, giving administrators visibility into the operational state of the security control.

The Kubernetes security documentation available through Supervisor includes guidance for pre-deployment security evaluation: threat modeling to identify trust boundaries and risks, cloud-native security lifecycle checklists organized around the develop phase, and recommendations for advanced security assessment techniques such as fuzzing and security chaos engineering where appropriate. The Kubernetes Security Response Committee publishes CVE feeds and tracks vulnerabilities in the Kubernetes platform, acknowledging reports within three working days, which gives teams visibility into known security issues in the AI and machine learning runtime infrastructure. For high-trust environments where AI workloads handle sensitive data, Supervisor supports deploying workloads on confidential virtual machines, adding hardware-level memory isolation as an additional element of the security profile that can be evaluated during a pre-deployment review.

The broader AI TEVV program, including evaluation criteria, result interpretation, and model-level testing for safety, fairness, and adversarial robustness, is an organizational responsibility. VCF provides the observable, policy-governed runtime environment that supports those activities but does not perform AI-specific evaluation itself.

VMware Private AI Services (PAIS) supports pre-deployment security and resilience evaluation of AI workloads through PAIS-native mechanisms in the model lifecycle workflow. MLOps engineers validate ML models against the organization's security, privacy, and technical requirements before onboarding them to the PAIS model gallery, with deep learning VMs and the PAIS model runtime available as the validation environment for functional and behavioral testing.

PAIS observability integrates with platforms such as Grafana and VCF Operations so that MLOps engineers, application developers, and VI administrators have ongoing visibility into model and component health, quality, and behavior in deployed AI applications. Metrics collection is activated through the PAISConfiguration custom resource, with a Prometheus runtime, a configurable storage class, a configurable retention period, and optional LLM traces forwarded through the OpenTelemetry

(OTel) Collector. This telemetry provides the data inputs for continued security and resilience review of models in production, including tracking of anomalous model behavior over time.

PAIS deployment leases bound how long an AI workload deployment can exist, providing a control for time-limited evaluation environments where candidate models can be exercised before broader rollout. PAIS supports both connected and disconnected (air-gapped) deployment models, allowing organizations to perform security evaluation of AI workloads in isolated environments. A Harbor or other OCI-compliant registry is used as the artifact source for models and container images, giving organizations a controlled location from which validated artifacts are retrieved.

Resilience evaluation for AI workloads depends on the underlying VCF platform, which provides vSphere High Availability for automatic VM restart on host failure, Distributed Resource Scheduler for workload balancing, and vMotion for live migration of GPU-accelerated VMs. These capabilities are VCF platform mechanisms; see VCF Coverage for the underlying resilience infrastructure.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to evaluating the security and resilience of AI and autonomous technology workloads by providing continuous network-level security assessment capabilities that operate during and after deployment.

The vDefend distributed firewall includes a dedicated Security Assessment workflow that generates Security Segmentation Reports and Blast Radius Reports. These reports identify at-risk workloads, communication chains, and traffic flows, providing structured input for evaluating whether network isolation is correctly applied to AI workload segments and identifying gaps in protection coverage.

Security Intelligence offers traffic flow analysis, a quantitative Security Segmentation Score, and environment-level monitoring that can inform resilience assessments. The Security Segmentation Score calculates posture by evaluating Distributed Firewall configuration and traffic rules; score values from 0 to 50 indicate low security, 50 to 80 indicate medium security, and values above 80 indicate a highly secure environment. The score breakdown report details total environments and environment pairs, protection rule actions, and highlights environment pairs lacking inter-environment policies. Security Intelligence generates policy recommendations by analyzing VM traffic flows over specified time periods and boundary definitions, and monitors inter-environment traffic to detect leakage and support lockdown rule implementation. The Security Intelligence dashboard displays environments, environment pairs, and segmentation state to help administrators understand current security posture.

The Security Services Platform collects and surfaces IDS/IPS readiness and performance metrics. Administrators can view intrusion details including severity, CVE identifiers, CVSS scores, and affected VMs through vDefend IDS/IPS to inform mitigation planning. Intelligent Assist assists with IDS policies, rules, and security profiles during remediation operations. The vDefend Threat Intelligence Service Portal supplies application-level threat intelligence that can inform distributed and gateway firewall policies targeting lateral and perimeter network threats.

The broader TEVV program for AI security and resilience, including defining evaluation criteria, establishing test plans, and interpreting results against organizational risk thresholds, is an organizational responsibility outside vDefend's scope.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MEASURE 2.8

> Risks associated with transparency and accountability – as identified in the MAP function – are examined and documented.

**SCF Controls:** AAT-10.6

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.9

> The AI model is explained, validated, and documented, and AI system output is interpreted within its context – as identified in the MAP function – to inform responsible use and governance.

**SCF Controls:** AAT-10, AAT-20.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.10

> Privacy risk of the AI system – as identified in the MAP function – is examined and documented.

**SCF Controls:** AAT-10.7

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.11

> Fairness and bias – as identified in the MAP function – are evaluated and results are documented.

**SCF Controls:** AAT-10.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.12

> Environmental impact and sustainability of AI model training and management activities – as identified in the MAP function – are assessed and documented.

**SCF Controls:** AAT-17.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides PAIS-native mechanisms that help organizations assess the environmental footprint of AI workloads. Metrics collection for PAIS is activated by uncommenting the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource, after which DevOps and MLOps engineers can visualize PAIS health and performance metrics for components running in a VCF Automation namespace through observability platforms such as Grafana. The same observability pipeline lets MLOps engineers and application developers monitor models used in agents, giving operators visibility into the operational characteristics of individual AI workloads across deep learning VMs, VKS clusters, and RAG applications. This telemetry is the raw operational data that organizations use to quantify the energy and resource footprint of AI activity.

PAIS also supports resource efficiency through deployment leases. A lease controls how long a PAIS deployment can exist, so that AI workloads provisioned from VCF Automation catalog items are reclaimed at the end of a defined period rather than continuing to consume GPU and compute resources indefinitely. Disconnected (air-gapped) and connected deployment modes both rely on the same observability and lease controls, so the same sustainability-relevant data and lifecycle controls apply regardless of connectivity model.

Broader sustainability and green-metric monitoring at the cluster and host level is a VCF platform capability and is covered under VCF Coverage. The organizational activity of setting sustainability targets, analyzing collected metrics, and documenting environmental impact is a process obligation outside PAIS itself, which is why the rating is Contributes rather than Meets.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 2.13

> Effectiveness of the employed TEVV metrics and processes in the MEASURE function are evaluated and documented.

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MEASURE 3.2

> Risk tracking approaches are considered for settings where AI risks are difficult to assess using currently available measurement techniques or where metrics are not yet available.

**SCF Controls:** AAT-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MEASURE 3.3

> Feedback processes for end users and impacted communities to report problems and appeal system outcomes are established and integrated into AI system evaluation metrics.

**SCF Controls:** AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MEASURE 4.2

> Measurement results regarding AI system trustworthiness in deployment context(s) and across the AI lifecycle are informed by input from domain experts and relevant AI actors to validate whether the system is performing consistently as intended. Results are documented.

**SCF Controls:** AAT-10.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure for evaluating AI systems for trustworthy behavior, specifically addressing the security dimension of trustworthiness assessment. The validate-then-publish workflow requires MLOps engineers to validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the Model Gallery. This validation includes evaluating models for inference functionality using the Triton Inference Server and examining inference requests for malicious behavior, directly addressing the security evaluation component of trustworthiness.

Deep learning VMs provisioned from PAIS images are isolated evaluation environments where data scientists and MLOps engineers can assess model behavior before production deployment. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so trustworthiness evaluation occurs under conditions comparable to the deployment environment. Model integrity is verified through hash code validation and unique content digests on each revision, stored as OCI artifacts with immutable manifests, providing cryptographic verification that the evaluated model is the same artifact that reaches production.

PAIS does not address the anonymization or disaggregation aspects of this control. Data anonymization, de-identification, and disaggregation of captured and stored data are application-layer data governance activities that fall outside the scope of infrastructure-level platform controls.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-1.3-001

> Document trade-offs, decision processes, and relevant measurement and feedback results for risks that do not surpass organizational risk tolerance, for example, in the context of model release: Consider different approaches for model release, for example, leveraging a staged release approach. Consider release approaches in the context of the model and its projected use cases. Mitigate, transfer, or avoid risks that surpass organizational risk tolerances.

**SCF Controls:** AAT-10.4, AAT-15.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-1.3-002

> Monitor the robustness and effectiveness of risk controls and mitigation plans (e.g., via red-teaming, field testing, participatory engagements, performance assessments, user feedback mechanisms).

**SCF Controls:** AAT-16.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to measuring the effectiveness of security controls for AI workloads through VCF Operations compliance dashboards that report on configuration conformance, hardening posture, and drift from baselines across the infrastructure hosting those workloads. VCF Operations generates health scores and compliance reports that can be reviewed to assess whether infrastructure-level controls are functioning. VCF Operations also monitors Kubernetes cluster health metrics, including node status and kubelet status, when the Supervisor is integrated as a data source, extending this infrastructure-level visibility to containerized workload environments.

At the Consumption layer, VMware Kubernetes Service (VKS) and the vSphere Supervisor provide technical mechanisms that support ongoing assessment of control effectiveness across containerized workloads. Pod Security Admission (PSA) supports three enforcement modes, enforce, warn, and audit, applied per namespace. When a namespace is configured with the `pod-security.kubernetes.io/audit` or `pod-security.kubernetes.io/warn` labels, violations are recorded in the Kubernetes audit log or surfaced as warnings without blocking workload deployment. This allows organizations to evaluate the compliance impact of a security policy before moving to full enforcement, and the `pod_security_evaluations_total` metric tracks the number of policy evaluations occurring across namespaces, giving administrators a quantitative view of PSA activity.

Kubernetes audit logging records all API server activity, including authentication outcomes, authorization decisions, and resource access patterns. The audit policy controls which events are captured and at what level of detail, and the resulting log stream can be delivered to a webhook backend or written to log files for integration with external monitoring and analysis platforms. Antrea NetworkPolicyStats, enabled via the NetworkPolicyStats feature flag, collects per-policy enforcement statistics including packet and flow counts for traffic matched by each network policy, allowing administrators to verify that policies are actively enforcing network boundaries and to identify policies with no traffic matches.

VKS Policy Insights provides centralized visibility into the governance health of the VKS cluster estate and generates actionable data for troubleshooting and remediating policy enforcement issues. It surfaces Health alerts when infrastructure-level conditions prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, and raises Incompatibility insights when a pre-existing Gatekeeper installation is detected outside of cluster management. Custom VKS Cluster Management Security Policies allow administrators to fine-tune security context parameters to match specific organizational requirements. The Prometheus standard package for VKS clusters measures API server availability as the ratio of successful requests to total requests over 30-day windows, with separate tracking for read and write verb categories, and also captures request duration and error rate metrics. The Telegraf standard package complements this by scraping metrics from service endpoints such as kube-state-metrics and node-exporter.

MachineHealthCheck, a Cluster API resource configurable on VKS clusters, defines unhealthyConditions as an array of node condition types, statuses, and timeout thresholds, enabling declarative detection of nodes that have fallen outside expected health parameters. When a defined condition is met, the controller marks the node for remediation, creating a record of detected infrastructure failures against which administrators can assess the state of resilience controls. VKS cluster machine health conditions, including KubernetesReleaseCompatible, indicate when the Kubernetes release in use by a cluster is no longer compatible with the Supervisor, supporting assessment of upgrade readiness and compatibility posture. VCF's Network Inventory provides visibility into Kubernetes node health by surfacing standard node conditions including MemoryPressure, PIDPressure, DiskPressure, and the Ready condition, allowing administrators to assess node-level health as part of broader infrastructure reviews. The health status of VKS infrastructure components can also be observed directly by inspecting the running state and restart counts of system pods, including etcd, kube-apiserver, antrea-agent, antrea-controller, and coredns, running in the Supervisor cluster.

Harbor Registry, available as a Supervisor Service and as a standard package on VKS clusters, provides vulnerability scanning, content trust, and policy-based access control for container images. Harbor Registry instances on the Supervisor are organized by vSphere Namespace and are automatically trusted by all VKS clusters on the same Supervisor, creating a consistent point of control for supply chain assessment. Security Technical Implementation Guides (STIGs) are available for Supervisor components and VKS Kubernetes releases, providing hardening benchmarks against which administrators can assess deployed cluster configuration and identify gaps. GitOps tooling, such as the Argo CD Supervisor Service, combined with infrastructure as code in version control, creates an audit trail of every authorized change to cluster configuration and supports retrospective review of configuration drift.

Measuring the effectiveness of AI-specific controls such as model accuracy, bias detection, and output filtering is outside VCF's scope. The organization must define assessment cadences, review audit log data and vulnerability reports, track findings to resolution, and evaluate potential impacts on affected communities.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-001

> Compare GAI system outputs against pre-defined organization risk tolerance, guidelines, and principles, and review and test AI-generated content against these guidelines.

**SCF Controls:** AAT-10.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-002

> Document training data sources to trace the origin and provenance of AI-generated content.

**SCF Controls:** AAT-12.1, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

### VMware vDefend (Contributes)

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based

detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-003

> Evaluate feedback loops between GAI system content provenance and human reviewers, and update where needed. Implement real-time monitoring systems to affirm that content provenance protocols remain effective.

**SCF Controls:** AAT-12.1, AAT-12.2, AAT-16.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

### VMware vDefend (Contributes)

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule



fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-004

> Evaluate GAI content and data for representational biases and employ techniques such as re-sampling, re-ranking, or adversarial training to mitigate biases in the generated content.

**SCF Controls:** AAT-10.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-005

> Engage in due diligence to analyze GAI output for harmful content, potential misinformation, and CBRN-related or NCII content.

**SCF Controls:** AAT-27

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure-level mechanisms that support output filtering for AI-generated content, but the specific content policies and filtering criteria are the responsibility of the deploying organization.

The retrieval-augmented generation (RAG) architecture available through PAIS helps reduce false or fabricated content. RAG workloads combine a large language model with an external knowledge base to ground responses in organizational data rather than relying solely on the model's training data. Data scientists can create knowledge bases linked to data sources hosted in external content management systems for production use cases, including Microsoft SharePoint On-Premises deployments, with a single knowledge base linked to up to ten data sources. PAIS knowledge base operations track document counts including crawled documents, newly found documents, deleted documents, and existing modified documents requiring embeddings update, so that the grounding corpus stays current and traceable.

PAIS extends grounding through Model Context Protocol (MCP) integration. PAIS can connect to MCP servers to integrate real-time data and specialized capabilities with generative AI applications, helping models respond from current authoritative sources rather than improvising answers from training data alone.

For model lifecycle, PAIS uses a Harbor registry, or another OCI-compliant registry, as the model gallery from which models are pulled into the platform. This supports a curated set of approved models rather than ad hoc model use. MLOps engineers and application developers can monitor model and agent behavior through observability platforms such as Grafana to track the health, quality, and behavior of AI applications, which gives operators a feedback path for identifying when a deployed model is producing problematic output.

PAIS does not include a built-in content classification or filtering API that automatically screens outputs against predefined content categories. The platform supplies several mechanisms that organizations can use to implement output filtering: RAG grounding, MCP-based real-time data integration, curated model deployment, and runtime observability. The specific content policies, acceptance thresholds, and filtering logic are defined by the deploying organization to match its regulatory and business requirements.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-006

> Use feedback from internal and external AI Actors, users, individuals, and communities, to assess impact of AI-generated content.

**SCF Controls:** AAT-11.1, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-007

> Use real-time auditing tools where they can be demonstrated to aid in the tracking and validation of the lineage and authenticity of AI-generated data.

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.2-008

> Use structured feedback mechanisms to solicit and capture user input about AI- generated content to detect subtle shifts in quality or alignment with community and societal values.

**SCF Controls:** AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-2.3-001

> Develop and update GAI system incident response and recovery plans and procedures to address the following: Review and maintenance of policies and procedures to account for newly encountered uses; Review and maintenance of policies and procedures for detection of unanticipated uses; Verify response and recovery plans account for the GAI system value chain; Verify response and recovery plans are updated for and include necessary details to communicate with downstream GAI system Actors: Points-of-Contact (POC), Contact information, notification format.

**SCF Controls:** AAT-01, BCD-01, IRO-04

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.4-001

> Establish and maintain communication plans to inform AI stakeholders as part of the deactivation or disengagement process of a specific GAI system (including for open-source models) or context of use, including reasons, workarounds, user access removal, alternative processes, contact information, etc.

**SCF Controls:** AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MG-2.4-002

> Establish and maintain procedures for escalating GAI system incidents to the organizational risk management authority when specific criteria for deactivation or disengagement is met for a particular context of use or for the GAI system as a whole.

**SCF Controls:** AAT-15.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.4-003

> Establish and maintain procedures for the remediation of issues which trigger incident response processes for the use of a GAI system, and provide stakeholders timelines associated with the remediation plan.

**SCF Controls:** AAT-18.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides AI-specific mechanisms that support an organization's risk response process for AI systems. MLOps engineers validate ML models onboarded to PAIS against the security, privacy, and technical requirements of the organization, providing a structured gate for remediation when an existing model is identified as risky and a replacement must be vetted before publication. When remediation requires substituting a model, operators can deploy completion or embedding model endpoints and use A/B testing to compare the behavior of candidate models against the incumbent in real-world settings, supporting empirical evaluation of the replacement before full rollout. Embedding model selection is recommended to be based on empirical evaluation using the organization's own data rather than relying solely on benchmarks.

Health and performance metrics for PAIS components running in a VCF Automation namespace can be visualized in observability platforms such as Grafana and VCF Operations. MLOps engineers and application developers can monitor the health, quality, and behavior of AI applications through these observability surfaces to detect anomalies that warrant a risk response. PAIS observability is configured through a Prometheus runtime with a specified storage class and a configurable metrics retention period, with a default of 14 days, giving risk responders historical context for investigation. Metrics collection is activated by enabling the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` CR.

Organizational processes for prioritizing AI risks based on assessments, coordinating remediation across stakeholders, and tracking risk closure remain organizational responsibilities outside the scope of PAIS infrastructure capabilities. General platform resilience inherited from VCF is covered under VCF Coverage and is not a PAIS-specific contribution to this control.

### VMware vDefend (Contributes)

VMware vDefend contributes to prioritizing, responding to, and remediating security risks affecting AI workloads running on VCF by providing severity-based threat prioritization, multiple response mechanisms, and policy-based remediation at the network layer.

**Prioritization.** Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low), helping security teams focus first on the most urgent risks to AI workloads. The Security Services Platform Campaign Impact Score measures the overall severity of correlated threat campaigns on a scale from 0 through 100, with scores calculated using the confidence level of each constituent detection and higher scores indicating higher-priority campaigns for triage. Malware Prevention's Process Analysis Report classifies risk estimates and flags artifacts as High risk when they represent a critical risk requiring priority attention. vDefend IDS/IPS follows a prioritized event-handling approach under memory pressure, dropping lower-priority severity data (Low and Informational) first and retaining Critical and High severity events, so that the most significant detections are preserved for triage and response.

**Response.** When security risks to AI workloads are identified, vDefend provides multiple response options calibrated to the situation. Administrators can deploy microsegmentation rules to isolate affected AI workloads, adjust IDS/IPS profiles to address newly identified threat patterns, or modify Gateway Firewall policies to restrict traffic at the perimeter. The Security Intelligence threat visualization canvas supports rapid threat containment by identifying compromised assets and guiding microsegmentation policy updates. Intelligent Assist analyzes detected anomalies and recommends remediation policies; remediation rules are added using the naming convention prefix 'ai-' and are not enabled by default, requiring an analyst or administrator to review and manually enable them after due diligence and verification. When Intelligent Assist determines that a given anomaly cannot be remediated, it indicates this automatically, allowing analysts to focus on actionable findings. Security Intelligence retains the IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations, providing an audit trail of response actions taken.

Remediation. The Security Intelligence recommendation engine generates firewall policy recommendations based on observed traffic patterns between virtual machines. These recommendations can be published as firewall policies applied to environment category pairs, enabling organizations to close segmentation gaps identified during risk assessments. Administrators can designate high-priority applications and groups through prioritized collections, focusing Security Intelligence's flow analysis on the AI workloads most critical to protect.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-2.4-004

> Establish and regularly review specific criteria that warrants the deactivation of GAI systems in accordance with set risk tolerances and appetites.

**SCF Controls:** AAT-15.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-3.1-001

> Apply organizational risk tolerances and controls (e.g., acquisition and procurement processes; assessing personnel credentials and qualifications, performing background checks; filtering GAI input and outputs, grounding, fine tuning, retrieval-augmented generation) to third-party GAI resources: Apply organizational risk tolerance to the utilization of third-party datasets and other GAI resources; Apply organizational risk tolerances to fine-tuned third-party models; Apply organizational risk tolerance to existing third-party models adapted to a new domain; Reassess risk measurements after fine-tuning third-party GAI models.

**SCF Controls:** AAT-02.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides the security and resilience infrastructure that protects AI and autonomous technology workloads running on the platform. VCF's layered security model includes VMware vCenter RBAC with granular roles and permissions that control who can manage AI workload VMs, VCF SSO for centralized authentication, ESX Secure Boot and TPM for host integrity, VM encryption and vSAN encryption at rest for data protection, and VDS/NSX network segmentation for workload isolation. VCF Operations provides continuous monitoring with compliance dashboards that assess the security posture of the infrastructure hosting AI workloads. VCF Operations also monitors Kubernetes-specific health metrics for Supervisor-managed clusters, including node status and kubelet status. vSphere HA and DRS provide compute resilience, and vSAN fault domains provide storage resilience. VKS clusters support MachineHealthCheck, a Kubernetes Cluster API resource that monitors defined node health conditions and triggers automatic machine remediation when worker nodes become unhealthy, providing a cluster-native resilience mechanism for AI workload infrastructure.

The Consumption layer of VCF, delivered through VMware Kubernetes Service (VKS) and the vSphere Supervisor, extends these protections to containerized AI and machine learning workloads. VKS requires the Ubuntu VKr node operating system for AI/ML workloads, establishing a defined and consistent runtime configuration to which security policy can be applied. Pod Security Admission (PSA) is enforced at the namespace level and supports three modes (warn, audit, and enforce) combined with three profiles (privileged, baseline, and restricted). The restricted profile disallows privileged containers, limits Linux capabilities, requires non-root execution contexts, and restricts volume types. The podSecurityStandard variable in VKS cluster configuration sets the cluster-wide default pod security policy, with per-namespace exemptions defined where workload requirements justify them. VKS cluster management provides out-of-the-box security policy templates for the baseline and restricted profiles, letting operators match the level of restriction to each workload's assessed risk without manual policy authoring.

VKS clusters enforce Kubernetes NetworkPolicy objects that restrict ingress and egress traffic at the pod and namespace level, allowing AI/ML workloads to be deployed in dedicated namespaces with rules that limit communication to authorized services. The Antrea AntreaPolicy feature gate enables fine-grained network policy enforcement through the Antrea CNI. The Istio CNI plugin can be enabled on VKS clusters to manage pod network interfaces and apply service mesh policies without requiring privileged containers, supporting AI inference pipelines that need encrypted inter-service communication and fine-grained traffic routing.

Kubernetes Deployments and ReplicaSets apply an immutable infrastructure pattern in which containers are replaced rather than modified in place, making unauthorized persistent changes to AI/ML workloads visible and reducing the risk of persistent compromise. More broadly, Kubernetes workload resources including Deployments, StatefulSets, and DaemonSets provide self-healing capabilities that automatically replace failed containers and reschedule workloads to available nodes when machines become unavailable. Liveness probes detect and remedy broken application states by restarting containers that fail health checks, supporting continuity of AI/ML workload operation without operator intervention. Harbor, available as a Supervisor Service and deployable as a standard package on VKS clusters, provides a private container image registry scoped by vSphere Namespace. Integrating workload deployments with a governed Harbor registry restricts AI/ML containers to images sourced from a controlled registry, reducing supply chain risk. In air-gapped environments, Harbor Supervisor Service serves as the private registry from which VKS images and upgrade packages are pulled. Content libraries in the Supervisor

environment support creation of VM images with current patches and required security settings following organizational security policies.

VCF Automation Organizations provide centralized access control and establish secure boundaries between organizational units consuming VKS clusters, supporting delegation of cluster management with enforced separation. VKS cluster management policies enable governance of the operational consistency and security posture of the cluster estate through policy-driven automation, covering both baseline and restricted security configurations.

Kubernetes documentation in the Consumption layer addresses cloud-native security practices applicable to AI/ML workloads, including threat modeling during the Develop lifecycle phase to identify trust boundaries and risks, and applying cryptographic protections for audit logs in high-assurance environments. Confidential virtual machines are available for workloads requiring additional hardware-level isolation.

AI-specific risk assessment and the alignment of protections to AI threat models are organizational responsibilities. VCF provides the infrastructure and platform mechanisms that those assessments direct, including the ability to calibrate pod security profile stringency, network segmentation scope, and image provenance controls to the assessed risk of each AI workload. Fully satisfying this control requires organizational processes to define acceptable risk thresholds and deliberately select the appropriate policy configuration based on each workload's risk assessment.

This control asks whether the organization ensures AI and autonomous technologies include reasonable security, compliance, and resilience protections commensurate with assessed risks and threats. The control is categorized as Process under NIST CSF Govern, which evaluates organizational risk assessment and governance practice rather than platform capability. VMware Private AI Services (PAIS) supplies technical mechanisms that the organization can configure when planning AI workload protections, including MLOps-driven validation of ML models against organizational security, privacy, and technical requirements before onboarding, examination and approval workflows for Model Context Protocol (MCP) server tools and capabilities before agents use them, CA trust bundle configuration for secure communication with external services and databases, Harbor and OCI-compliant registry integration with certificate-based trust for model retrieval, observability through Prometheus and Grafana for monitoring AI model health, quality, and behavior, and support for air-gapped deployment models for environments with strict isolation requirements. Determining which protections are commensurate with the organization's assessed risks and threats, and governing AI initiatives under an enterprise risk program, are organizational activities that PAIS does not perform.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to ensuring AI workloads running on VCF include reasonable cybersecurity protections commensurate with assessed risks and threats.

The vDefend distributed firewall and microsegmentation capabilities enforce network-level protections that can be scaled proportionally to each AI workload's risk profile. Security Intelligence monitors traffic flows, generates firewall rule recommendations, and validates security policies for the Distributed Firewall, providing Infrastructure, Environment, and Application Monitoring across the deployment. Security Intelligence generates policy recommendations for environment pairs based on observed inter-VM traffic patterns, and these recommendations can be published as firewall policies applied to environment category pairs. The Recommendation engine selects inter-environment traffic that hits protection rules or default category rules, producing granular application-level rules that allow only authorized traffic between environments. Administrators can identify all inter-environment flows and secure them with specific policies before enforcing strict block rules between environments.

Security Services Platform Environment Protection evaluates whether workloads are protected by environment-specific segmentation policies such as Dev, Prod, and Test. Security Intelligence provides metrics for monitoring firewall rule effectiveness and proactive threat detection. Comparing the ratio of detected versus prevented events provides a means to assess how effectively security controls are protecting infrastructure, giving administrators insight into whether current protections are proportionate to AI workload risk. Security Intelligence also collects IDS policies, rules, and security profiles created by Intelligent Assist as part of remediation operations, enabling policy adjustments in response to detected threats.

IDS/IPS inspects traffic to and from AI workloads for exploit attempts, command-and-control traffic, lateral movement, and exfiltration patterns. Malware Prevention analyzes files entering the environment for malicious content. vDefend rules can enforce isolation between projects, denying all inter-project communication except for required infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

vDefend contributes to this control because its Distributed Firewall, IDS/IPS, Malware Prevention, and Security Intelligence capabilities provide network-layer protections that can be scaled to each AI workload's assessed risk level. However, ensuring adequate protections across all dimensions of AI risk, including application security, data governance, model integrity, and operational resilience, extends beyond the network security domain that vDefend addresses.

#### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) contributes to the security and resilience protections for AI and autonomous technology workloads through replication, failover orchestration, and isolated recovery capabilities. When AI workloads run on VCF infrastructure, PNR protects them with configurable replication intervals, automated recovery plans, and tested failover procedures. Protection and Recovery organizes virtual machines into protection groups as the basis for cross-site replication and failover, and recovery plans can be tested in quarantined test networks that have no lasting effects on either the protected site or the recovery site.

Cyber Recovery extends protection with vulnerability analysis and clean room recovery capabilities. The Integrated Security and Vulnerability Analysis with CrowdStrike assigns vulnerability risk scores on a scale from 0 (no risk) to 10.0 (maximum risk), assessing the risk associated with vulnerabilities based on exploitability likelihood and predicted potential impact on virtual machines in the recovery environment. Cyber Recovery implements a "Quarantined + Analysis" isolation level that restricts virtual machine connectivity to integrated security and vulnerability servers, providing a controlled environment for analyzing workloads before returning them to production. Periodic security scans of virtual machines in the clean room region support compliance validation prior to production restoration.

The broader requirements of this control, including AI-specific risk assessment, threat identification, and alignment of protections to assessed risk levels, are organizational responsibilities outside PNR's scope.

#### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to the security and resilience protections for AI workloads that store data in DSM-managed databases. DSM provides role-based access control with Admin and User roles that restrict who can administer the environment and who can manage databases, and namespace-scoped restrictions that allow a Cloud Administrator to control which InfrastructurePolicies and BackupLocations are available in each user namespace. Infrastructure policies act as guardrails that restrict the quality and quantity of resources DSM users can consume from vSphere clusters, covering CPU, memory, storage policies, IP pool, VM classes, and related resources, and the Infrastructure Policies view in the DSM administrator UI gives administrators a single place to review available policies and the databases associated with them.

Data service policies can be defined for MySQL, PostgreSQL, and SQL Server and configured to enforce consistent security and compliance posture across tenants. Each policy can require, allow, or disallow automated backups, and when backups are required at least one backup location must be configured with a trusted root certificate. Resilience for database workloads is supported through high-availability topologies; for workloads that need both data protection and high read throughput, a three-node HA cluster can be deployed with multiple read replicas, where the primary node synchronously replicates to failover nodes and asynchronously replicates to read replicas. DSM generates infrastructure policy compliance alerts, including INFRASTRUCTURE\_POLICY\_CLUSTER\_COMPLIANT and INVALID\_SUPERVISOR\_INFRASTRUCTURE\_POLICY\_STATUS, that monitor cluster configuration and Supervisor infrastructure policy state so administrators can detect drift from defined policy.

The broader requirements of this control, including AI-specific risk assessment and alignment of protections to assessed risk levels, are organizational responsibilities outside DSM's scope.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer security mechanisms that organizations can use to protect AI and autonomous technology workloads running behind Avi virtual services. These capabilities address the security and resilience dimensions of this control at the application delivery layer.

Avi's Web Application Firewall (WAF) supports a positive security model through WAF Positive Security rules, which define allowed application behavior as an allowlist of expected request patterns. WAF Positive Security Groups can be created and configured within a WAF Policy to define allowed request patterns and enforce positive security models. Avi WAF Policies attach a Positive Security group to apply learned data for security and to define hit and miss actions. Administrators can enable Application Insights to analyze known-good traffic and generate a Positive Security group for ongoing enforcement. For AI API endpoints where expected request structures can be defined, this provides a mechanism to enforce consistent application-layer access controls.

The Avi Cloud Console Application Rules Service allows organizations to protect their applications from vulnerabilities by enabling the service on their Avi Controllers, providing a cloud-delivered mechanism for rule-based protection of AI application endpoints.

Avi's Bot Management capability detects and classifies automated traffic, including bots and autonomous agents, and applies enforcement actions based on classification results. The Avi Cloud Console BOT Management Service can allow, deny, or rate-limit bad bots, and supports User Agent Database Sync to receive updated user agent signatures for threat detection. Bot detection policies are created using the `configure botdetectionpolicy` CLI command or through HTTP security policy rules. WAF HTTP Security policies support Bot Management as a match condition, allowing administrators to select specific bot classifications and assign enforcement actions such as allow, deny, or rate limiting. The BOT Management Service requires the IP Reputation service to be enabled for full coverage of bad bot traffic. A `System-BotDetectionPolicy` can be bound to virtual services to enforce bot detection rules across AI workload endpoints. For AI workloads that interact with automated clients, this gives administrators visibility and control over which automated systems are permitted access.

In Kubernetes deployments using the Avi Kubernetes Operator (AKO), the `L7Rule` custom resource definition supports a `botPolicyRef` parameter to reference a bot policy for bot detection and mitigation on individual ingress routes. Virtual services can also reference a `SecurityPolicy` to perform DDoS attack mitigation on traffic flowing through the virtual service, giving platform teams a Kubernetes-native path to apply Avi security capabilities to AI workloads running in clusters.

Avi Service Engines automatically defend against DDoS attacks by implementing TCP SYN cookies, idle connection reaping, and protocol validation. The Service Engine data-plane architecture isolates attacks on the data plane from management interfaces, so a volumetric attack against a backend AI service does not affect Controller management. Service Engines detect and mitigate a wide range of Layer 4-7 network attacks to protect application traffic.

Avi's Network Security Policy supports creation of rules that match on IP address and apply IP Groups to control access, providing a mechanism to restrict which sources can reach AI application endpoints.

Avi supports role-based access control for administrative access to the Controller. Administrators can restrict administrative access by source IP address range and use RBAC to limit access levels, scoping the administrative attack surface for Avi infrastructure that fronts AI workloads.



## Control MG-3.1-002

> Test GAI system value chain risks (e.g., data poisoning, malware, other software and hardware vulnerabilities; labor practices; data privacy and localization compliance; geopolitical alignment).

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-3.1-003

> Re-assess model risks after fine-tuning or retrieval-augmented generation implementation and for any third-party GAI models deployed for applications and/or use cases that were not evaluated in initial testing.

**SCF Controls:** AAT-10.1, AAT-11.2

**Aggregate Coverage:** Contributes

#### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure for evaluating AI systems for trustworthy behavior, specifically addressing the security dimension of trustworthiness assessment. The validate-then-publish workflow requires MLOps engineers to validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the Model Gallery. This validation includes evaluating models for inference functionality using the Triton Inference Server and examining inference requests for malicious behavior, directly addressing the security evaluation component of trustworthiness.

Deep learning VMs provisioned from PAIS images are isolated evaluation environments where data scientists and MLOps engineers can assess model behavior before production deployment. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so trustworthiness evaluation occurs under conditions comparable to the deployment environment. Model integrity is verified through hash code validation and unique content digests on each revision, stored as OCI artifacts with immutable manifests, providing cryptographic verification that the evaluated model is the same artifact that reaches production.

PAIS does not address the anonymization or disaggregation aspects of this control. Data anonymization, de-identification, and disaggregation of captured and stored data are application-layer data governance activities that fall outside the scope of infrastructure-level platform controls.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control MG-3.1-004**

> Take reasonable measures to review training data for CBRN information, and intellectual property, and where appropriate, remove it. Implement reasonable measures to prevent, flag, or take other action in response to outputs that reproduce particular training data (e.g., plagiarized, trademarked, patented, licensed content or trade secret material).

**SCF Controls:** AAT-12, AAT-26

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-3.1-005

> Review various transparency artifacts (e.g., system cards and model cards) for third-party models.

**SCF Controls:** AAT-20.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-3.2-003

> Document sources and types of training data and their origins, potential biases present in the data related to the GAI application and its content provenance, architecture, training process of the pre-trained model including information on hyperparameters, training duration, and any fine-tuning or retrieval-augmented generation processes applied.

**SCF Controls:** AAT-10.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-3.2-004

> Evaluate user reported problematic content and integrate feedback into system updates.

**SCF Controls:** AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-3.2-005

> Implement content filters to prevent the generation of inappropriate, harmful, false, illegal, or violent content related to the GAI application, including for CSAM and NCII. These filters can be rule-based or leverage additional machine learning models to flag problematic inputs and outputs.

**SCF Controls:** AAT-27

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure-level mechanisms that support output filtering for AI-generated content, but the specific content policies and filtering criteria are the responsibility of the deploying organization.

The retrieval-augmented generation (RAG) architecture available through PAIS helps reduce false or fabricated content. RAG workloads combine a large language model with an external knowledge base to ground responses in organizational data rather than relying solely on the model's training data. Data scientists can create knowledge bases linked to data sources hosted in external content management systems for production use cases, including Microsoft SharePoint On-Premises deployments, with a single knowledge base linked to up to ten data sources. PAIS knowledge base operations track document counts including crawled documents, newly found documents, deleted documents, and existing modified documents requiring embeddings update, so that the grounding corpus stays current and traceable.

PAIS extends grounding through Model Context Protocol (MCP) integration. PAIS can connect to MCP servers to integrate real-time data and specialized capabilities with generative AI applications, helping models respond from current authoritative sources rather than improvising answers from training data alone.

For model lifecycle, PAIS uses a Harbor registry, or another OCI-compliant registry, as the model gallery from which models are pulled into the platform. This supports a curated set of approved models rather than ad hoc model use. MLOps engineers and application developers can monitor model and agent behavior through observability platforms such as Grafana to track the health, quality, and behavior of AI applications, which gives operators a feedback path for identifying when a deployed model is producing problematic output.

PAIS does not include a built-in content classification or filtering API that automatically screens outputs against predefined content categories. The platform supplies several mechanisms that organizations can use to implement output filtering: RAG grounding, MCP-based real-time data integration, curated model deployment, and runtime observability. The specific content policies, acceptance thresholds, and filtering logic are defined by the deploying organization to match its regulatory and business requirements.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-3.2-006

> Implement real-time monitoring processes for analyzing generated content performance and trustworthiness characteristics related to content provenance to identify deviations from the desired standards and trigger alerts for human intervention.

**SCF Controls:** MON-01.2, MON-05.1

**Aggregate Coverage:** Meets

### VCF (Meets)

VCF provides integrated tools for near-real-time log analysis, event correlation, incident investigation, and alert escalation across the entire infrastructure stack. It also supports forwarding logs to external SIEM solutions through syslog integration on every major component.

VCF Operations continuously monitors compute, storage, and networking resources, correlating metrics over time to identify trends and anomalies. Administrators can define alert policies that specify which objects to monitor and what thresholds to apply. Alert definitions can be based on performance metrics, log events, or custom conditions configured through the Management Pack Builder. Metric event symptoms can be configured based on reported violations of metric thresholds from monitored systems, and those symptoms can be incorporated into alert definitions that trigger when conditions are met. Intelligent Alerts group related alerts into clusters based on creation time and topology distance, reducing alert noise so administrators can focus on the most critical issues rather than sifting through thousands of alerts generated by multiple monitoring tools for the same problem. Each alert cluster includes a graphical timeline and an object-relationship chart to help trace root causes. When an alert is triggered, it generates an event that is posted to the event history database for tracking and escalation. VCF Operations can also send alert notifications via SNMP trap to up to four SNMP trap destinations.

VCF Health, a component of VCF Operations, continuously monitors the operational state of VCF components to verify they are functioning as expected, giving platform operators a single view of operational status. The Platform Health Alerts page provides a centralized view of all alerts related to overall system health, including alerts from data sources and infrastructure nodes. Health alerts are generated for conditions that affect the health of the environment and require immediate attention.

The Troubleshooting Incidents page in VCF Operations provides a summary of all incidents, including status, entity count for in-progress incidents, and count of top root causes. The interface highlights anomalies in metrics for quick detection and allows filtering metrics and alerts based on metric name, entity name, and other parameters. Correlated metric analysis is available through the incident interface to support root cause investigation. VCF Operations Diagnostics provides a Refresh Findings capability that performs real-time analysis using product logs in the environment where the problem has occurred.

Event auditing within VCF Operations provides visibility into platform interaction changes across the VCF infrastructure, with insights into suspicious access events and policy violations. Each audit event includes a detailed view containing information that helps administrators analyze events in the virtual infrastructure for suspicious user actions or system issues.

VCF Operations provides continuous compliance management by monitoring infrastructure against industry-standard benchmarks and custom policies. Administrators can create custom compliance benchmarks that monitor selected alert definitions and policies, tailoring the monitoring posture to organizational requirements. The platform assesses objects based on selected compliance policies and activates alert definitions associated with the current scorecard, providing ongoing visibility into compliance status.

VCF Log Management provides centralized log aggregation, collecting logs from all VCF components including VMware vCenter, VMware ESX, NSX, vSAN, VCF Automation, VCF Identity Broker, VCF Operations for Networks, and VCF Operations HCX. The platform delivers real-time analytics that allow administrators to search and filter logs instantly for troubleshooting or auditing purposes. Pre-built dashboards, alerts, and queries are available through content packs for each VCF component. Log-based alert definitions allow administrators to trigger notifications when specific log patterns appear across monitored systems. Log analysis charts support aggregation functions and grouping types for investigating patterns across the environment. VCF Operations and VCF Log Management must be integrated to implement the centralized log collection architecture.



VCF supports forwarding logs to external SIEM or syslog targets on every major component. vCenter syslog forwarding can be configured through both the UI and the vCenter Management API, supporting TCP, UDP, TLS, and RELP protocols. The API provides endpoints for setting the forwarding configuration, retrieving the current configuration, and testing the connection with remote syslog servers. The vCenter Appliance Management Interface supports up to three remote syslog destination hosts. ESX hosts can forward syslog messages to remote collectors through the VMware Host Client by configuring the Syslog.global.logHost setting, using the format protocol://hostname:port where protocol can be UDP, TCP, or SSL. NSX Manager can export syslog to a remote server with configurable protocol, port, and log level, and supports TLS on port 6514 for encrypted log transmission. The Foundation Load Balancer supports log forwarding to syslog servers. VCF Operations supports remote syslog host configuration through Host System Properties. VCF Operations HCX automatically forwards logs from both the manager and appliance virtual machines once configured. VCF Operations for Networks supports per-cluster syslog server configuration, with the option for individual collectors to use different syslog destinations. vSphere Supervisor forwards control plane logs to external syslog servers using Fluent Bit with RFC 5424 message format over TCP, with configurable host, port, and transport mode. Log forwarding supports TLS encryption for confidentiality in transit.

At the vSphere layer, the alarm infrastructure integrates with events and performance counters for real-time alerting. The MetricAlarmExpression data object allows administrators to set alarms on specific performance metrics with configurable monitoring intervals and aggregation functions for processing data points. The alarm system supports automating actions and sending different types of notification in response to certain server conditions. The vSphere Client provides direct visibility into tasks and events for change tracking.

The monitoring platform extends beyond VCF's core infrastructure. When VCF Automation is integrated with VCF Operations, the Insights dashboard and Alerts tab provide real-time capacity awareness and alert information for VCF Automation objects, giving IT teams visibility into resource usage across both provisioned workloads and the underlying infrastructure. The Management Pack Builder allows administrators to set up event definitions for integrated systems, monitoring specific conditions or thresholds and configuring alerts for proactive management. Adapters can be installed on VCF Operations nodes to extend monitoring to additional systems and data sources beyond the core VCF components.

VCF Operations supports flexible grouping and scheduling to align monitoring with operational realities. Custom groups can be configured with automatic membership criteria to support monitoring strategies and achieve a high level of automation. Maintenance schedules can be assigned to objects undergoing planned downtime to keep monitoring data accurate and avoid false alerts when an object is offline for scheduled maintenance.

At the network layer, NSX provides monitored indicators including node uptime status, deployment status, management and controller connections, tunnel status, PNIC status, and uptime duration. NSX time series APIs allow viewing data such as VPN statistics, including metadata about the number of tunnels configured and how many are up or down at a given time. NSX Live Traffic Analysis monitors live traffic at a source or between source and destination, with packet capture to identify packet drops and bad flows between endpoints. Starting with NSX 4.2, Live Traffic Analysis sessions can capture real-time debug statistics from data path kernel-level modules on ESX host transport nodes.

VCF Operations also supports self-monitoring through the VCF Operations adapter, which collects internal metrics such as analytics operation counts, threshold check durations, and incoming observation sizes. This allows administrators to verify that the monitoring platform itself is functioning correctly. The VCF Operations policy engine monitors conditions and generates events to react to changing states in the orchestrator server or connected technologies. The Adapter Instance monitoring interval is configurable, with intervals as granular as five minutes.

VMware Private AI Services (PAIS) provides observability infrastructure that supports near real-time monitoring of AI workload activity and emits the data streams that an external Security Incident Event Manager (SIEM) or analytics platform consumes for analysis and incident escalation.

PAIS exposes a Prometheus runtime that is activated through the observability section of the PAISConfiguration custom resource, with a configurable storage class policy and a metrics retention period. The Prometheus metrics endpoint is reachable at the PAIS FQDN or IP address so that external monitoring systems can scrape operational data in near real time. PAIS metrics are visualized in observability platforms such as Grafana and VCF Operations, and a single Grafana instance can

visualize metrics from multiple PAIS instances when they share the same OIDC provider. The Grafana dashboards expose operationally relevant signals including LLM completion API response times at the 95th percentile, inference engine tokens-per-second generation rate, and GPU compute and memory utilization. For the VCF Operations integration, PAIS Controller metrics are collected through Telegraf with namepass filters configured to capture `controller_runtime_active_workers`, `controller_runtime_max_concurrent_reconciles`, `workqueue_depth`, and `workqueue_longest_running_processor`. The PAIS Prometheus server authenticates clients using Forward OAuth identity.

For AI inference traceability, PAIS supports forwarding LLM traces to an external OpenTelemetry Collector, configured by uncommenting the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource. Traces are transmitted over HTTP/Protobuf or gRPC. Authentication to the collector is configured through a Kubernetes Secret containing Authorization Bearer tokens and custom headers. When LLM trace collection is active, operators and security teams can analyze traces from agents and knowledge base indexing in the OpenTelemetry Collector, producing behavioral visibility that can feed into incident analysis workflows. The vLLM inference engine that runs completion models on GPU supports a configurable logging level through the `VLLM_LOGGING_LEVEL` environment variable for additional diagnostic detail.

For Deep Learning VM workloads, PAIS deploys a DCGM Exporter virtual machine that integrates with NVIDIA DCGM, Prometheus, and Grafana to export vGPU performance metrics. Prometheus and Grafana are deployed as Docker services on a visualization VM to collect and visualize DCGM metrics from Deep Learning VMs running the DCGM exporter, supporting near real-time GPU performance monitoring.

To support SIEM integration, administrators should activate the PAIS observability sections and direct the Prometheus and OpenTelemetry data streams to the SIEM, security analytics platform, or VCF Log Management deployment that performs the near real-time analysis and incident escalation. PAIS itself does not implement SIEM correlation or automated escalation; that capability is provided by the external platform that consumes these streams.

### VMware vDefend (Contributes)

VMware vDefend does not function as a SIEM but contributes to near real-time analysis by generating structured security event data from multiple enforcement and detection engines, supporting forwarding of that data to external log management and SIEM platforms, and providing native dashboards that surface security events, intrusion trends, and anomalies.

Security Services Platform (SSP) supports syslog forwarding to remote servers with TCP, UDP, or TLS-encrypted transport, configurable through the SSP UI under Server Configurations > Add Platform Syslog Server or via REST API. The License Hub component within SSP can independently be configured to send logs to a remote syslog server by specifying a server FQDN or IP address, protocol, and port. Malware Prevention Service log forwarding supports UDP delivery with configurable log level and message ID filtering (SECURITY, MONITORING), and can be configured for TLS-encrypted delivery using client certificates and keys. IDS/IPS events support independent syslog forwarding, enabling security operations teams to route detection events to a centralized log management or SIEM platform.

The Security Overview Dashboard's Threat Event Monitoring view provides near real-time visibility into security events: a timeline graph of intrusion events categorized by Intrusion Severity, a radar chart showing distribution by Attack Type, Attack Target, or Severity over a configurable window of 24 hours to 14 days, the top IPs and VMs subject to intrusion attempts filtered by Vulnerability Severity criteria, and counts of unique intrusion signatures detected per severity category. Firewall Insights provides time-series data visualizations for historical firewall activity trends. Security Intelligence categorizes detected suspicious traffic events by impact type (Critical, High, Medium, and Low) to help prioritize response actions, and detects and categorizes suspicious events using MITRE tactics and techniques over the selected time period.

Through the Security Explorer interface, Security Intelligence detects intrusion events in real time with filtering by compute and IDS Signature ID, and provides a View Full Event History capability that displays all events associated with a signature ID and intrusion severity. Network Detection and Response (NDR) and IDS/IPS support date range filtering for event detail review, enabling temporal analysis of security events and intrusion attempts. Security teams can investigate individual threat events and correlated campaigns through the SSP interface to assess impact, identify root causes, and take appropriate mitigation actions. The Process Analysis Report for fileless and file-based malware provides a downloadable packet capture (PCAP) file for detailed process inspection analysis. The Metrics API provides programmatic access to firewall and network

monitoring metrics, supporting Point-in-Time queries for current state, Top-N analysis, and time-interval aggregated queries over configurable windows.

Organizations must deploy a dedicated SIEM or equivalent platform to fulfill the full requirements of this control, including cross-source event correlation, normalization, and automated incident escalation workflows.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides a native alerting framework that processes system events and metrics against user-defined rules and generates near real-time notifications through multiple channels. When audit record failures occur across the Events, Syslog, or Splunk subsystems, the Avi Controller and Service Engine log those failures and route them to configured notification destinations.

The Avi Controller supports four alert notification channels: email, external syslog servers, SNMP trap receivers, and ControlScripts. These are configured in the Operations > Notifications page of the Controller UI. The Controller cluster leader issues SNMP trap notifications based on system events, and multiple SNMP servers can be configured for redundancy. Both SNMPv2c and SNMPv3 protocols are supported for SNMP trap delivery. SNMP notifications can be configured with TLS encryption and strict certificate verification for secure transport to monitoring infrastructure.

For syslog-based notification, Avi provides the Syslog-Audit-Persistence mechanism, which streams alert events to external syslog servers. Alert events can be delivered using the SYSLOG\_RFC5425\_ENHANCED format for structured notification delivery. Syslog notifications push alert events to syslog servers; virtual service logs must be separately retrieved from the Controller through the API or pushed to a remote destination using a ControlScript.

The Avi Controller and Service Engine log audit record failures for trusted channel initiation, termination, and function failures to the Events, Syslog, and Splunk subsystems. Custom alert configurations allow administrators to map specific system events to specific notification actions. The Controller also executes ControlScripts when alert conditions are triggered, generating detailed execution logs including operation status and error conditions. Avi Event Logs provide an audit trail that records system activities and configuration changes with information about who made them and when.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-3.2-007

> Leverage feedback and recommendations from organizational boards or committees related to the deployment of GAI applications and content provenance when using third-party pre-trained models.

**SCF Controls:** AAT-11.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-3.2-008

> Use human moderation systems where appropriate to review generated content in accordance with human-AI configuration policies established in the Govern function, aligned with socio-cultural norms in the context of use, and for settings where AI models are demonstrated to perform poorly.

**SCF Controls:** AAT-27.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-3.2-009

> Use organizational risk tolerance to evaluate acceptable risks and performance metrics and decommission or retrain pre-trained models that perform outside of defined limits.

**SCF Controls:** AAT-10.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.1-001

> Collaborate with external researchers, industry experts, and community representatives to maintain awareness of emerging best practices and technologies in measuring and managing identified risks.

**SCF Controls:** AAT-16.5

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) supports domain expert validation through a structured role-based workflow built around a validated-model gallery, container-registry model storage, and approval gates for agent tooling. The platform separates responsibilities so that domain-appropriate experts review AI systems at each stage, with MLOps engineers acting as the designated domain expert for model quality and safety within the PAIS workflow.

MLOps engineers validate ML models onboarded to PAIS against the security, privacy, and technical requirements of the organization before the models are made available for downstream use. Validated models are stored in a Harbor registry that acts as the model storage backend, with authentication and certificate-based trust for retrieval; OCI-compliant registries from other vendors are also supported, including in disconnected environments. A central model gallery is the recommended store for ML models, providing centralized management and consistency across deployment targets, which gives reviewers a single inventory to assess and approve before promotion.

For agent-based AI applications, PAIS requires examination and approval of Model Context Protocol (MCP) server tools and capabilities before they are used in agents, and the Agent Builder maintains a list of approved tools for use when connecting to MCP servers. Deep learning VMs give domain experts hands-on environments to prototype, fine-tune, and validate model behavior before promotion. When deploying completion or embedding model endpoints, A/B testing is recommended so that reviewers can compare candidate models in real-world settings. Catalog items for AI applications provisioned through VCF Automation, together with PAIS observability surfaced in platforms such as Grafana, give reviewers the operational signals needed to validate that AI systems perform consistently after release.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.1-002

> Establish, maintain, and evaluate effectiveness of organizational processes and procedures for post-deployment monitoring of GAI systems, particularly for potential confabulation, CBRN, or cyber risks.

**SCF Controls:** AAT-10.11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



### Control MG-4.1-003

> Evaluate the use of sentiment analysis to gauge user sentiment regarding GAI content performance and impact, and work in collaboration with AI Actors experienced in user research and experience.

**SCF Controls:** AAT-01, AAT-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MG-4.1-005

> Share transparency reports with internal and external stakeholders that detail steps taken to update the GAI system to enhance transparency and accountability.

**SCF Controls:** AAT-10.6

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.1-006

> Track dataset modifications for provenance by monitoring data deletions, rectification requests, and other changes that may impact the verifiability of content origins.

**SCF Controls:** AAT-12.1, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

### VMware vDefend (Contributes)

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.1-007

> Verify that AI Actors responsible for monitoring reported issues can effectively evaluate GAI system performance including the application of content provenance data tracking techniques, and promptly escalate issues for response.

**SCF Controls:** AAT-10.13

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to post-deployment monitoring of AI workloads through VCF Operations, which provides continuous health, performance, and capacity monitoring for the infrastructure hosting those workloads. VCF Operations dashboards surface CPU, memory, storage, and network metrics for VMs running AI workloads. VCF Log Management aggregates and analyzes log data from VMware vCenter, VMware ESX, and NSX components. vCenter alarms provide threshold-based alerting for infrastructure conditions that could affect AI workload availability.

For AI workloads running as containerized applications on VMware Kubernetes Service (VKS) clusters, the platform extends infrastructure-level observability to the Kubernetes layer. VKS clusters provisioned with the automated-monitoring label automatically receive monitoring configuration on each new node, integrating cluster telemetry with VCF Operations. The Prometheus standard package, installable on VKS clusters through the Supervisor Management Proxy Service, deploys kube-state-metrics, node-exporter, pushgateway, Prometheus, and Alertmanager as components. The prometheus-kube-state-metrics component monitors node status and capacity, ReplicaSet compliance, pod status, job and CronJob status, and resource requests and limits, providing continuous metric collection that can be directed at AI inference services or training job pods. Telegraf is available as a standard package that deploys as a Deployment component to scrape metrics from kube-state-metrics and node-exporter and forward them to external observability backends. Monitoring and alerting for Kubernetes deployments is also available through the Argo CD Supervisor Service using Grafana Operator and Prometheus.

Kubernetes-native health probes and status tracking support workload condition detection at the pod level. Liveness and readiness probes can be configured on AI workload containers to detect unresponsive or overloaded model serving instances; a readiness probe removes the pod from service routing when it cannot handle requests, and a liveness probe triggers a container restart when the application becomes unresponsive. The Kubernetes Deployment controller continuously monitors running application instances and automatically replaces instances when nodes fail or are removed from service, providing a self-healing mechanism that addresses machine failure or maintenance. Kubernetes DeploymentStatus exposes observedGeneration and conditions fields with type, status, lastTransitionTime, and reason values, allowing operators to detect rollout failures, stuck deployments, or configuration drift from the expected specification. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly, and generates Policy Insights when configuration conflicts or environmental errors are detected.

For organizations using Harness CI/CD on VKS, Dynatrace integration provides full-stack observability including application performance monitoring, infrastructure monitoring, and digital experience monitoring. The Dynatrace operator automates deployment, scaling, and maintenance of the monitoring stack within VKS clusters, and automatically correlates application deployment service metrics with underlying VKS infrastructure including nodes, pods, and the network. The Dynatrace AI engine detects anomalies, identifies root causes, and provides intelligent alerts. Harness SRM monitors deployed services post-deployment to calculate a real-time health score based on transaction success and latency.

The VCF Automation Monitor tab provides deployment health information drawn from VCF Operations, and deployment cards in the self-service catalog surface deployment state, last request status, and operational history for workload deployments. AI-specific behavior monitoring (model accuracy drift, output quality) requires application-level tooling outside VCF's scope.

VMware Private AI Services (PAIS) provides AI-specific monitoring mechanisms that support continuous post-deployment observation of AI workloads on VCF.

At the PAIS layer, observability is activated by updating the PAISConfiguration custom resource with parameters that enable metrics collection and forward large language model traces to an OpenTelemetry Collector. PAIS deploys a Prometheus server pod for metrics collection that must be ready and running for observability to function, configured with a chosen

storage class and a configurable metrics retention period. PAIS controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance, and the telegraf-user-config ConfigMap in the vmware-system-monitoring namespace manages user-configured monitoring endpoints for PAIS. The PAIS Supervisor Service exposes service-level metrics through `pais.vmware.com` that VI administrators access to monitor the health of the service.

DevOps engineers visualize PAIS health and performance metrics in observability platforms such as Grafana, where dashboards report pod restart frequency, vGPU licensing status, and idle or underutilized GPU devices in passthrough mode. VI administrators visualize PAIS controller pod operation metrics in VCF Operations using the same metrics pipeline. MLOps engineers and application developers track the health, quality, and behavior of AI applications and the models used in agents through Grafana, supporting continuous observation of inference behavior. Model Endpoint deployment status can be verified using the `kubectl get modelendpoints` command, which returns the Ready status for each deployed endpoint, and the `vcf` cluster command-line interface provides cluster provisioning monitoring, registration, and kubeconfig retrieval for VKS clusters that host AI workloads. PAIS deployment leases can be configured to bound how long a deployment can exist, supporting lifecycle oversight of catalog-deployed AI workloads.

Enabling these observability features, defining retention and alerting policy, and acting on monitoring signals are organizational process responsibilities. PAIS provides the monitoring infrastructure and integration points, but continuous post-deployment monitoring as a practice requires the organization to assign operational ownership, review observability data on an ongoing basis, and respond to anomalies in AI workload behavior.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to proactive and continuous monitoring of deployed AI workloads running on VCF through multiple layers of ongoing network-level security monitoring.

Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workloads evolve. It also monitors infrastructure services to detect newly deployed servers. A classification cron job runs automatically at 2:00 AM local time and repeats every 24 hours, evaluating traffic flows from the preceding 30 days to classify compute entities providing network infrastructure services. When the Recommendations Monitoring feature is enabled, Security Intelligence checks every hour for changes in the scope of monitored entities, allowing policy recommendations to remain current as AI workloads change. The Security Intelligence Flow Insights Dashboard supports detection and display of MITRE ATT&CK framework tactics and techniques, showing counts of detected suspicious events per tactic and technique during a selected time period.

Segmentation Monitoring provides dedicated views for environment-level traffic flows, accessible through the Monitor & Plan interface. Administrators can monitor traffic between configured environment pairs, view flows related to detected infrastructure servers within specified time intervals, and export all unique flows to a CSV file for offline analysis or compliance evidence. The Environments monitoring window provides assessment of current security posture and enables improvement actions for environment pairs. When no protection policy is configured for an environment pair, Segmentation Monitoring offers a Run Recommendations option to generate policy recommendations, closing monitoring gaps around AI workloads.

The Security Services Platform (SSP) collects metrics to monitor the readiness and performance of vDefend IDS/IPS in the environment. IDS/IPS engine statistics accessible per host include uptime, alert count, suppressed alerts, alert queue overflow status, engine ID, and last reload timestamp. IDS/IPS monitoring dashboards can be scoped to custom projects, displaying events triggered for that project only. For bare metal deployments, Bare Metal Agents stream metrics and detailed host-level telemetry to the SSP. The NDR Sensor periodically checks the status of activated features on the SSP every 15 minutes and updates its configuration accordingly.

Intelligent Assist provides AI-assisted analysis within the NSX Manager UI and SSP UI, displaying on the IDS/IPS, Detections, and Campaigns pages to help administrators interpret monitoring data.

Malware Prevention Service provides deployment status monitoring at the cluster level and per-node level, displaying deployment errors and individual transport node status. Network Detection and Response (NDR) applies behavioral analysis to detect suspicious activity targeting monitored workloads and correlates events into campaigns for investigation.

Monitoring AI system functionality at the application layer, including model performance, output quality, and behavioral drift, is outside vDefend's domain.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.2-001

> Conduct regular monitoring of GAI systems and publish reports detailing the performance, feedback received, and improvements made.

**SCF Controls:** AAT-07.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

Continuous improvement of Artificial Intelligence and Autonomous Technologies capabilities is an organizational activity carried out by the teams that build, evaluate, and operate AI workloads. VMware Private AI Services (PAIS) is the AI infrastructure layer of VCF and supplies the platform on which those workloads run; it does not perform the improvement cycle itself. The decision to retrain a model, change a data source, adjust a prompt, or retire a capability is made by the data science, MLOps, and product teams that own the workload, governed by their own internal processes.

PAIS supplies platform mechanisms that workload teams can incorporate into their own improvement cycles. A central model gallery is recommended for managing ML models with consistency across deployment targets. Knowledge bases can be created with linked data sources including Microsoft SharePoint sites and Amazon S3 compatible stores, allowing teams to update the context available to model responses without rebuilding the underlying model. Private AI Services Agent Builder maintains a list of approved tools for use in AI agents when connecting to Model Context Protocol (MCP) servers, giving workload owners a mechanism to add or restrict capabilities over time. PAIS can be installed or updated to later versions independently of the core Supervisor Service, allowing platform-level improvements to ship without a full core update. Controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance, so operations teams can feed platform telemetry into their evaluation loops. These are tools that workload teams use; PAIS does not own the improvement decision.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MG-4.2-002

> Practice and follow incident response plans for addressing the generation of inappropriate or harmful content and adapt processes based on findings to prevent future occurrences. Conduct post-mortem analyses of incidents with relevant AI Actors, to understand the root causes and implement preventive measures.

**SCF Controls:** IRO-04, IRO-13

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control MG-4.3-001**

> Conduct after-action assessments for GAI system incidents to verify incident response and recovery processes are followed and effective, including to follow procedures for communicating incidents to relevant AI Actors and where applicable, relevant legal and regulatory bodies.

**SCF Controls:** IRO-10, IRO-13

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.3-002

> Establish and maintain policies and procedures to record and track GAI system reported errors, near-misses, and negative impacts.

**SCF Controls:** AAT-17

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MG-4.3-003

> Report GAI incidents in compliance with legal and regulatory requirements (e.g., HIPAA breach reporting, e.g., OCR (2023) or NHTSA (2022) autonomous vehicle crash reporting requirements.

**SCF Controls:** CPL-01, IRO-10.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides detection, monitoring, alerting, notification delivery, and investigation capabilities through VCF Operations that support timely identification and reporting of incidents involving sensitive or regulated data. While the organizational process of formally reporting such incidents to regulators, affected individuals, or other stakeholders falls outside the platform's scope, VCF supplies the technical foundation that enables an organization to detect incidents quickly, gather evidence, and route information to the people and systems responsible for response.

VCF Operations event auditing provides visibility into platform interaction changes across the VCF infrastructure and surfaces suspicious access events and policy violations. This capability allows security teams to identify unauthorized or anomalous activity that may indicate a data incident. VCF Operations also provides audit tracking that identifies who made changes to the data center during a specific time range, which is important for establishing the scope and timeline of an incident involving sensitive data.

VCF Operations compliance management continuously monitors infrastructure by evaluating collected data against defined policies. When a compliance alert is triggered on VMware vCenter instances, VMware ESX hosts, virtual machines, distributed port groups, or distributed switches, compliance violations are recorded for investigation. This automated detection of deviations from compliance baselines helps organizations identify potential data-related incidents as they occur rather than discovering them after the fact. Compliance management also highlights risk areas and provides actionable remediation recommendations, supporting the triage process that precedes formal incident reporting.

VCF Operations generates alerts based on configurable thresholds and event definitions. When an alert fires, VCF Operations can deliver notifications through multiple outbound channels: SNMP traps to network management platforms, webhook calls to REST-enabled systems (in JSON or XML format), a ServiceNow plug-in that automatically creates incidents in the ServiceNow ticketing system, a Slack plug-in that forwards alerts to Slack channels with links to alert details, and email. Notification rules let administrators filter which alerts are forwarded and to which endpoints, so that events potentially involving data exposure reach the right teams without delay.

All VCF components support syslog forwarding to external log aggregation and SIEM platforms. vCenter syslog forwarding can be configured through the vCenter Management API, and ESX hosts send syslog feeds through Log Collections configuration. VCF Log Management ingests and indexes these events from across the stack, providing real-time analytics to search and filter logs instantly for troubleshooting or auditing. Users can collect and analyze log feeds, view log-related metrics, and dynamically extract fields from log messages based on customized queries. This centralized log management gives security operations teams the ability to correlate events across the environment.

Accurate log correlation depends on synchronized clocks across all components. The vSphere documentation notes that incorrect time settings in vCenter and ESX hosts make it difficult to inspect and correlate log files to detect attacks and render auditing inaccurate; NTP should be configured on all vCenter instances and ESX hosts so that log timestamps are reliable for incident investigation and reporting.

The Diagnostic Findings feature provides a consolidated view of known product issues, VMSA-based security exposures, and industry best-practice recommendations across the VCF environment. Diagnostic Findings are alerts without notifications that result from a scan of the platform against known issues, logs, and properties. This provides an additional signal that may be relevant during incident triage, helping teams determine whether an observed event is related to a known vulnerability.

For incident tracking and investigation, VCF Operations provides capabilities at multiple levels. The Troubleshooting Incident Page in VCF Network Operations displays information related to incidents, including status, root cause metrics, closing

remarks, and timestamps for when incidents were created. During investigation, analysts can flag metrics and mark root causes, creating a documented trail that supports the incident reporting process. Incident status can be tracked as resolved or unresolved within the platform. VCF Operations also supports scheduled automated reports at regular intervals to track current resources and identify potential risks to the environment, which can feed an organization's incident reporting workflow.

VCF Operations Data and Site Resiliency Monitoring provides centralized visibility into data protection metrics across private clouds, giving organizations awareness of the state of their data protection posture. VCF Automation includes data compliance controls that require explicit consent before exposing user names. This supports organizations that must track access to personally identifiable information.

To satisfy this control fully, organizations must establish incident response procedures that define reporting timelines, designate responsible personnel, identify the authorities and regulators to notify, and specify the content and format of incident reports. VCF provides the detection, correlation, notification delivery, and evidence-gathering layer, but the reporting process itself requires organizational policies, communication channels, and human decision-making.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control MP-1.1-001**

> When identifying intended purposes, consider factors such as internal vs. external use, narrow vs. broad application scope, fine-tuning, and varieties of data sources (e.g., grounding, retrieval-augmented generation).

**SCF Controls:** AAT-03

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-1.1-002

> Determine and document the expected and acceptable GAI system context of use in collaboration with socio-cultural and other domain experts, by assessing: Assumptions and limitations; Direct value to the organization; Intended operational environment and observed usage patterns; Potential positive and negative impacts to individuals, public safety, groups, communities, organizations, democratic institutions, and the physical environment; Social norms and expectations.

**SCF Controls:** AAT-03, AAT-07.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-1.1-003

> Document risk measurement plans to address identified risks. Plans may include, as applicable: Individual and group cognitive biases (e.g., confirmation bias, funding bias, groupthink) for AI Actors involved in the design, implementation, and use of GAI systems; Known past GAI system incidents and failure modes; In-context use and foreseeable misuse, abuse, and off-label use; Over reliance on quantitative metrics and methodologies without sufficient awareness of their limitations in the context(s) of use; Standard measurement and structured human feedback approaches; Anticipated human-AI configurations.

**SCF Controls:** AAT-07, AAT-09

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MP-1.1-004

> Identify and document foreseeable illegal uses or applications of the GAI system that surpass organizational risk tolerances.

**SCF Controls:** AAT-02.1, AAT-09, AAT-27, TDA-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-1.2-001

> Establish and empower interdisciplinary teams that reflect a wide range of capabilities, competencies, demographic groups, domain expertise, educational backgrounds, lived experiences, professions, and skills across the enterprise to inform and conduct risk measurement and management functions.

**SCF Controls:** AAT-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-1.2-002

> Verify that data or benchmarks used in risk measurement, and users, participants, or subjects involved in structured GAI public feedback exercises are representative of diverse in-context user populations.

**SCF Controls:** AAT-11.1, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.1-001

> Establish known assumptions and practices for determining data origin and content lineage, for documentation and evaluation purposes.

**SCF Controls:** AAT-12.1, AAT-12.3, RSK-01.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.1-002

> Institute test and evaluation for data and content flows within the GAI system, including but not limited to, original data sources, data transformations, and decision-making criteria.

**SCF Controls:** AAT-12.1, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

### VMware vDefend (Contributes)

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule

fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.2-001

> Identify and document how the system relies on upstream data sources, including for content provenance, and if it serves as an upstream dependency for other systems.

**SCF Controls:** AAT-12.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.2-002

> Observe and analyze how the GAI system interacts with external networks, and identify any potential for negative externalities, particularly where content provenance might be compromised.

**SCF Controls:** AAT-20.1, NET-05.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several boundary protection mechanisms that help organizations enforce policies prohibiting direct connections between sensitive systems and external networks.

NSX, the networking component of VCF, manages external connectivity through Transit Gateways and Edge nodes. NSX Edge nodes provide north-south traffic connectivity between the physical data center networks and the NSX software-defined networks, serving as the boundary protection devices through which all external traffic must pass. The External Connection configuration defines how a Transit Gateway connects to networks outside NSX and which services are available on that connection. This architecture means that workloads on internal segments do not have direct paths to external networks; all external traffic passes through a defined gateway boundary. Administrators configure external connections through the NSX Manager Networking interface, where distributed and centralized connection types control how traffic reaches outside environments. A gateway CIDR IPv4 address must be explicitly configured to define the route through which traffic is forwarded to any external network, providing a controlled and auditable point of egress. External connections are defined at the infrastructure level and require dedicated Edge node deployment, giving administrators a centralized point of control for outbound connectivity.

For workloads that require outside reachability, VCF uses External IPs with 1:1 NAT to grant access to specific virtual machines on private networks from the external environment. Rather than exposing internal addresses directly, this IP translation mechanism acts as a boundary intermediary. A NAT firewall in this path discards unsolicited requests and data packets, blocking communication attempts that were not initiated from the internal side.

VCF provides network isolation capabilities at multiple layers. Network profiles support isolation using subnets, security groups, and VLAN transport zones. Private network profiles using VLAN transport zones restrict workloads to internal-only connectivity by design, with no external path unless one is explicitly provisioned. In VCF Automation, security groups define isolation settings for on-demand private and outbound networks. Network profiles can be configured with isolation policies so that provisioned workloads on private or outbound networks have controlled, one-way access to upstream networks rather than open bidirectional connectivity. The Tier-1 uplink port IP is added to an isolation security group to enable the data path while maintaining segmentation boundaries. VCF Automation also supports a denylist of internal hosts that restricts connection-testing API access, protecting internal infrastructure from probing through external-facing interfaces. At the vSphere Distributed Switch layer, traffic filtering and marking policies can be applied on distributed ports and uplink ports to deny, allow, or tag specific traffic flows, providing a boundary enforcement capability at the virtual networking infrastructure level independent of NSX policy.

For environments with stringent separation requirements, VCF supports the Workload Separation Distributed Switch Model, which provides physical air-gapped separation of network traffic. This approach uses separate distributed virtual switches so that sensitive workloads have no shared network path with less-trusted traffic, enforcing separation at the virtual infrastructure layer.

VCF Operations includes firewall hardening that restricts network access to its internal services, limiting external exposure of the management platform itself. Service connections are classified as Incoming or Outgoing based on whether a remote process is connected to a listening port, providing visibility into the direction and nature of external communications. VCF Operations for Networks supports FIPS validated cryptographic modules for external connections, and administrators can enable FIPS mode to restrict cryptographic modules used on external connections to FIPS validated implementations only. The vSphere security guidance recommends securing management network access through a bastion host that isolates client



traffic, CLI and API traffic, and third-party software traffic from other network traffic, so that the management plane itself is not directly reachable from external networks.

The organizational policy decision of which systems are sensitive and which boundary protection devices are required is outside VCF's scope. VCF provides the technical mechanisms for boundary enforcement, including gateway-based egress control, NAT-based address translation, network isolation profiles, air-gapped switch models, and management plane hardening, but the prohibition policy itself must be defined and enforced through organizational processes.

#### **VMware vDefend (Contributes)**

VMware vDefend (VMware vDefend) contributes to prohibiting direct connections from sensitive systems to external networks by providing boundary protection mechanisms that operate at both the gateway and workload levels.

The vDefend gateway firewall operates on NSX Edge nodes and enforces stateful firewall rules on all north-south traffic traversing the boundary between VCF-managed workloads and external networks. Because all external connectivity must pass through Edge nodes, the Gateway Firewall acts as an organization-defined boundary protection device where administrators define allow, drop, or reject actions for traffic crossing the perimeter. Stateful rule processing permits only traffic matching approved flows to pass outbound or inbound. In multi-project deployments, Enterprise Administrators can enforce isolation between projects using centralized transit Gateway Firewall rules that deny all inter-project communication except for specified infrastructure protocols such as DHCP, DNS, NTP, and ICMP.

The vDefend distributed firewall (DFW) extends boundary enforcement to the workload level. DFW rules are enforced at the vNIC of each virtual machine, so even if a workload has a network path to an external segment, DFW policy can block that traffic before it leaves the hypervisor. This provides defense in depth: a sensitive workload can be microsegmented so that its only permitted communication is with internal resources, regardless of the routing topology. The Application Connectivity Strategy can be configured to DROP all unsolicited inbound traffic by default, blocking external ingress to an application group. The "Allow Intra, Deny Other Traffic" connectivity strategy generates a specific intra-group ALLOW rule combined with a default ANY/ANY/DROP rule, isolating the group from all external traffic. DFW also supports applying scoped deny rules targeted to specific infrastructure groups via the "Applied-To" field, enabling phased Zero Trust adoption that restricts external access to critical servers. Security Services Platform segmentation monitoring can configure DFW protection rules with Drop or Reject actions to block unknown flows between environment pairs, such as development and production, that should never communicate.

The Security Services Platform's Secure External Communications project identifies workloads with inbound or outbound connections to external IP addresses, providing visibility into boundary protection gaps that administrators can then remediate through DFW policy.

For environments requiring strict isolation, vDefend Advanced Threat Prevention features including IDS, Network Traffic Analysis, and Network Detection and Response can operate in air-gapped environments where internet connectivity is not permitted. Network Detection and Response supports standalone operation without external network access, executing all detection, correlation, and response activities entirely within the closed network.

The organizational determination of which systems are sensitive and the policy decisions about permitted external connections must be established through organizational processes outside vDefend's scope. vDefend provides the enforcement mechanisms at multiple layers, but the prohibition policy itself must be defined by the organization and then implemented through vDefend's rule sets and segmentation capabilities.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) functions as an application-layer boundary protection device for workloads published through it. Virtual Service Network Security Policies evaluate incoming client traffic based on network-level parameters and determine whether a connection should be accepted, discarded, or rate-limited. These policies can block traffic from unauthorized IP addresses by dropping TCP SYN packets before connections are established. When a Network Security Policy rule discards a connection, subsequent HTTP Security, Request, or Response policy evaluation does not occur for that

traffic, stopping further processing at the boundary. Administrators configure Network Security Policies through the Avi Controller UI under the Policies tab of each virtual service or via the CLI `configure networksecuritypolicy` command.

Network Security and HTTP Security policies support IP-based connection control through a Blocklist IP group mechanism. A policy rule that references an IP group named Blocklist discards any connection originating from an address in that group before the request reaches backend pool members. The Avi Controller also exposes a `networksecuritypolicydos` API endpoint with a block action that allows programmatic addition of client IPs to a virtual service's blocked list, supporting automated threat response workflows.

In Kubernetes environments, the Avi Kubernetes Operator (AKO) extends boundary protection to ingress traffic. The `networkSecurityPolicy` setting in an AKO `HostRule` custom resource applies a Network Security Policy to parent virtual services and dedicated virtual services, enforcing connection control at the Kubernetes ingress layer. AKO also supports setting `insecureEdgeTerminationPolicy` to `None` for Secure Routes, which disables insecure edge termination and prevents unprotected connections on routes configured for HTTPS.

Routing all application traffic through the load balancer so that backend servers are not directly reachable from external networks requires network topology and segmentation decisions at the VCF platform level. Avi's documentation explicitly states that Service Engine data plane traffic egressing the Data Plane vNIC is subjected to routing isolation and ACL and firewalling controls present in the external network. VCF network segmentation and vDefend microsegmentation rules are the mechanisms that restrict traffic from bypassing Avi and reaching backend servers directly. Avi's own policy controls operate on traffic already directed to a virtual service listener and do not by themselves control routing paths within the broader network.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.3-001

> Assess the accuracy, quality, reliability, and authenticity of GAI output by comparing it to a set of known ground truth data and by using a variety of evaluation methods (e.g., human oversight and automated evaluation, proven cryptographic techniques, review of content inputs).

**SCF Controls:** AAT-16.5

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) supports domain expert validation through a structured role-based workflow built around a validated-model gallery, container-registry model storage, and approval gates for agent tooling. The platform separates responsibilities so that domain-appropriate experts review AI systems at each stage, with MLOps engineers acting as the designated domain expert for model quality and safety within the PAIS workflow.

MLOps engineers validate ML models onboarded to PAIS against the security, privacy, and technical requirements of the organization before the models are made available for downstream use. Validated models are stored in a Harbor registry that acts as the model storage backend, with authentication and certificate-based trust for retrieval; OCI-compliant registries from other vendors are also supported, including in disconnected environments. A central model gallery is the recommended store for ML models, providing centralized management and consistency across deployment targets, which gives reviewers a single inventory to assess and approve before promotion.

For agent-based AI applications, PAIS requires examination and approval of Model Context Protocol (MCP) server tools and capabilities before they are used in agents, and the Agent Builder maintains a list of approved tools for use when connecting to MCP servers. Deep learning VMs give domain experts hands-on environments to prototype, fine-tune, and validate model behavior before promotion. When deploying completion or embedding model endpoints, A/B testing is recommended so that reviewers can compare candidate models in real-world settings. Catalog items for AI applications provisioned through VCF Automation, together with PAIS observability surfaced in platforms such as Grafana, give reviewers the operational signals needed to validate that AI systems perform consistently after release.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.3-002

> Review and document accuracy, representativeness, relevance, suitability of data used at different stages of AI life cycle.

**SCF Controls:** AAT-10.13

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to post-deployment monitoring of AI workloads through VCF Operations, which provides continuous health, performance, and capacity monitoring for the infrastructure hosting those workloads. VCF Operations dashboards surface CPU, memory, storage, and network metrics for VMs running AI workloads. VCF Log Management aggregates and analyzes log data from VMware vCenter, VMware ESX, and NSX components. vCenter alarms provide threshold-based alerting for infrastructure conditions that could affect AI workload availability.

For AI workloads running as containerized applications on VMware Kubernetes Service (VKS) clusters, the platform extends infrastructure-level observability to the Kubernetes layer. VKS clusters provisioned with the automated-monitoring label automatically receive monitoring configuration on each new node, integrating cluster telemetry with VCF Operations. The Prometheus standard package, installable on VKS clusters through the Supervisor Management Proxy Service, deploys kube-state-metrics, node-exporter, pushgateway, Prometheus, and Alertmanager as components. The prometheus-kube-state-metrics component monitors node status and capacity, ReplicaSet compliance, pod status, job and CronJob status, and resource requests and limits, providing continuous metric collection that can be directed at AI inference services or training job pods. Telegraf is available as a standard package that deploys as a Deployment component to scrape metrics from kube-state-metrics and node-exporter and forward them to external observability backends. Monitoring and alerting for Kubernetes deployments is also available through the Argo CD Supervisor Service using Grafana Operator and Prometheus.

Kubernetes-native health probes and status tracking support workload condition detection at the pod level. Liveness and readiness probes can be configured on AI workload containers to detect unresponsive or overloaded model serving instances; a readiness probe removes the pod from service routing when it cannot handle requests, and a liveness probe triggers a container restart when the application becomes unresponsive. The Kubernetes Deployment controller continuously monitors running application instances and automatically replaces instances when nodes fail or are removed from service, providing a self-healing mechanism that addresses machine failure or maintenance. Kubernetes DeploymentStatus exposes observedGeneration and conditions fields with type, status, lastTransitionTime, and reason values, allowing operators to detect rollout failures, stuck deployments, or configuration drift from the expected specification. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly, and generates Policy Insights when configuration conflicts or environmental errors are detected.

For organizations using Harness CI/CD on VKS, Dynatrace integration provides full-stack observability including application performance monitoring, infrastructure monitoring, and digital experience monitoring. The Dynatrace operator automates deployment, scaling, and maintenance of the monitoring stack within VKS clusters, and automatically correlates application deployment service metrics with underlying VKS infrastructure including nodes, pods, and the network. The Dynatrace AI engine detects anomalies, identifies root causes, and provides intelligent alerts. Harness SRM monitors deployed services post-deployment to calculate a real-time health score based on transaction success and latency.

The VCF Automation Monitor tab provides deployment health information drawn from VCF Operations, and deployment cards in the self-service catalog surface deployment state, last request status, and operational history for workload deployments. AI-specific behavior monitoring (model accuracy drift, output quality) requires application-level tooling outside VCF's scope.

VMware Private AI Services (PAIS) provides AI-specific monitoring mechanisms that support continuous post-deployment observation of AI workloads on VCF.

At the PAIS layer, observability is activated by updating the PAISConfiguration custom resource with parameters that enable metrics collection and forward large language model traces to an OpenTelemetry Collector. PAIS deploys a Prometheus server pod for metrics collection that must be ready and running for observability to function, configured with a chosen storage class and a configurable metrics retention period. PAIS controller pod metrics are integrated into observability

platforms through Telegraf configuration in the Supervisor instance, and the telegraf-user-config ConfigMap in the vmware-system-monitoring namespace manages user-configured monitoring endpoints for PAIS. The PAIS Supervisor Service exposes service-level metrics through pais.vmware.com that VI administrators access to monitor the health of the service.

DevOps engineers visualize PAIS health and performance metrics in observability platforms such as Grafana, where dashboards report pod restart frequency, vGPU licensing status, and idle or underutilized GPU devices in passthrough mode. VI administrators visualize PAIS controller pod operation metrics in VCF Operations using the same metrics pipeline. MLOps engineers and application developers track the health, quality, and behavior of AI applications and the models used in agents through Grafana, supporting continuous observation of inference behavior. Model Endpoint deployment status can be verified using the `kubectl get modelendpoints` command, which returns the Ready status for each deployed endpoint, and the `vcf` cluster command-line interface provides cluster provisioning monitoring, registration, and kubeconfig retrieval for VKS clusters that host AI workloads. PAIS deployment leases can be configured to bound how long a deployment can exist, supporting lifecycle oversight of catalog-deployed AI workloads.

Enabling these observability features, defining retention and alerting policy, and acting on monitoring signals are organizational process responsibilities. PAIS provides the monitoring infrastructure and integration points, but continuous post-deployment monitoring as a practice requires the organization to assign operational ownership, review observability data on an ongoing basis, and respond to anomalies in AI workload behavior.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to proactive and continuous monitoring of deployed AI workloads running on VCF through multiple layers of ongoing network-level security monitoring.

Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workloads evolve. It also monitors infrastructure services to detect newly deployed servers. A classification cron job runs automatically at 2:00 AM local time and repeats every 24 hours, evaluating traffic flows from the preceding 30 days to classify compute entities providing network infrastructure services. When the Recommendations Monitoring feature is enabled, Security Intelligence checks every hour for changes in the scope of monitored entities, allowing policy recommendations to remain current as AI workloads change. The Security Intelligence Flow Insights Dashboard supports detection and display of MITRE ATT&CK framework tactics and techniques, showing counts of detected suspicious events per tactic and technique during a selected time period.

Segmentation Monitoring provides dedicated views for environment-level traffic flows, accessible through the Monitor & Plan interface. Administrators can monitor traffic between configured environment pairs, view flows related to detected infrastructure servers within specified time intervals, and export all unique flows to a CSV file for offline analysis or compliance evidence. The Environments monitoring window provides assessment of current security posture and enables improvement actions for environment pairs. When no protection policy is configured for an environment pair, Segmentation Monitoring offers a Run Recommendations option to generate policy recommendations, closing monitoring gaps around AI workloads.

The Security Services Platform (SSP) collects metrics to monitor the readiness and performance of vDefend IDS/IPS in the environment. IDS/IPS engine statistics accessible per host include uptime, alert count, suppressed alerts, alert queue overflow status, engine ID, and last reload timestamp. IDS/IPS monitoring dashboards can be scoped to custom projects, displaying events triggered for that project only. For bare metal deployments, Bare Metal Agents stream metrics and detailed host-level telemetry to the SSP. The NDR Sensor periodically checks the status of activated features on the SSP every 15 minutes and updates its configuration accordingly.

Intelligent Assist provides AI-assisted analysis within the NSX Manager UI and SSP UI, displaying on the IDS/IPS, Detections, and Campaigns pages to help administrators interpret monitoring data.

Malware Prevention Service provides deployment status monitoring at the cluster level and per-node level, displaying deployment errors and individual transport node status. Network Detection and Response (NDR) applies behavioral analysis to detect suspicious activity targeting monitored workloads and correlates events into campaigns for investigation.

Monitoring AI system functionality at the application layer, including model performance, output quality, and behavioral drift, is outside vDefend's domain.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-2.3-003

> Deploy and document fact-checking techniques to verify the accuracy and veracity of information generated by GAI systems, especially when the information comes from multiple (or unknown) sources.

**SCF Controls:** AAT-26

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides several infrastructure capabilities that support the development and implementation of fact-checking techniques for AI-generated content. The most direct mechanism is the Retrieval-Augmented Generation (RAG) architecture available through PAIS. RAG workloads combine a large language model with an external knowledge base, grounding model responses in organizational data rather than relying solely on the model's training data. Data scientists can build knowledge bases that link to data sources hosted in external content management systems, including Microsoft SharePoint sites and Amazon S3 compatible stores, with a maximum of 10 data sources per knowledge base and each data source bound to a fixed type at creation. PAIS Data Indexing and Retrieval enables automatic collection and indexing of data updates from linked sources over time, which helps keep the grounding data current. This architecture provides a structural approach to improving the accuracy of AI-generated information by anchoring responses to authoritative source material rather than unconstrained generation.

The validate-then-publish workflow for ML models supports pre-deployment testing that can include accuracy verification. MLOps engineers validate ML models against the security, privacy, and technical requirements of their organization before storing them in PAIS. PAIS uses a Harbor registry service in the Supervisor to store validated ML models, with authentication and certificate-based trust required for model retrieval, and OCI-compliant registries from other vendors are also supported. Storing models in a controlled registry provides traceability for which model version was validated and deployed.

Agent Builder in PAIS integrates with Data Indexing and Retrieval to add business data from knowledge bases to agents, allowing teams to build generative AI applications where agent output is informed by curated, access-controlled knowledge bases. Agent Builder also maintains a list of approved tools for use in AI agents when connecting to MCP servers, and available tools are displayed in the tool gallery for namespace-level examination and approval before an agent can call them. MLOps engineers and application developers can monitor the health, quality, and behavior of models used in agents through observability platforms such as Grafana, and PAIS observability can be activated by updating the PAISConfiguration custom resource with metrics and OpenTelemetry trace parameters. The combination of RAG grounding, model validation, approved-tool gating, and observability provides the technical mechanisms organizations need to implement fact-checking techniques, while the specific fact-checking methodologies and acceptance criteria remain the responsibility of the deploying organization.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-2.3-004

> Develop and implement testing techniques to identify GAI produced content (e.g., synthetic media) that might be indistinguishable from human-generated content.

**SCF Controls:** AAT-26.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MP-2.3-005

> Implement plans for GAI systems to undergo regular adversarial testing to identify vulnerabilities and potential manipulation or misuse.

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-3.4-001

> Evaluate whether GAI operators and end-users can accurately understand content lineage and origin.

**SCF Controls:** AAT-12.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-3.4-002

> Adapt existing training programs to include modules on digital content transparency.

**SCF Controls:** SAT-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-3.4-003

> Develop certification programs that test proficiency in managing GAI risks and interpreting content provenance, relevant to specific industry and context.

**SCF Controls:** AAT-01, CPL-01.4, TDA-01.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-3.4-004

> Delineate human proficiency tests from tests of GAI capabilities.

**SCF Controls:** AAT-26.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-3.4-005

> Implement systems to continually monitor and track the outcomes of human-GAI configurations for future refinement and improvements.

**SCF Controls:** AAT-08

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) supports differentiated roles and responsibilities across the AI workload lifecycle through platform-level access controls layered on the VCF identity model. Platform administrators manage infrastructure setup: they deploy infrastructure, configure GPU-accelerated workload domains, and add the PAIS supervisor service to the supervisor before any AI workloads can be deployed. This role controls the foundational infrastructure on which AI operations depend.

Organization administrators control namespace imports and grant permissions for AI catalog items. The organization administrator token is required for API calls that import namespaces into VCF Automation organizations, centralizing oversight of which AI capabilities are exposed. Organization administrators must grant permissions before users can request AI catalog items, providing a gatekeeping function over AI deployments.

DevOps engineers are scoped to project and namespace membership for provisioning GPU-accelerated VMware Kubernetes Service (VKS) clusters and related infrastructure. Data scientists and MLOps engineers provision models and retrieval-augmented generation (RAG) applications through PAIS. The MLOps role carries specific validation responsibilities: MLOps engineers validate ML models against the security, privacy, and technical requirements of the organization before uploading them to the model gallery, including testing inference functionality and evaluating performance and safety against business use cases.

Access to PAIS is authorized through OIDC groups specified in the `authorizedGroups` configuration, tying role enforcement to VCF SSO. Namespace-scoped permissions confine each role's actions to assigned boundaries within the platform.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-3.4-006

> Involve the end-users, practitioners, and operators in GAI system in prototyping and testing activities. Make sure these tests cover various scenarios, such as crisis situations or ethically sensitive contexts.

**SCF Controls:** AAT-26.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-4.1-001

> Conduct periodic monitoring of AI-generated content for privacy risks; address any possible instances of PII or sensitive data exposure.

**SCF Controls:** AAT-10.13, PRI-01.6

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to post-deployment monitoring of AI workloads through VCF Operations, which provides continuous health, performance, and capacity monitoring for the infrastructure hosting those workloads. VCF Operations dashboards surface CPU, memory, storage, and network metrics for VMs running AI workloads. VCF Log Management aggregates and analyzes log data from VMware vCenter, VMware ESX, and NSX components. vCenter alarms provide threshold-based alerting for infrastructure conditions that could affect AI workload availability.

For AI workloads running as containerized applications on VMware Kubernetes Service (VKS) clusters, the platform extends infrastructure-level observability to the Kubernetes layer. VKS clusters provisioned with the automated-monitoring label automatically receive monitoring configuration on each new node, integrating cluster telemetry with VCF Operations. The Prometheus standard package, installable on VKS clusters through the Supervisor Management Proxy Service, deploys kube-state-metrics, node-exporter, pushgateway, Prometheus, and Alertmanager as components. The prometheus-kube-state-metrics component monitors node status and capacity, ReplicaSet compliance, pod status, job and CronJob status, and resource requests and limits, providing continuous metric collection that can be directed at AI inference services or training job pods. Telegraf is available as a standard package that deploys as a Deployment component to scrape metrics from kube-state-metrics and node-exporter and forward them to external observability backends. Monitoring and alerting for Kubernetes deployments is also available through the Argo CD Supervisor Service using Grafana Operator and Prometheus.

Kubernetes-native health probes and status tracking support workload condition detection at the pod level. Liveness and readiness probes can be configured on AI workload containers to detect unresponsive or overloaded model serving instances; a readiness probe removes the pod from service routing when it cannot handle requests, and a liveness probe triggers a container restart when the application becomes unresponsive. The Kubernetes Deployment controller continuously monitors running application instances and automatically replaces instances when nodes fail or are removed from service, providing a self-healing mechanism that addresses machine failure or maintenance. Kubernetes DeploymentStatus exposes observedGeneration and conditions fields with type, status, lastTransitionTime, and reason values, allowing operators to detect rollout failures, stuck deployments, or configuration drift from the expected specification. VKS cluster management proactively monitors the cluster estate to verify that assigned policies are enforced correctly, and generates Policy Insights when configuration conflicts or environmental errors are detected.

For organizations using Harness CI/CD on VKS, Dynatrace integration provides full-stack observability including application performance monitoring, infrastructure monitoring, and digital experience monitoring. The Dynatrace operator automates deployment, scaling, and maintenance of the monitoring stack within VKS clusters, and automatically correlates application deployment service metrics with underlying VKS infrastructure including nodes, pods, and the network. The Dynatrace AI engine detects anomalies, identifies root causes, and provides intelligent alerts. Harness SRM monitors deployed services post-deployment to calculate a real-time health score based on transaction success and latency.

The VCF Automation Monitor tab provides deployment health information drawn from VCF Operations, and deployment cards in the self-service catalog surface deployment state, last request status, and operational history for workload deployments. AI-specific behavior monitoring (model accuracy drift, output quality) requires application-level tooling outside VCF's scope.

VMware Private AI Services (PAIS) provides AI-specific monitoring mechanisms that support continuous post-deployment observation of AI workloads on VCF.

At the PAIS layer, observability is activated by updating the PAISConfiguration custom resource with parameters that enable metrics collection and forward large language model traces to an OpenTelemetry Collector. PAIS deploys a Prometheus server pod for metrics collection that must be ready and running for observability to function, configured with a chosen



storage class and a configurable metrics retention period. PAIS controller pod metrics are integrated into observability platforms through Telegraf configuration in the Supervisor instance, and the telegraf-user-config ConfigMap in the vmware-system-monitoring namespace manages user-configured monitoring endpoints for PAIS. The PAIS Supervisor Service exposes service-level metrics through `pais.vmware.com` that VI administrators access to monitor the health of the service.

DevOps engineers visualize PAIS health and performance metrics in observability platforms such as Grafana, where dashboards report pod restart frequency, vGPU licensing status, and idle or underutilized GPU devices in passthrough mode. VI administrators visualize PAIS controller pod operation metrics in VCF Operations using the same metrics pipeline. MLOps engineers and application developers track the health, quality, and behavior of AI applications and the models used in agents through Grafana, supporting continuous observation of inference behavior. Model Endpoint deployment status can be verified using the `kubectl get modelendpoints` command, which returns the Ready status for each deployed endpoint, and the `vcf` cluster command-line interface provides cluster provisioning monitoring, registration, and kubeconfig retrieval for VKS clusters that host AI workloads. PAIS deployment leases can be configured to bound how long a deployment can exist, supporting lifecycle oversight of catalog-deployed AI workloads.

Enabling these observability features, defining retention and alerting policy, and acting on monitoring signals are organizational process responsibilities. PAIS provides the monitoring infrastructure and integration points, but continuous post-deployment monitoring as a practice requires the organization to assign operational ownership, review observability data on an ongoing basis, and respond to anomalies in AI workload behavior.

### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to proactive and continuous monitoring of deployed AI workloads running on VCF through multiple layers of ongoing network-level security monitoring.

Security Intelligence continuously monitors for new flows between environments and alerts administrators to unauthorized or unexpected traffic, enabling ongoing policy adjustments as workloads evolve. It also monitors infrastructure services to detect newly deployed servers. A classification cron job runs automatically at 2:00 AM local time and repeats every 24 hours, evaluating traffic flows from the preceding 30 days to classify compute entities providing network infrastructure services. When the Recommendations Monitoring feature is enabled, Security Intelligence checks every hour for changes in the scope of monitored entities, allowing policy recommendations to remain current as AI workloads change. The Security Intelligence Flow Insights Dashboard supports detection and display of MITRE ATT&CK framework tactics and techniques, showing counts of detected suspicious events per tactic and technique during a selected time period.

Segmentation Monitoring provides dedicated views for environment-level traffic flows, accessible through the Monitor & Plan interface. Administrators can monitor traffic between configured environment pairs, view flows related to detected infrastructure servers within specified time intervals, and export all unique flows to a CSV file for offline analysis or compliance evidence. The Environments monitoring window provides assessment of current security posture and enables improvement actions for environment pairs. When no protection policy is configured for an environment pair, Segmentation Monitoring offers a Run Recommendations option to generate policy recommendations, closing monitoring gaps around AI workloads.

The Security Services Platform (SSP) collects metrics to monitor the readiness and performance of vDefend IDS/IPS in the environment. IDS/IPS engine statistics accessible per host include uptime, alert count, suppressed alerts, alert queue overflow status, engine ID, and last reload timestamp. IDS/IPS monitoring dashboards can be scoped to custom projects, displaying events triggered for that project only. For bare metal deployments, Bare Metal Agents stream metrics and detailed host-level telemetry to the SSP. The NDR Sensor periodically checks the status of activated features on the SSP every 15 minutes and updates its configuration accordingly.

Intelligent Assist provides AI-assisted analysis within the NSX Manager UI and SSP UI, displaying on the IDS/IPS, Detections, and Campaigns pages to help administrators interpret monitoring data.

Malware Prevention Service provides deployment status monitoring at the cluster level and per-node level, displaying deployment errors and individual transport node status. Network Detection and Response (NDR) applies behavioral analysis to detect suspicious activity targeting monitored workloads and correlates events into campaigns for investigation.

Monitoring AI system functionality at the application layer, including model performance, output quality, and behavioral drift, is outside vDefend's domain.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides application-layer logical security mechanisms that help protect traffic carrying personal data. At the transport layer, Avi supports SSL/TLS termination with certificate management, securing connections between clients and the application proxy and helping protect sensitive data from unauthorized interception or modification in transit (CLI Access Settings > Certificates). For Kubernetes workloads, the Avi Kubernetes Operator (AKO) supports PKIProfile configuration, which enables secure communication with backend services through certificate-based authentication and encryption (Designing and Deploying AKO > Setting up Routing Rules using CRDs > PKIProfile).

For application logging, the Avi Analytics Profile supports the creation of a sensitive log profile that governs how sensitive data is handled within client-side logs (Load Balancing > Analytics Profile > Client Log). Administrators can configure which fields are captured in client logs to limit inadvertent recording of personal data transmitted through applications. TLS persistence data, used to maintain session affinity across Service Engines, is stored in an encrypted format that a Service Engine can read if a client reconnects to a different Service Engine, reducing exposure of session-bound data throughout the persistence lifetime (Load Balancing > Persistence > TLS Persistence).

Client access to applications can be controlled through authentication profiles. Avi supports LDAP Authentication Profiles configurable with LDAPS for encrypted directory connections, validating user identities against a directory service before granting access to application resources (User Authentication and Authorization > Authentication Profile > LDAP Authentication Profile). Avi also supports OAuth 2.0 and OpenID Connect (OIDC) for secure delegated client authentication, enabling identity providers to issue tokens to third-party applications without exposing user credentials directly (Security > Client Authentication > OAuth and OIDC).

Multi-tenant data plane isolation depends on context configuration. When Tenant Context is used, Avi provides both control plane and data plane isolation, scoping application traffic to designated tenant resources and supporting multi-tenant deployments where each tenant's traffic remains separated. When Provider Context is used, only control plane isolation is provided; organizations requiring full data plane separation should configure Tenant Context accordingly (Tenant Settings > Tenants Versus SE Group Isolation).

Health monitor probes in secure environments should use encrypted credentials; Avi supports reconfiguring existing health monitors from plaintext credentials to encrypted form when encrypted authentication is required (Load Balancing > Health Monitoring > HTTP Health Monitor). For deployments with stringent cryptographic requirements, Avi supports FIPS 140-3 compliance, which requires stricter handling of keys, authentication data, and random number generation to help protect sensitive security parameters (FIPS Compliance in Avi Load Balancer > FIPS 140-3 Compliance). For Avi Controller deployments automated via Ansible, Ansible Vault can be used to securely store sensitive variables such as passwords and API tokens, reducing the risk of credential exposure during automated provisioning (Automation Tools Overview > Ansible).

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-4.1-002

> Implement processes for responding to potential intellectual property infringement claims or other rights.

**SCF Controls:** AAT-12

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-4.1-003

> Connect new GAI policies, procedures, and processes to existing model, data, software development, and IT governance and to legal, compliance, and risk management activities.

**SCF Controls:** AAT-01, TDA-22

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-4.1-004

> Document training data curation policies, to the extent possible and according to applicable laws and policies.

**SCF Controls:** AAT-16.7

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides mechanisms for validating the source and quality of pre-trained models before they enter the deployment pipeline. Models must be downloaded into a Deep Learning VM from trusted sources such as the NVIDIA NGC catalog, Hugging Face, or another model hub before validation. Inside the Deep Learning VM, the validation workflow performs integrity verification through hash code checking, malware scanning, serialization attack scanning, and inference testing with the Triton Inference Server. MLOps engineers validate onboarded models against the security, privacy, and technical requirements of the organization, and the documentation recommends distributing internally validated models from a central gallery rather than pulling models directly from the internet, which can carry malicious code or be tuned for malicious behavior.

After validation, models are uploaded to the PAIS Model Gallery, which stores ML models that can be referenced by URL for deployment on CPU or GPU infrastructure. The Model Gallery sits behind a Harbor registry service running in the Supervisor and supports OCI-compliant registries from other vendors for connected and disconnected environments. Access to the Harbor registry requires authentication and certificate-based trust for model retrieval, which restricts access to the validated model store. The `vcf pais` commands support automated CI/CD upload of validated models for MLOps pipelines and provide a consistent mechanism for promoting models from validation to publication.

PAIS Model Runtime serves validated models as Model Endpoints paired with inference engines such as vLLM, llama.cpp, or Infinity, and the endpoints are reachable through the PAIS REST API or through agents in Agent Builder in VCF Automation. The guidance recommends A/B testing between embedding models in real-world settings to compare performance, and MLOps engineers and application developers can perform monitoring and diagnostics through observability platforms such as Grafana to track the health, quality, and behavior of AI applications running on PAIS, supporting ongoing quality validation after a model has been admitted to production.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control MP-4.1-005**

> Establish policies for collection, retention, and minimum quality of data, in consideration of the following risks: Disclosure of inappropriate CBRN information; Use of Illegal or dangerous content; Offensive cyber capabilities; Training data imbalances that could give rise to harmful biases; Leak of personally identifiable information, including facial likenesses of individuals.

**SCF Controls:** AAT-01, AAT-10.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-4.1-006

> Implement policies and practices defining how third-party intellectual property and training data will be used, stored, and protected.

**SCF Controls:** AAT-12, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to protecting the integrity of data sources used by AI workloads through storage-level encryption and access controls. vSAN encryption at rest and VM encryption protect AI training data stored on VCF infrastructure from unauthorized access at the storage layer. VMware vCenter RBAC restricts who can access or modify VMs containing AI data. Storage policies control datastore placement and encryption properties for AI workload VMs.

At the Consumption layer, VMware Kubernetes Service (VKS) on vSphere Supervisor extends these protections to containerized AI workloads. Harbor, available both as a Supervisor Service and as a standard package on VKS clusters, is the private container image registry, with images organized by vSphere Namespace. Harbor scans images for known vulnerabilities, enforces content trust so that only signed and verified artifacts are trusted, applies role-based access control to restrict which principals can push or overwrite model artifacts and pipeline images, and uses policy-based replication to control how artifacts move between registries. After Harbor is integrated with the Supervisor, all VKS clusters on the same Supervisor automatically trust it as a source of verified images.

Kubernetes admission controllers, including ValidatingAdmissionPolicy and validating webhook controllers, can be configured on VKS clusters to enforce requirements before workloads are admitted. Relevant policies include restricting image pulls to the trusted Harbor registry, requiring that images carry a valid signature, and blocking workloads that reference unscanned or unapproved artifacts. These controls reduce the risk that a workload carrying corrupted or tampered data processing logic reaches AI training data.

GitOps workflows, supported through the Argo CD Supervisor Service, store all workload and infrastructure configuration declaratively in a Git repository as the single source of truth. Every change to the deployed state flows through Git, creating a durable record of every authorized modification. Immutable infrastructure patterns complement this approach by making unauthorized changes identifiable through drift detection between actual cluster state and the declared configuration.

Kubernetes RBAC restricts which users and service accounts can read from or write to data volumes, ConfigMaps, and Secrets within VKS clusters. Supervisor namespace isolation with resource quotas contains workloads within defined boundaries, reducing the risk that one tenant can access or alter another tenant's data. Antrea-based network policies define namespace-level ingress and egress rules, scoping the network access surface for storage components that hold AI training data or inference inputs.

CSI Volume Snapshots for VKS clusters support crash-consistent backups with deduplication, compression, and encryption. The ability to restore from a known-good snapshot provides a recovery path when data corruption is detected. The VCF CLI binary, used to interact with VCF Services consumption, publishes a sha256sum.txt checksum file alongside each download so that administrators can verify the binary's integrity before use.

Validating the provenance and accuracy of AI training data at the application level is outside VCF's scope. Data poisoning detection, training data lineage, and AI-specific data provenance tracking require application-layer tooling or AI platform components built on top of the VCF platform.

VMware Private AI Services (PAIS) provides integrity controls for both model artifacts and data sources used by AI workloads. Model revisions in the Model Gallery use Harbor as a storage backend, and each push of the same model receives a unique digest so that successive revisions are content-addressed and distinguishable. Before upload, model files should be validated for integrity by checking hash codes, scanned for malware and serialization attacks, and tested for correct inference behavior using Triton Inference Server as part of the sandbox validation process in a Deep Learning VM. This pre-upload validation

provides cryptographic verification and behavioral testing that helps prevent contaminated or tampered model data from entering production.

The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models. Harbor integration requires authentication and certificate-based trust for model retrieval, and PAIS requires CA trust bundles to be imported for the Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, and MCP servers providing tools for agents. These access controls and verified chains of trust restrict unauthorized modification of model and data artifacts. The documentation recommends using the Model Gallery to reduce redundant copies of models and maintain model integrity in a controlled environment.

For knowledge base data sources used by retrieval-augmented generation, PAIS Data Indexing and Retrieval enables automatic collection and indexing of data updates from linked data sources over time, supporting external content management systems such as Microsoft SharePoint and Amazon S3 compatible stores. Each knowledge base data source is created with a specific type that cannot be changed after creation, which helps prevent silent reconfiguration of the underlying source provider. The content management system used as a data source must be supported, and valid credentials are required for access to the content location. SharePoint data sources require user name and password authentication, and service account key file data sources require the information from the service account key file during data source creation. PAIS uses a CA trust bundle for secure communication with external services and databases, establishing verified transport between PAIS and its data sources.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.





## Control MP-4.1-007

> Re-evaluate models that were fine-tuned or enhanced on top of third-party models.

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-4.1-008

> Re-evaluate risks when adapting GAI models to new domains. Additionally, establish warning systems to determine if a GAI system is being used in a new domain where previous assumptions (relating to context of use or mapped risks such as security, and safety) may no longer hold.

**SCF Controls:** AAT-07.2, AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-4.1-009

> Leverage approaches to detect the presence of PII or sensitive data in generated output text, image, video, or audio.

**SCF Controls:** AAT-23, AAT-27, SEA-09

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several mechanisms across its management, automation, and lifecycle components that contribute to information output filtering and validation, though the control's full scope requires organizational processes beyond what the platform delivers on its own.

VCF Operations includes output filtering capabilities in its dashboard and widget framework. The Output Filter section available across widget types, including the Alert List Widget, Environment Status Widget, Health Widget, Object Relationship Widget, Geo Widget, Scoreboard Widget, Rolling View Chart Widget, Weather Map Widget, and Property List Widget, restricts the data displayed based on selected filter criteria. Advanced output filter options further refine widget data by object type, allowing administrators to control which information is presented and confirm that displayed data aligns with expected content. Tag-based output filtering provides an additional dimension for refining widget data, where multiple values for the same tag include objects with any of those tags applied, and multiple values for different tags include only objects with all tags applied. Views in VCF Operations support multiple criteria sets that enable complex filtering logic, giving operators granular control over how operational data is surfaced.

VCF Operations orchestrator provides a workflow validation tool that identifies errors in workflows and verifies that data flows correctly from one element to the next. Validation elements within orchestrator workflows can be configured to execute external validation actions, returning an error string when validation fails or allowing the workflow to continue when output is consistent with expectations. The input form designer can validate workflow inputs using external actions that execute action scripts and return error messages when input parameter values are invalid. This programmatic validation capability allows organizations to build automated output checks into their operational workflows.

VCF Automation extends output validation to catalog request forms and custom forms. The custom form designer supports data validation by adding constraints to form fields, restricting what values can be submitted. External validations can be attached to catalog request forms, running VCF Operations orchestrator action scripts when a user submits a request from either the UI or the API. These validations check that form data meets defined criteria before the request proceeds. A content validation interface in VCF Automation identifies custom forms containing actions that cannot be validated, helping administrators identify gaps in their validation coverage. Approval policies can be configured so that project administrators review all changes to deployed catalog instances before they take effect, providing a human review layer for output that affects shared resources.

Configuration validation within vCenter examines configuration files for errors and conflicts, returning output that helps administrators avoid loading incorrect or conflicting configurations. The VCF Automation API supports the `$filter` query option to filter API results by predicate expressions using operators including equality (eq), inequality (ne), and logical connectives (and, or), providing programmatic output filtering at the API layer. The vSphere TaskInfo object enables client applications to monitor task completion status and handle errors when tasks do not complete successfully, offering a feedback mechanism for verifying that operations produce expected results. ESX supports configurable log output filtering through the ``logRegexp`` parameter, a Python regular expression that identifies log messages to suppress, alongside ``numLogs``, which controls how many matching messages are permitted before filtering begins.

vSphere Lifecycle Manager validates software specifications before they are applied. The Image Manager component runs a validation check before a draft software specification is saved to the database, and administrators can validate the compliance of hosts in a cluster or standalone hosts against the desired state before applying changes. The Compliance interface compares the desired state against the current state of each host and calculates compliance, helping ensure that the software configuration output matches what was intended. vCenter also performs an automatic checksum check on all software

manually imported into the vSphere Lifecycle Manager depot and verifies the SHA-256 checksum of downloaded software before it is applied.

These platform-level validation and filtering mechanisms support the control objective. Organizational processes are needed to define validation criteria and review procedures specific to the applications running on VCF, establish acceptance thresholds for output data, and maintain the approval workflows that govern changes to shared resources.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer operates as the application proxy layer for workloads running on VCF and provides application-layer mechanisms for inspecting and validating HTTP response content as traffic passes through the Service Engine.

The DataScript scripting engine is the primary Avi-native mechanism for output inspection and conditional validation. DataScript runs at the proxy boundary and provides an external request validation API that returns a response object containing the HTTP response status code, headers table, and HTTP response body (p.3658). Operators can write DataScript policies that inspect this response content against expected patterns and take conditional action on responses that deviate from expectations, including modifying headers, rewriting content, or terminating connections. DataScript also provides certificate-level validation functions: `avi.ssl.check_client_cert_validity()` enables enforcement of certificate presentation and validity checks in virtual service policies (p.3600), and `avi.ssl.clear_client_cert_verify_error` supports conditional handling of verification errors based on error code evaluation, such as clearing errors when a CRL has expired (p.3605). These functions support inspection and conditional response handling beyond HTTP-layer content.

The Avi WAF Positive Security Model, also called Application Specific Policy, describes expected application behavior and validates inputs by setting an accepted range and length of characters, reporting a policy violation when input falls outside those bounds (p.3535). This positive security approach constrains what output an application can produce by defining what the application is permitted to accept and process, helping identify deviations from expected content patterns.

Avi generates per-virtual-service Application Security Reports in PDF format, documenting application security findings and pre-check validation results (p.3481). Reports are visible on the Reports page of the Controller UI and can be downloaded for external review. This provides operators with a structured artifact for assessing whether application output behavior is consistent with security expectations.

The Avi Kubernetes Operator (AKO) performs syntactical validations at the time of Custom Resource Definition (CRD) object creation to verify configuration correctness and provides effective status messages (p.83, [avi-kubernetes-operator-2-1.pdf](#)). This supports output consistency validation for Kubernetes-native Avi configurations.

The Controller API supports response field filtering through the `fields query` parameter, which restricts API responses to specified fields and reduces information returned to only what is relevant (p.4296). Query parameter-based filtering is available for targeted operations on specific resource subsets (p.4295). Application logs on each Service Engine support filtering using free-form text, keywords, or formal search syntax with field-based filtering using equality operators (p.4109, p.4121), enabling focused review of application output behavior.

Coverage is Contributes because, while Avi provides the proxy-level inspection, WAF validation, and reporting infrastructure, organizations must define what constitutes expected output for each protected application, author the DataScript policies and WAF rules that encode those expectations, and establish a review schedule for Application Security Reports.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MP-4.1-010

> Conduct appropriate diligence on training data use to assess intellectual property, and privacy, risks, including to examine whether use of proprietary or sensitive training data is consistent with applicable laws.

**SCF Controls:** AAT-12, TDA-22

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-5.1-001

> Apply TEVV practices for content provenance (e.g., probing a system's synthetic data generation capabilities for potential misuse or vulnerabilities).

**SCF Controls:** AAT-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-5.1-002

> Identify potential content provenance harms of GAI, such as misinformation or disinformation, deepfakes, including NCII, or tampered content. Enumerate and rank risks based on their likelihood and potential impact, and determine how well provenance solutions address specific risks and/or harms.

**SCF Controls:** AAT-07, AAT-07.2, AAT-10.17, AAT-12.1, AAT-12.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



### Control MP-5.1-003

> Consider disclosing use of GAI to end users in relevant contexts, while considering the objective of disclosure, the context of use, the likelihood and magnitude of the risk posed, the audience of the disclosure, as well as the frequency of the disclosures.

**SCF Controls:** AAT-22.7, AAT-22.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

#### **Control MP-5.1-004**

> Prioritize GAI structured public feedback processes based on risk assessment estimates.

**SCF Controls:** AAT-11, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-5.1-005

> Conduct adversarial role-playing exercises, GAI red-teaming, or chaos testing to identify anomalous or unforeseen failure modes.

**SCF Controls:** VPM-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-5.1-006

> Profile threats and negative impacts arising from GAI systems interacting with, manipulating, or generating content, and outlining known and potential vulnerabilities and the likelihood of their occurrence.

**SCF Controls:** AAT-07.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-5.2-001

> Determine context-based measures to identify if new impacts are present due to the GAI system, including regular engagements with downstream AI Actors to identify and quantify new contexts of unanticipated impacts of GAI systems.

**SCF Controls:** AAT-07.1, AAT-07.2, AAT-18

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MP-5.2-002

> Plan regular engagements with AI Actors responsible for inputs to GAI systems, including third-party data and algorithms, to review and evaluate unanticipated impacts.

**SCF Controls:** AAT-07.1, AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.1-001

> Employ methods to trace the origin and modifications of digital content.

**SCF Controls:** AAT-12.4

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to logging modifications to digital content through vCenter event logging that records VM-level operations (creation, modification, deletion, snapshot, migration) and VCF Log Management that aggregates these events for analysis. Changes to VMs hosting AI workloads or their associated storage are captured in vCenter's event stream with timestamps and user attribution through VCF SSO.

For AI and autonomous technology workloads deployed on VMware Kubernetes Service (VKS) within the VCF Consumption layer, the Kubernetes API server includes a configurable audit subsystem that records all API requests representing content modifications, including create, update, patch, and delete operations. Audit events follow the structure defined by the audit.k8s.io API group, capturing the audit level, a unique audit ID, requesting user, timestamp, and affected resource. Administrators configure audit behavior through an audit policy that determines what events are recorded and at what level of detail. Four audit levels are available: None (matching events are not logged), Metadata (logs request metadata including requesting user, timestamp, and resource), Request (logs metadata and request body), and RequestResponse (logs metadata, request body, and response body). When the `--audit-log-path` flag is omitted from the kube-apiserver configuration, no events are logged; the flag must be set explicitly to activate audit recording and direct logs to the appropriate file path. Audit event truncation is disabled by default and requires explicit enablement through separate API server flags. The Supervisor can also be configured to preserve the source IP addresses of authentication and Kubernetes API server requests, making those addresses available for attribution in audit logs. This configurability allows organizations to capture the full content of modifications to Kubernetes resources used by AI workloads, including ConfigMaps, Secrets, Deployments, and custom resources.

VKS clusters on Supervisor include Fluent Bit logging agents deployed in the `vmware-system-logging` namespace. Fluent Bit processes and tags Kubernetes API server audit logs separately from container logs and Linux daemon logs, enabling targeted forwarding of audit streams to external log management systems. Supported destinations include Syslog, HTTP, Elasticsearch, Kafka, and Splunk logging servers, as well as VCF Log Management using a configurable values file. On the Supervisor control plane, Fluent Bit collects kube-apiserver audit logs from `/var/log/vmware/audit/kube-apiserver.log` using the tag `audit.apiserver.*`, with records buffered locally in `/var/log/vmware/fluentbit/flb_audit_apiserver` before forwarding. The kube-apiserver exposes the `apiserver_audit_event_total` Prometheus metric to allow continuous monitoring of the total audit events exported. A second metric, `apiserver_audit_level_total`, tracks audit events by policy level with one counter increment per request.

For workloads running as vSphere Pods in vSphere Namespaces, the LogAgentConfiguration Custom Resource configures log streaming to a remote Syslog server. Syslog messages from vSphere Pods include metadata fields covering namespace name, pod UID, pod name, container name, and ESX host name, enabling attribution of events to specific workloads and infrastructure components.

For AI workloads where syscall-level modification auditing is needed, Kubernetes seccomp audit profiles can be configured in a pod's security context. The `audit.json` seccomp profile logs all system calls of a process without restricting any calls, directing records to syslog or auditd via `SCMP_ACT_LOG`. VKS clusters also generate component logs from CAPI, CAPV, VM Operator, and VKS Controller Manager, with VM Operator specifically recording reconciliation events for VirtualMachineService resources that reflect changes to workload infrastructure.

Logging modifications to AI model content or training data at the application level requires AI-specific tooling beyond what the VCF platform provides.

VMware Private AI Services (PAIS) provides content modification logging for AI knowledge base operations and for model artifacts. During knowledge base indexing, PAIS knowledge base operations track document-level changes including crawled

documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. This document-level change record produces an audit trail of what content was added, modified, or removed from the knowledge base that feeds retrieval-augmented generation agents. Knowledge base operations also capture size metrics such as total megabytes downloaded, number of new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents, along with timing metrics for file download, embedding generation, and overall index operation duration.

For model artifacts, each push to the Model Gallery creates a new model revision stored as an immutable OCI artifact identified by content digest, with deduplication so that identical model data pushed multiple times results in only one stored revision. The Model Gallery assigns a unique digest to each revision when the same model is pushed multiple times, supporting integrity verification of model content over time. Revisions can be tagged, supporting human-readable identification of model changes alongside the digest.

PAIS observability extends content-modification visibility through OpenTelemetry. The PAISConfiguration custom resource exposes a `spec.observability.llmTraces` section and an optional Prometheus metrics section that can be activated to send LLM traces and metrics for agent execution flow and knowledge base indexing to an OpenTelemetry Collector with configurable storage class and metrics retention period. PAIS Controller metrics are exposed at a Prometheus endpoint on the `pais-controller-manager` service for collection by monitoring systems, and Deep Learning VMs expose vGPU performance metrics through Prometheus. The vLLM inference server logging level is controlled by the `VLLM_LOGGING_LEVEL` environment variable, and per-pod logs for model endpoints can be retrieved with `kubectl` in the `pais` namespace. Deep Learning VMs record cloud-init script logs in `/var/log/dl.log` and GPU driver installation logs in `/var/log/gpu-install.log`.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MS-1.1-002

> Integrate tools designed to analyze content provenance and detect data anomalies, verify the authenticity of digital signatures, and identify patterns associated with misinformation or manipulation.

**SCF Controls:** AAT-10.17, AAT-26, MON-16

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several capabilities that contribute to anomalous behavior detection and user activity monitoring, though it does not include a dedicated User & Entity Behavior Analytics (UEBA) or User Activity Monitoring (UAM) solution.

VCF Operations includes anomaly detection capabilities that use both dynamic and static thresholds to identify when metrics deviate from normal operating behavior. Dynamic thresholding is enabled by default and uses historical data analysis to establish baselines for each monitored object. The Smart Early Warning feature analyzes the number of applicable metrics that violate the dynamic threshold determining normal operating behavior, triggering alerts when the number of anomalies on an object exceeds a trending threshold. When an anomalous entity is detected, VCF Operations generates an outlier violation alert (vmwAnalyticsOutlierEvent, OID 37002), notifying administrators of unexpected behavior. A Critical threshold violation alert is also generated when anomalous entities are detected.

The Anomalies widget displays detected anomalies for a resource over the past six hours at configurable time intervals, with color-coded criticality indicators. The Anomaly Breakdown widget shows likely root causes for symptoms on a selected resource, helping operators triage issues. The Troubleshooting Workbench includes an Anomalous Metrics card that surfaces metrics exhibiting drastic changes within a selected scope and time window, ranked by degree of change with the most recent anomaly given the highest weighting. Administrators can also examine outlier VMs detected by VCF Operations to identify unexpected behavior and take corrective actions. VCF Operations supports outbound SNMP trap notifications, enabling alert delivery to external SNMP management systems with up to four configurable trap destinations.

For user activity monitoring, VCF Operations provides a User Activity Audit report that offers traceability of user actions including logging in, operations on clusters and nodes, changes to system passwords, certificate activation, and logging out. Each audit event has a detailed view containing information that supports analysis of events in the virtual infrastructure for suspicious user actions or system issues. Event auditing across the VCF platform provides visibility into platform interaction changes and surfaces suspicious access events and policy violations. Administrators should continuously monitor user security aspects to detect security risks early and respond to potential threats. VCF SSO maintains a dedicated audit log that captures user management events, including account creation, modification, deletion, and activation or deactivation, as well as changes to account credentials and profile information. The vSphere Client's Advanced Export feature allows administrators to export tasks performed by a specific user during a specified time range, providing targeted audit data for investigating suspicious activity.

Audit logging extends across VCF components. NSX Manager generates audit log messages that record user operations with fields for UserName, ModuleName, Operation, and Operation status, along with detailed resource change information and timestamps. NSX Manager audit logs also record failed login attempts with username and timestamp information, enabling tracking of access patterns across the environment. VCF Operations for Networks captures audit logs of administrative actions, including CRUD operations and login/logout events.

VCF Operations supports forwarding user activity audit logs to an external syslog server, enabling integration with dedicated SIEM or UEBA platforms for broader correlation and behavioral analysis. VCF Log Management includes content packs that offer pre-built dashboards, alerts, and queries for VCF components. These content packs support security monitoring use cases such as tracking failed login attempts and privilege escalations.

VCF's built-in anomaly detection is primarily oriented toward infrastructure metrics and operational health rather than user behavior profiling. A dedicated UEBA or UAM solution consuming VCF's audit data would be needed to establish user behavior baselines, detect credential compromise through behavioral deviation, and provide the full scope of analytics this

control requires. For organizations requiring deeper behavioral analysis, VMware vDefend extends VCF's monitoring foundation with IDS/IPS, network traffic inspection, and threat intelligence integration.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides application-layer anomaly detection mechanisms that contribute to meeting this control. The Anomalies Overlay feature, available in Virtual Service Analytics, Service Engine Analytics, and Pool Analytics, flags statistical deviations in traffic metrics as anomaly events when a specific metric deviates from the historical norm by more than four sigma during the anomaly period. Monitored metrics include CPU utilization, bandwidth, disk I/O, server response time, and connection rates. Each anomaly event is identified by entity name, entity type (Virtual Machine, Virtual Service, or Service Engine), and metric value, with a timestamp indicating when the deviation occurred. Anomaly detection operates against a moving-average baseline calculated from recent historical traffic. The Pool Anomalies Overlay also displays prediction interval upper and lower bounds alongside the anomalous value. Administrators can adjust detection granularity by changing the statistics time interval, and can configure alert filter sensitivity to tune the threshold for new alert generation. Note that anomaly recording is disabled when the statistics interval is set to Real Time; a non-real-time statistics interval is required for anomaly capture to function.

The Bot Management module adds a behavioral detection layer focused on credential stuffing and web attack patterns at the application proxy boundary. Bot Management detects malicious bots responsible for online fraud and credential stuffing attacks. The IP Reputation service extends detection by maintaining a database of categorized IP addresses and identifying anomalous traffic patterns, including DoS and DDoS activity and anomalous SYN floods.

For authentication-related anomalous behavior, Avi provides the `AUDIT_COMPLIANCE_EVENT` mechanism to log authentication failures for audit purposes, persisting them via the alerts infrastructure. The Web Application Firewall (WAF) App Log Analytics component captures events whenever a WAF application rule is triggered, recording the type of attack detected. Service Engines generate `DOS_ATTACK` alert events that include attack type, source IP addresses, virtual service UUID and name, and a report timestamp, supporting audit and forensic analysis of detected attacks. Avi also supports DataScripts for custom identification of suspicious traffic and execution of appropriate mitigation actions, enabling organizations to define custom behavioral detection logic beyond the built-in statistical baselines.

Avi monitors over 500 real-time metrics to support DDoS detection and attack visibility. Alerts from any of these mechanisms can be forwarded proactively to email, syslog, SNMP, or custom APIs, enabling integration with a central SIEM or security operations platform. Avi integrates with Splunk via the Avi Load Balancer Splunk Add-on, generating events that serve as an audit trail for user logins, configuration changes, and runtime state changes.

These capabilities operate at the application delivery and load balancing layer. An organization requires a dedicated UEBA or UAM platform to fulfill the full scope of this control, including identity-level behavioral baselines, user session correlation, and cross-system entity analytics that extend beyond application traffic visible to Avi.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.1-003

> Disaggregate evaluation metrics by demographic factors to identify any discrepancies in how content provenance mechanisms work across diverse populations.

**SCF Controls:** AAT-10.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides specific, documentable tools for AI TEVV activities. Deep learning VMs are the primary validation environment, provisioned from PAIS images with pre-installed software stacks validated for running AI applications on NVIDIA GPUs. DL VMs support prototyping, fine-tuning, validation, and inference workloads in a single environment.

The Triton Inference Server is the documented tool for model inference validation. Models are tested for inference functionality using Triton and evaluated for performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. This provides a standardized, repeatable testing tool for model evaluation.

For performance measurement, each DL VM includes a pre-installed NVIDIA DCGM Exporter that monitors GPU metrics and workload behavior. GPU metrics are collected by Prometheus at configurable scrape intervals (global scrape at 15 seconds, DCGM exporter scrape at 5 seconds) and visualized in Grafana dashboards. VCF Operations provides additional GPU metrics monitoring at the cluster, host system, and host properties levels. The vSphere Client provides GPU performance charts at both host and cluster levels.

The vcf pais CLI provides model management tooling, including the vcf pais models list command for retrieving and displaying all models available in a model gallery. Harbor Registry provides the artifact management tooling for storing, versioning, and distributing model artifacts with integrity verification through hash codes and unique content digests.

PAIS does not manage test datasets or test set documentation. The selection, curation, versioning, and documentation of test sets used during TEVV activities is an organizational responsibility.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.1-004

> Develop a suite of metrics to evaluate structured public feedback exercises informed by representative AI Actors.

**SCF Controls:** AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-1.1-005

> Evaluate novel methods and technologies for the measurement of GAI-related risks including in content provenance, offensive cyber, and CBRN, while maintaining the models' ability to produce valid, reliable, and factually accurate outputs.

**SCF Controls:** AAT-17.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.1-006

> Implement continuous monitoring of GAI system impacts to identify whether GAI outputs are equitable across various sub-populations. Seek active and direct feedback from affected communities via structured feedback mechanisms or red-teaming to monitor and improve outputs.

**SCF Controls:** AAT-10.13, AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.1-007

> Evaluate the quality and integrity of data used in training and the provenance of AI-generated content, for example by employing techniques like chaos engineering and seeking stakeholder feedback.

**SCF Controls:** AAT-11, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to protecting the integrity of data sources used by AI workloads through storage-level encryption and access controls. vSAN encryption at rest and VM encryption protect AI training data stored on VCF infrastructure from unauthorized access at the storage layer. VMware vCenter RBAC restricts who can access or modify VMs containing AI data. Storage policies control datastore placement and encryption properties for AI workload VMs.

At the Consumption layer, VMware Kubernetes Service (VKS) on vSphere Supervisor extends these protections to containerized AI workloads. Harbor, available both as a Supervisor Service and as a standard package on VKS clusters, is the private container image registry, with images organized by vSphere Namespace. Harbor scans images for known vulnerabilities, enforces content trust so that only signed and verified artifacts are trusted, applies role-based access control to restrict which principals can push or overwrite model artifacts and pipeline images, and uses policy-based replication to control how artifacts move between registries. After Harbor is integrated with the Supervisor, all VKS clusters on the same Supervisor automatically trust it as a source of verified images.

Kubernetes admission controllers, including ValidatingAdmissionPolicy and validating webhook controllers, can be configured on VKS clusters to enforce requirements before workloads are admitted. Relevant policies include restricting image pulls to the trusted Harbor registry, requiring that images carry a valid signature, and blocking workloads that reference unscanned or unapproved artifacts. These controls reduce the risk that a workload carrying corrupted or tampered data processing logic reaches AI training data.

GitOps workflows, supported through the Argo CD Supervisor Service, store all workload and infrastructure configuration declaratively in a Git repository as the single source of truth. Every change to the deployed state flows through Git, creating a durable record of every authorized modification. Immutable infrastructure patterns complement this approach by making unauthorized changes identifiable through drift detection between actual cluster state and the declared configuration.

Kubernetes RBAC restricts which users and service accounts can read from or write to data volumes, ConfigMaps, and Secrets within VKS clusters. Supervisor namespace isolation with resource quotas contains workloads within defined boundaries, reducing the risk that one tenant can access or alter another tenant's data. Antrea-based network policies define namespace-level ingress and egress rules, scoping the network access surface for storage components that hold AI training data or inference inputs.

CSI Volume Snapshots for VKS clusters support crash-consistent backups with deduplication, compression, and encryption. The ability to restore from a known-good snapshot provides a recovery path when data corruption is detected. The VCF CLI binary, used to interact with VCF Services consumption, publishes a sha256sum.txt checksum file alongside each download so that administrators can verify the binary's integrity before use.

Validating the provenance and accuracy of AI training data at the application level is outside VCF's scope. Data poisoning detection, training data lineage, and AI-specific data provenance tracking require application-layer tooling or AI platform components built on top of the VCF platform.

VMware Private AI Services (PAIS) provides integrity controls for both model artifacts and data sources used by AI workloads. Model revisions in the Model Gallery use Harbor as a storage backend, and each push of the same model receives a unique digest so that successive revisions are content-addressed and distinguishable. Before upload, model files should be validated for integrity by checking hash codes, scanned for malware and serialization attacks, and tested for correct inference behavior using Triton Inference Server as part of the sandbox validation process in a Deep Learning VM. This pre-upload validation

provides cryptographic verification and behavioral testing that helps prevent contaminated or tampered model data from entering production.

The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models. Harbor integration requires authentication and certificate-based trust for model retrieval, and PAIS requires CA trust bundles to be imported for the Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, and MCP servers providing tools for agents. These access controls and verified chains of trust restrict unauthorized modification of model and data artifacts. The documentation recommends using the Model Gallery to reduce redundant copies of models and maintain model integrity in a controlled environment.

For knowledge base data sources used by retrieval-augmented generation, PAIS Data Indexing and Retrieval enables automatic collection and indexing of data updates from linked data sources over time, supporting external content management systems such as Microsoft SharePoint and Amazon S3 compatible stores. Each knowledge base data source is created with a specific type that cannot be changed after creation, which helps prevent silent reconfiguration of the underlying source provider. The content management system used as a data source must be supported, and valid credentials are required for access to the content location. SharePoint data sources require user name and password authentication, and service account key file data sources require the information from the service account key file during data source creation. PAIS uses a CA trust bundle for secure communication with external services and databases, establishing verified transport between PAIS and its data sources.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.





## Control MS-1.1-008

> Define use cases, contexts of use, capabilities, and negative impacts where structured human feedback exercises, e.g., GAI red-teaming, would be most beneficial for GAI risk measurement and management based on the context of use.

**SCF Controls:** AAT-11, AAT-26.3, TDA-01.1, TDA-21, VPM-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-1.1-009

> Track and document risks or opportunities related to all GAI risks that cannot be measured quantitatively, including explanations as to why some risks cannot be measured (e.g., due to technological limitations, resource constraints, or trustworthy considerations). Include unmeasured risks in marginal risks.

**SCF Controls:** AAT-16.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-1.3-001

> Define relevant groups of interest (e.g., demographic groups, subject matter experts, experience with GAI technology) within the context of use as part of plans for gathering structured public feedback.

**SCF Controls:** AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.3-002

> Engage in internal and external evaluations, GAI red-teaming, impact assessments, or other structured human feedback exercises in consultation with representative AI Actors with expertise and familiarity in the context of use, and/or who are representative of the populations associated with the context of use.

**SCF Controls:** AAT-07.1, AAT-10, AAT-11, VPM-10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-1.3-003

> Verify those conducting structured human feedback exercises are not directly involved in system development tasks for the same GAI model.

**SCF Controls:** HRS-11

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides granular role-based access control (RBAC) across its component products, giving organizations the technical foundation to implement and enforce separation of duties policies. While VCF does not define SoD policies on its own, it supplies the authorization mechanisms that make duty separation enforceable at the infrastructure layer.

VMware vCenter implements fine-grained authorization through a permissions and roles model applied to the vSphere object hierarchy. Administrators can create custom roles with specific privilege assignments, controlling exactly which actions a user or group can perform on specific vSphere objects. Permission propagation allows these assignments to cascade through the object tree, so access boundaries can be drawn at any level of the infrastructure. When a role is assigned directly to an individual user, that assignment takes precedence over any role assigned to a group to which the user belongs, allowing administrators to grant more restrictive or more permissive access to specific individuals without modifying group-level assignments. vCenter ships with system-defined roles that cannot be modified or deleted, including a Read Only role limited to three system-defined privileges (System.Anonymous, System.View, and System.Read) and an administrator role that provides an intermediate authorization level for users who manage vCenter configuration and control functions. If a predefined role does not match operational requirements, administrators can define new roles containing only the minimum set of required privileges, supporting least-privilege assignment aligned with duty boundaries. PowerCLI cmdlets such as New-VIRole and Set-VIRole allow programmatic creation and modification of roles, enabling consistent and auditable role management across environments. The privilege checks recorder feature allows administrators to monitor and query the privileges checked during vCenter operations, which helps build least-privilege custom roles tailored to particular workflows.

VCF Operations extends RBAC with its own set of predefined and assignable roles. Each user must have a unique account with one or more roles assigned, and administrators can assign roles to individual users or to user groups with a defined scope for each role. Predefined roles in VCF Operations include privileges for create, read, update, and delete actions on components such as dashboards, reports, administration, capacity, policies, problems, symptoms, alerts, user account management, and adapters. The ContentAdmin role can manage all content, including views, reports, dashboards, and custom groups. This separation of administrative functions allows organizations to restrict operational staff to monitoring and reporting while reserving configuration and policy changes for designated administrators. VCF Operations also integrates with vCenter by sending its roles as privileges within the vCenter Global privilege group, requiring a vCenter administrator to assign those roles to users, which creates a natural two-party authorization step for cross-product access.

VCF Automation extends role-based access control with both organization-wide and project-level role assignments. Predefined roles include Organization Administrator, Organization User, Organization Auditor, Project Administrator, Project User, Project Advanced User, and Project Auditor. At the project level, users can be assigned as administrators, members, or viewers. Organization Administrators have broad management rights including certificate management, content libraries, and approval policies, while Organization Auditors have read-only access for review purposes. VCF Automation also supports approval policies that require designated approvers to hold specific role combinations, adding a workflow-level separation step for provisioning and deployment actions. The System Administrator role in VCF Automation provides granular permissions across dozens of functional areas including API tokens, approvals, audit, blueprints, catalog, cloud accounts, deployments, extensibility, and more.

NSX supports creating custom roles with granular permission assignments based on operational requirements, allowing network administration duties to be separated from compute and storage administration. vSAN covers RBAC and permissions management through its Security Configuration Guide, supporting storage-specific duty boundaries. vSphere also supports configuring separate key providers for different departments or organizational units, supporting granular access control to

encryption keys that aligns with duty separation requirements for cryptographic operations. VCF Operations Orchestrator supports group-based permission management where users without an assigned role can view only their own workflow runs.

Together, these RBAC capabilities allow an organization to assign distinct roles for compute administration, network configuration, storage management, security policy, monitoring, and cloud automation across VCF's component products. By granting each team or individual only the privileges required for their function, organizations can enforce duty separation that requires collusion between multiple privileged accounts to perform unauthorized actions. The organization remains responsible for defining SoD policies, determining which duties must be segregated, and assigning personnel to the appropriate roles. VCF provides the technical enforcement layer that restricts users to their granted privileges.

VMware Private AI Services (PAIS) provides several role-based access control mechanisms that support the implementation of Separation of Duties across the AI infrastructure stack.

VCF Automation, which PAIS uses to deliver self-service provisioning of GPU-accelerated VMware Kubernetes Service (VKS) clusters and Deep Learning VMs, defines distinct project-level roles including Project Administrator, Project Advanced User, and Project Auditor with differentiated privilege levels. These roles allow organizations to separate the individuals who configure AI infrastructure from those who consume it and those who review activity. At the platform tier, VCF Automation separates provider-level operations, which require a `PROVIDER_ADMIN_ACCESS_TOKEN`, from organization administrator operations, which require a `TENANT_ADMIN_ACCESS_TOKEN`. This token distinction means that infrastructure-wide actions and organization-scoped actions must be performed under different credentials by different principals.

PAIS enforces access control through OIDC group-based authorization. The `authorizedGroups` field in the `PAISConfiguration` custom resource specifies which OIDC groups can access the service, restricting access to designated personnel. PAIS can be configured with only one OIDC provider, so all group-based authorization decisions flow through a single auditable path. PAIS users are organized in groups, with a `groups` claim included in the Access Token and a `groups` scope created in the OIDC configuration, giving organizations a mechanism to map personnel categories to access levels. The `PAISConfiguration` custom resource is defined as a CRD YAML file with sections for storage policy, CA trust bundles, database connection, OIDC provider integration, and ingress, and access control uses OIDC provider groups with configurable claim names for group identification in the organization namespace.

The observability layer carries its own role separation. Grafana for PAIS supports OIDC-driven role assignment using a configurable role attribute path expression: users whose OIDC groups match the configured access group receive the Admin role, while remaining authenticated users receive the Viewer role. This restricts who can modify dashboards and alert configurations from those who can only read metrics.

For Deep Learning VM and PAIS deployment, a VI administrator must configure a GPU-accelerated workload domain and clusters with support for vSphere Supervisor and VCF Automation before PAIS is installed on a Supervisor for an organization. Separately, the organization administrator must assign the required user role before any user can provision Deep Learning VMs or upload to the model gallery. This two-step requirement separates the actor who manages platform prerequisites from the actor who grants provisioning access to individual users.

The organization must define its SoD policy, decide which personnel occupy which roles, and configure the OIDC provider with appropriate group memberships to reflect those assignments. PAIS supplies the technical mechanisms; the design and maintenance of the SoD structure itself is an organizational responsibility.

### **VMware vDefend (Contributes)**

VMware vDefend supports Separation of Duties within its management plane through differentiated role-based access control across Security Services Platform, Security Intelligence, Distributed Firewall policy management, and the VCF Automation firewall administration layer.

Security Services Platform defines five distinct roles with non-overlapping permissions: Enterprise Admin, Auditor, Security Engineer, Security Operator, and Support Bundle Collector. Security Intelligence applies the same role structure within its management surface. Each role carries differentiated capabilities, preventing any single administrator from controlling all aspects of security operations without oversight.

In 9.1, VCF Automation introduces a Firewall category under rights that governs access to Distributed Firewall, Tenant Gateway Firewall, VPC Gateway Firewall, and VPC Security Profile management. The Organization Administrator role requires all eight rights across these firewall categories, while custom roles can be configured to grant narrower combinations of manage and view rights per firewall tier. This allows organizations to assign separate personnel for firewall rule management versus read-only visibility, and to separate responsibility across north-south and east-west firewall functions. Administrative rights in VCF Automation 9.1 are primarily governed by predefined roles rather than granular custom project-level rights, keeping privilege delegation bounded.

VMware vDefend implements a persona-based security rule model with three distinct administrative tiers: the Provider Admin manages global resources and high-precedence rules in the shared infrastructure space, the Project Admin orchestrates security policy within a project, and the Organization Admin manages tenant-level resources and groups. Tenant-level groups are owned and managed by the Organization Admin, while Project Admins focus on groups within their dedicated VPCs, providing structural administrative separation between provider-tier and tenant-tier firewall policy management.

Access to Distributed Firewall monitoring features, including Firewall Insights, is restricted to Enterprise Admin, Security Admin, and Security Operator roles, limiting who can observe security telemetry to designated personnel.

VMware vDefend's SoD controls apply within its own management plane. Organizational SoD enforcement spanning identity governance, staffing decisions, and cross-system access management is outside the scope of a network security product.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) supports separation of duties for replication and disaster recovery operations through role-based access control that augments vCenter roles with PNR-specific permissions. PNR adds several predefined roles to vCenter that are available in the role drop-down for assigning permissions to users and user groups. Each role includes a defined set of privileges that allows users to complete specific actions while restricting access to resources belonging to other users.

By default, the vCenter administrator role inherits all PNR and vSphere Replication privileges upon installation. PNR also supports assigning protection and recovery roles to users or user groups that do not hold vCenter administrator rights, allowing those users to perform protection and recovery operations without granting full vCenter administration. When a user requires privileges for both PNR and vSphere Replication operations without holding vCenter administrator rights, the recommended approach is to add the user to two separate user groups, each assigned the appropriate role, so the combined privileges are explicit and auditable. Users granted the vCenter administrator role after PNR installation must have PNR roles manually assigned on PNR objects, so that elevated platform roles do not automatically convey replication-administration rights to those users.

PNR enforces additional duty separation across the recovery workflow. Testing a recovery plan and running a recovery plan require separate privilege assignment to help prevent unintended changes that take significant time and effort to reverse. PNR administrators can assign SrmAdministrator or SrmProtectionGroupsAdministrator roles to automatic-protection users or groups, allowing protection responsibilities to be delegated independently of plan execution.

The Clean Room Orchestrator component within PNR adds its own role model with Organization-level roles and service-specific roles. Access to the Clean Room Orchestrator is governed by Global Console Admin and Recovery Admin service roles, separating overall console administration from recovery operations within the isolated recovery environment. Service-specific roles can be assigned to users in addition to Organization-level roles, allowing organizations to delegate clean-room responsibilities without granting broader administrative scope. PNR also applies resource isolation on shared recovery sites to maintain separation between different organizations' virtual machines.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer provides a role-based access control (RBAC) system that organizations can use to implement Separation of Duties across the Avi control and data planes. The Avi for VCF guide identifies role-based separation of duties as a core design principle, enabling application teams to autonomously consume load-balancing services using resources assigned to their organization.



The Avi Controller supports three privilege levels for each resource: Write (full create, read, modify, and delete access), Read (view-only access without modification capability), and No Access (which restricts the user from reading or listing the resource entirely). Administrators can create custom roles that assign these privilege levels independently for each system resource, enabling precise allocation of capabilities to specific personnel without granting broader access than required. Roles are combined with tenant assignments to define the complete authorization profile for each user, making it possible for a team member responsible for virtual service operations to hold write access to load balancing resources while holding no access to certificate management or WAF policy configuration. Permission categories cover two main areas: Operations (including alerts, actions, and traffic capture) and Administration (including controller, tenant, user, role, and system configuration management).

The Extended Granular RBAC system provides additional access scoping through label-based permissions for cloud objects. When no filters are configured, a user can access all objects according to the privileges in the assigned role. Granular RBAC per field allows administrators to restrict write access to specific sub-resources within objects, enabling fine-grained separation of configuration responsibilities. Virtual services also support RBAC configuration during creation, allowing granular access control for managing and monitoring individual applications independently.

In VCF organization-managed mode, a Provider or Load Balancer Administrator manages resource assignments to organizations to enforce quotas and resource boundaries. At the data plane level, Service Engine groups are an inherent method of providing data plane isolation, and Service Engine Group allocation at the project level keeps each project within its designated boundaries. A service provider can allocate isolated Service Engines to each tenant or place multiple tenants in the same group depending on resource sharing requirements.

For Global Server Load Balancing (GSLB), both predefined and custom-defined roles are available. Function-specific roles such as `Gslb_Group_Enabled` and `Gslb_Health_Monitor` can be assigned to user accounts with tenant-level scope, allowing separate personnel to manage GSLB group membership configuration independently from health monitoring configuration.

The License Hub implements three distinct roles: Enterprise Admin (performs all operations), Auditor (views information and tracks activity without making changes), and Support Bundle Collector (collects system logs and diagnostics). This structure provides built-in separation of duties between operational and read-only audit functions for licensing management.

For Kubernetes environments, the Avi Kubernetes Operator (AKO) implements RBAC by assigning tenants and roles to user accounts. HealthMonitor resources in AKO are scoped to a specific tenant, and the AKO CRD Operator manages namespace-scoped resources with tenant isolation for multi-tenancy support.

Organizations should identify which duties require separation based on their operational and compliance requirements, then configure Avi roles, tenant assignments, Service Engine group boundaries, and organization-managed mode settings to enforce those separations.

Not applicable for this control: VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of this product.

## Control MS-2.2-001

> Assess and manage statistical biases related to GAI content provenance through techniques such as re-sampling, re-weighting, or adversarial training.

**SCF Controls:** AAT-06, AAT-10.8, AAT-12.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.2-002

> Document how content provenance data is tracked and how that data interacts with privacy and security. Consider: Anonymizing data to protect the privacy of human subjects; Leveraging privacy output filters; Removing any personally identifiable information (PII) to prevent potential harm or misuse.

**SCF Controls:** AAT-12.1, AAT-26, DCH-23

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-2.2-003

> Provide human subjects with options to withdraw participation or revoke their consent for present or future use of their data in GAI applications.

**SCF Controls:** PRI-03.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.2-004

> Use techniques such as anonymization, differential privacy or other privacy- enhancing technologies to minimize the risks associated with linking AI-generated content back to individual human subjects.

**SCF Controls:** DCH-23

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.3-001

> Consider baseline model performance on suites of benchmarks when selecting a model for fine tuning or enhancement with retrieval-augmented generation.

**SCF Controls:** CFG-02

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides secure baseline configurations for all major platform components, consistent with industry-accepted hardening standards. The VCF Security Baseline is a purpose-built document that builds on VCF security fundamentals to address frequently requested compliance standards, regulations, and frameworks. It is designed and validated to tailor security configurations without affecting VCF's ability to meet its design objectives. Organizations can use the VCF Security Baseline to evaluate both default and non-default configurations and to secure their environments in a compliance context.

VCF Operations includes a consolidated out-of-the-box benchmark called the VCF 9 Security Baseline, which provides a ready-to-use compliance profile for evaluating the security posture of a VCF environment. This benchmark enables automated assessment of configurations against the documented baseline, helping maintain a consistent configuration across VCF components. ISO Security Standards compliance benchmarks are also available from the VCF Operations repository as a native pack, giving organizations the ability to measure their environment against internationally recognized hardening standards. Broadcom also provides DISA Security Technical Implementation Guides (STIGs) for VCF components, including vSphere 7.0 and vSphere 8.0 STIGs, which provide detailed instructions for securing and configuring systems to meet specific security requirements.

Individual VCF components have their own security configuration guides that document hardening recommendations. The vSphere Security Configuration Guide provides best practices for securing VMware vCenter, including securing the installation, configuring access and authentication, defining roles and permissions, and enabling auditing and logging. VMware ESX host hardening covers authentication and authorization settings, disabling unnecessary services, enabling security features such as Secure Boot and Trusted Platform Module (TPM), and implementing network security measures. The vSphere Security Configuration Guide documents specific STIG-aligned values for the `Security.PasswordQualityControlPwquality` setting on ESX hosts, including parameters such as `minlen=15`, `maxrepeat=3`, `maxclassrepeat=4`, `difok=4`, and `enforce_for_root`. The NSX Security Configuration Guide provides recommendations for securing NSX components, including NSX nodes, NSX Controllers, and NSX Edge nodes, by configuring strong authentication, implementing role-based access control, and securing administrative access.

VCF Operations also provides a Configure Host Security Config Data workflow that allows selective enforcement of host security hardening rules. Beyond security settings, vSphere Lifecycle Manager maintains a desired-state cluster image that defines the ESX base build, vendor add-ons, and firmware for every host in a cluster, so the software baseline stays consistent across hosts, and VCF Operations runs scheduled drift detection that flags configuration deviations from the desired state for remediation. Administrators can configure individual configuration elements under Enforce Options, enabling granular control over which baseline settings are applied and enforced across the environment. This supports reducing organizational and business risk by maintaining configuration consistency. vSphere Host Profiles provide an additional mechanism for automated and centrally managed host configuration baseline enforcement, capturing a reference host's configuration and applying it consistently across ESX hosts, covering memory, storage, networking, and other configuration aspects.

For containerized workloads, VMware Kubernetes Service (VKS) includes preconfigured security policy templates. The Baseline security template provides a set of constraints that restrict known privilege escalations while maintaining compatibility with common containerized workloads.

DISA STIGs for Supervisor and VKRs are available to guide hardening of the Supervisor control plane and individual VKS cluster releases, providing baseline security guidance at the same standard as the DISA STIGs applied to VCF infrastructure components. The VKS cluster management interface provides out-of-the-box security policy templates that mirror industry-standard Pod Security Standards profiles, including both Baseline and Restricted configurations. Custom VKS Cluster

Management Security Policy templates are also available to fine-tune individual security context parameters and support governance controls tailored to specific organizational requirements.

Pod Security Admission (PSA), enabled in VKr 1.25 and later, enforces pod security standards at the namespace level. Three policy profiles are defined: Privileged (unrestricted, for system-level workloads), Baseline (helps prevent known privilege escalations while allowing the default minimally specified pod configuration), and Restricted (heavily restricted, following pod hardening best practices). Three enforcement modes are available: enforce, warn, and audit. The `podSecurityStandard` field in the ClusterClass API encodes the intended security posture in cluster definitions, accepting these modes with specific policy versions and namespace exemptions so that baseline security configurations are applied consistently across VKS deployments. System namespaces including `kube-system`, `tkg-system`, and `vmware-system-cloudprovider` are excluded from pod security enforcement. The PSA admission controller can also be statically configured with default enforce, audit, and warn levels for unlabeled namespaces, so namespaces created without explicit labels still receive a defined security baseline. To support gradual policy adoption, audit and warn modes can be set to a stricter level such as restricted while enforce remains at baseline, giving administrators visibility into policy violations before full enforcement is applied. VCF Automation IaaS Resource Policies provide an additional enforcement point at the management layer, supporting requirements that Kubernetes clusters operate at a minimum baseline pod security level.

Kubernetes-native kernel security mechanisms provide workload-level baseline hardening options. `seccomp` restricts the Linux kernel system call surface available inside containers using BPF-based profiles, and the `RuntimeDefault` `seccomp` profile provides a strong set of security defaults while preserving workload functionality. AppArmor and SELinux provide further kernel-level restrictions through default configurations that offer foundational protections. Kubernetes default RBAC role bindings should be reviewed as part of establishing a security baseline, as defaults may grant broader access than a hardened configuration requires. Isolating each workload in its own Kubernetes namespace allows tailored security policies to be applied per workload and restricts access to namespace-scoped resources such as ConfigMaps and Secrets.

Harbor Registry, available as a standard package for VKS clusters, supports a controlled baseline for container artifacts entering the environment. Harbor provides vulnerability scanning, content trust, and policy-based replication, along with role-based access control and artifact security policies, supporting controlled management of the container image supply chain. For stand-alone virtual machines deployed in vSphere Supervisor environments, Content Libraries can distribute VM images created with current patches and required security settings that follow corporate security policies.

VMware Private AI Services (PAIS) provides PAIS-specific declarative configuration mechanisms that organizations can use to define and apply baseline settings across the AI infrastructure stack on VCF.

The primary mechanism is the `PAISConfiguration` custom resource. Private AI Services settings are declared in a YAML file compliant with the `PAISConfiguration` schema and applied with `kubectl`, giving administrators a single resource that captures observability, identity, and trust configuration for an organization namespace. Observability includes the `spec.observability.prometheusRuntime` section for Prometheus metrics collection with a configurable storage class and metrics retention period, and an `llmTraces` section for routing large language model traces to an OpenTelemetry Collector. The `PAISConfiguration` custom resource can be patched with `kubectl patch` and verified with `kubectl get paisconfiguration`, supporting baseline change control and drift detection at the AI service layer.

Certificate trust is handled through the `spec.clientTls.caBundleRefs` section, which references ConfigMaps containing CA trust bundles. Private AI Services requires HTTPS trust bundles for the OIDC provider, the Harbor registry, content management systems hosting knowledge database data, and MCP servers that provide tools to models. Trust bundles can be organized per application, with periodic updates required before certificate expiration. Access scope is restricted through the `authorizedGroups` setting, which limits Private AI Services access to specified OIDC groups.

Harbor registry distribution carries baseline controls for model and image artifacts. Replication rules support configurable filters, target namespace, and trigger mode, including a manual trigger mode, so administrators can align artifact replication with organizational policy for connected and disconnected sites. The Model Gallery uses Harbor project access capabilities to restrict access to sensitive training and tuning data. Air-gapped deployments capture the self-hosted registry URL and registry login credentials as part of the activation flow.

Workload resource baselines are defined through `SupervisorNamespaceClassConfig`, which specifies per-zone CPU limits, CPU reservations, memory limits, and memory reservations for resource allocation across zones. GPU-capable VM classes can carry GPU reservations and be confined to a single zone or supervisor namespace, supporting isolation of GPU consumption to a specific tenant. A default storage policy selection in the Private AI Services quickstart defines storage placement and resources for the service database.

Deep Learning VM (DL VM) baselines are captured through VCF Automation self-service catalog items that parameterize VM class, data disk size, user password, and optional SSH public key authentication for remote access. The DL VM OVF property `config-json` accepts a base64-encoded configuration file that controls DCGM Exporter metrics visibility through `export_dcgml_to_public` and JupyterLab authentication through `enable_jupyter_auth`, giving operators a consistent surface to define DL VM hardening parameters.

Credentials supplied during Private AI Services activation, including the private container registry password and proxy password, are stored as secrets in VCF Automation rather than as plaintext configuration values, supporting credential hygiene as part of the deployment baseline.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to secure baseline configurations within its network security domain by providing structured configuration management capabilities, predefined security profiles and strategies, and configuration integrity controls that align with industry-accepted hardening practices.

vDefend supports draft configuration management with configuration locking to prevent multiple users from simultaneously opening and editing a manual draft, helping maintain configuration integrity and reducing the risk of conflicting changes to firewall policy. Role-Based Access Control (RBAC) in vDefend governs who can create or modify firewall policies, providing control over which administrators can alter the security baseline.

In vDefend, five system-defined VPC Security Strategies are available for establishing security baselines across Virtual Private Clouds (VPCs): VPC Isolation, VPC Isolation with Essential Services, VPC External Connectivity, VPC Secure Connection, and NONE. These strategies are consumed through Security Profiles in VCF Automation, which are predefined configuration templates that define the default security posture for VPCs. VPC Security Strategies provide a declarative, consistent way to apply DFW security baselines across multiple VPCs within a project, and Project Admins are guided to select a pre-defined high-level security posture that enforces Secure by Default principles rather than manually configuring individual firewall rules. Security profiles can be applied to one or more VPCs simultaneously and updated as requirements evolve.

vDefend provides predefined TLS Decryption Action Profiles with four settings: Balanced (default), High Fidelity, High Security, and Custom. These profiles are vendor-defined baseline configurations for TLS inspection behavior, giving organizations a documented starting point aligned with different security postures. TLS Inspection policies also support an Advanced Configuration option to lock policies, preventing multiple users from making concurrent changes to TLS inspection policy baseline settings.

Security Services Platform validates configuration changes before implementation through a deployment wizard that conducts thorough validations to confirm configurations are correct and compatible. The platform enforces initial security policies that cannot be modified through the user interface after they have been published, providing an immutability mechanism for foundational policy baseline elements. Security Services Platform supports backup and restore of configuration data, and certificate consistency between backup and restored environments should be verified to maintain NDR sensor integrity.

Security Services Platform's Bare Metal Security feature extends vDefend policy enforcement to physical servers, applying L3/4 security policies to bare metal infrastructure using the same policy model and management plane as virtualized workloads. Two default DFW rules are created when Bare Metal servers are onboarded to Security Services Platform, providing an immediate baseline posture for physical infrastructure. Security policies are defined, propagated, and enforced across Bare Metal servers with consistent application and monitoring.

vDefend's configuration management capabilities operate within the network security layer. The broader secure baseline configuration program for VCF, including the VCF Security Baseline document, component hardening guides, DISA STIGs,



and compliance scanning through VCF Operations, is managed at the platform level. vDefend contributes by maintaining its own secure defaults and configuration controls within the network security domain.

### **VCF Protection and Recovery (Contributes)**

VCF Protection and Recovery (PNR) provides configurable security baseline mechanisms for its replication and recovery infrastructure. The PNR appliance includes a security reference section that identifies configuration files containing settings that affect environment security, and PNR documentation establishes that secure operation depends on proper configuration and maintenance of the PNR server. The security reference also documents network port requirements, providing the technical specifications needed to develop and maintain secure baseline configurations for disaster recovery infrastructure.

PNR includes a Configuration Import/Export Tool that captures the complete set of protection and recovery configuration settings, including server version, build number, local and remote site names, inventory mappings, placeholder datastores, advanced settings, and array managers. The tool supports both UI-based and scripted exports and can transfer configuration data without requiring credential entry when using the bundled generated script. This gives organizations a mechanism to document, back up, and restore known-good baseline configurations for their disaster recovery infrastructure. The underlying system configuration is stored in the `va-configurator.xml` file and is accessible through Advanced Settings on the Site Pair tab in the management interface, providing a defined location for baseline review and modification.

The PNR appliance management interface allows administrators to configure appliance security settings after deployment. The Advanced Settings system provides privileged users with the ability to adjust default values governing protection and recovery features. When modifying the minimum protocol version for TLS, PNR requires that the change be applied consistently across all configuration occurrences in the system, supporting systematic baseline management for transport security settings.

For cyber recovery deployments, PNR documentation recommends using standard VCF topology with separate workload and management domains to achieve better isolation and align with security best practices at the recovery site.

Full compliance with this control requires an organizational baseline configuration management program, documentation practices, version control, and hardening tooling extending beyond what PNR provides directly.

### **VMware Data Services Manager (Contributes)**

VMware Data Services Manager (DSM) contributes to secure baseline configuration management through its infrastructure policy framework, data service policy enforcement, and built-in secure defaults for authentication and certificate management.

Infrastructure policies in DSM define the compute, storage, and networking resources for each database deployment, including the list of allowed VM classes and compatible storage policies. These policies are configured by DSM administrators and act as standardized, repeatable deployment baselines that database users must follow. When administrators configure infrastructure policies, they constrain the quality and quantity of resources that users can consume from vSphere clusters, establishing guardrails that support consistent deployments across the environment. Database cluster creation applies both infrastructure policies and storage policies that enforce isolation and resource constraints, reducing the risk of misconfiguration by individual users.

Data service policies extend this baseline enforcement across multi-tenant deployments. DSM administrators can define and configure data service policies for various database services and enforce them across different tenants to maintain a consistent security and compliance posture. Data service policies constrain which infrastructure options can be applied to database instances. When DSM is integrated with VCF Automation, data service policies can be applied consistently across organizational units.

DSM also ships with predefined secure defaults for database authentication. PostgreSQL databases on DSM use `scram-sha-256` as the default password-based authentication method, as configured in the default `pg_hba.conf` entries stored at `/pgsql/data/pg_hba.conf`. Custom `pg_hba.conf` entries support `scram-sha-256`, `reject`, and `cert` authentication methods. TLS is enforced by default for database client connections, with an administrator-controlled option to relax enforcement via the `postgrescluster-allow-non-ssl-system-users` setting in the `advanced-system-config` ConfigMap within the `dsm-system` namespace.

Certificate management is integrated into the database creation workflow and validates certificate chains for connections to external systems, including VMware vCenter. DSM introduces a stricter default certificate validation mode, the "latest" mode, that enforces cryptographic and KeyUsage validations for all DSM endpoints, including the Provider VM and data service clusters. Certificates uploaded to DSM are validated against FIPS 140-3 cryptographic standards, and uploads containing unsupported algorithms or parameters are rejected. Custom trusted root certificates must comply with FIPS requirements. DSM also verifies the SHA256 thumbprint of vCenter during initial configuration to confirm the management connection targets the expected endpoint. Custom certificate support allows organizations to replace the default DSM certificate with organization-issued certificates for both the Provider VM and database clusters. For self-service deployments using the DSM Consumption Operator, signature verification confirms package integrity before installation.

DSM validates certificate chains using configured root CA certificates stored in ConfigMaps and supports private container registry configuration with CA certificate validation for air-gapped environments.

Addressing this control fully requires organizational processes beyond what DSM provides directly. DSM does not include tooling to document baseline configurations in a compliance-ready format, map configurations to specific industry hardening standards, or audit deviations from defined baselines over time. Organizations should supplement DSM's policy and defaults framework with configuration management documentation, change tracking processes, and integration with compliance scanning tools to satisfy the full requirements of this control.

### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) provides several built-in mechanisms that support the development and application of secure baseline configurations for the application delivery layer.

The SSL/TLS Profile system gives administrators a documented starting point for cryptographic configuration. Profile Templates define accepted SSL and TLS versions and ciphers in prioritized order, and can be associated with virtual services or the Controller itself. The Standard SSL/TLS Profile is suitable for typical deployments, while the System-Standard profile provides modern cipher suites for backend server re-encryption in Kubernetes environments managed through the Avi Kubernetes Operator (AKO). Avi includes a curated list of cipher suites considered reasonably strong for SSL/TLS configuration, and the documentation notes the trade-offs between security, compatibility, and computational expense when selecting profiles. The Service Engine disables unsafe legacy renegotiation by default, providing a built-in protocol hardening baseline that reduces the risk of protocol downgrade attacks.

The System-Secure-HTTP application profile is a pre-configured baseline for securing HTTP virtual services. It enforces HTTPS, protects cookies, manages client IP handling, and controls protocol behavior, giving administrators a hardened starting point for web application delivery. Administrators can supplement these defaults with more granular settings through policies or DataScripts.

For deployments requiring validated cryptographic modules, Avi Load Balancer implements FIPS 140-3 compliance, providing a cryptographic baseline aligned with the U.S. and Canadian government standard for cryptographic modules.

The Avi Web Application Firewall (WAF) Positive Security model supports application-layer baseline configuration through rules that define allowed application behavior. Each rule supports Enable/Disable control, mode selection between Detection and Enforcement, and configurable Paranoia levels, allowing organizations to tune an application security baseline to their risk posture. The Positive Security Rule Updates feature can be enabled to activate additional configuration options for application security policies. The Cloud Console Application Rules service extends this with rules specifically designed to address known application vulnerabilities, including those with CVEs, and updates them automatically.

For Kubernetes deployments, AKO uses Custom Resource Definitions (CRDs) to enable syntactical validation of configuration objects at creation time, which helps prevent invalid configurations from being deployed. The AKO L4 CRD Rule supports SSL profiles and PKI profiles for securing pool connections, allowing Kubernetes-native expression of Avi's cryptographic baseline settings.

Certificate lifecycle management supports maintaining cryptographic baselines over time. Certificate Management Profiles support automated certificate renewal workflows, and the Trust Protection Platform integration can automatically handle certificate and chain certificate renewals by learning the mapping of virtual service names to their certificates.

The organizational process of developing, documenting, and maintaining baseline configurations across all in-scope technology assets, including selecting appropriate profile settings, applying them consistently, and updating them as software versions and security guidance evolve, remains outside what Avi performs on the organization's behalf.

## Control MS-2.3-002

> Evaluate claims of model capabilities using empirically validated methods.

**SCF Controls:** AAT-10.16

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-2.3-003

> Share results of pre-deployment testing with relevant GAI Actors, such as those with system release approval authority.

**SCF Controls:** AAT-10.15

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.3-004

> Utilize a purpose-built testing environment such as NIST Dioptra to empirically evaluate GAI trustworthy characteristics.

**SCF Controls:** TDA-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.5-001

> Avoid extrapolating GAI system performance or capabilities from narrow, non- systematic, and anecdotal assessments.

**SCF Controls:** AAT-10.16

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.5-002

> Document the extent to which human domain knowledge is employed to improve GAI system performance, via, e.g., RLHF, fine-tuning, retrieval- augmented generation, content moderation, business rules.

**SCF Controls:** AAT-20.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure for several of the human domain knowledge mechanisms listed in this control, giving organizations the platform through which domain expertise is incorporated into AI system performance.

For retrieval-augmented generation, PAIS includes the Data Indexing and Retrieval service, which provides a Knowledge Bases interface for creating and managing knowledge bases. A knowledge base is built from text chunks and vector embeddings generated using an embedding model endpoint deployed through PAIS Model Endpoints, and a single knowledge base can be linked to as many as 10 data sources. Supported data sources include Microsoft SharePoint sites, Amazon S3 compatible stores, and other external content management systems, allowing domain experts to curate and update the knowledge that augments model responses without modifying the underlying model. Knowledge base operations record document counts, embedding update activity, total megabytes downloaded, chunk counts, and timing metrics across the download, embedding, and indexing phases, producing technical artifacts that an organization can reference when documenting how RAG augments its AI systems.

For business rules style direction, PAIS deploys agents in Agent Builder that consume completion model endpoints. An agent can be configured with static tool execution to access knowledge bases in Data Indexing and Retrieval over MCP when a tool-calling model is unavailable. Agents are deployed alongside model endpoints, RAG applications, and knowledge bases within an organization namespace once PAIS has been activated by an organization administrator or MLOps engineer.

PAIS is consumed through VCF Automation. AI catalog items are added by running the PAIS Quickstart, allowing users in the organization to provision AI workloads including model endpoints, agents, and RAG applications from a curated catalog. The catalog items give an organization a defined provisioning surface from which AI workloads with documented RAG and agent configurations are deployed.

PAIS does not provide reinforcement learning from human feedback or built-in content moderation features. Organizations requiring those mechanisms would implement them on Deep Learning VMs or through external tooling. The platform's contribution is the infrastructure and workflow through which RAG knowledge curation, agent instructions, and catalog-driven provisioning of AI workloads are applied and tracked.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MS-2.5-003

> Review and verify sources and citations in GAI system outputs during pre- deployment risk measurement and ongoing monitoring activities.

**SCF Controls:** AAT-12.1, AAT-26

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.5-004

> Track and document instances of anthropomorphization (e.g., human images, mentions of human feelings, cyborg imagery or motifs) in GAI system interfaces.

**SCF Controls:** AAT-26.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.5-005

> Verify GAI system training data and TEVV data provenance, and that fine-tuning or retrieval-augmented generation data is grounded.

**SCF Controls:** AAT-12.1

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides explicit data source identification and tracking for AI workloads. The Data Indexing and Retrieval service offers a Knowledge Bases interface where users create and manage knowledge bases, and a knowledge base can be linked to up to ten data sources. Each data source is created with a name, description, type, and the required properties for retrieving content from its original location, and a single data source can be linked to multiple knowledge bases. The data source type is fixed at creation. Supported data source types include Microsoft SharePoint sites, Amazon S3 compatible stores, and other enterprise content management systems. Each data source stores the credentials required for retrieval, such as service account key file information when applicable, which creates a documented connection between the AI system and its data origins.

During knowledge base indexing, PAIS tracks document-level detail including crawled documents, new documents found, deleted documents, existing unmodified documents, existing modified documents requiring embedding updates, and skipped documents. It captures size metrics including total megabytes downloaded, new chunks indexed corresponding to inference server invocations for embeddings, and final index size after removal of deleted documents. It records timing metrics for download, embedding generation, and the overall index operation. Document counts returned by retrieval queries are tracked, and counts of documents per media type such as PDF and PPTX are maintained for each knowledge base. Automatic collection and indexing of updates from linked data sources over time keeps these records current.

For runtime visibility, PAIS supports LLM trace collection through an OpenTelemetry Collector by configuring the `spec.observability.llmTraces` section of the `PAISConfiguration` custom resource, with traces transmitted over HTTP/protobuf or gRPC. PAIS metrics, including knowledge base activity, can be visualized in third-party observability platforms such as Grafana. The Data Indexing and Retrieval component also implements a Model Context Protocol (MCP) server that exports a set of search tools for each knowledge base, which gives downstream AI applications a documented programmatic surface tied back to specific data sources. PAIS AI catalog items, including AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, are added to the VCF Automation catalog by running the PAIS Quickstart, with required images uploaded in advance to a Harbor registry in disconnected environments.

Organizational decisions about which data sources are approved for AI use, how data lineage is documented outside the platform, and how training data provenance is governed remain the responsibility of the organization. PAIS supplies the technical registration and tracking infrastructure that the organization configures and operates.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.5-006

> Regularly review security and safety guardrails, especially if the GAI system is being operated in novel circumstances. This includes reviewing reasons why the GAI system was initially assessed as being safe to deploy.

**SCF Controls:** AAT-01

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### **Control MS-2.6-001**

> Assess adverse impacts, including health and wellbeing impacts for value chain or other AI Actors that are exposed to sexually explicit, offensive, or violent information during GAI training and maintenance.

**SCF Controls:** AAT-17.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.6-002

> Assess existence or levels of harmful bias, intellectual property infringement, data privacy violations, obscenity, extremism, violence, or CBRN information in system training data.

**SCF Controls:** AAT-12, AAT-17.1, AAT-17.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.6-003

> Re-evaluate safety features of fine-tuned models when the negative risk exceeds organizational risk tolerance.

**SCF Controls:** AAT-10, AAT-10.10

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.6-004

> Review GAI system outputs for validity and safety: Review generated code to assess risks that may arise from unreliable downstream decision-making.

**SCF Controls:** AAT-26

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides several infrastructure capabilities that support the development and implementation of fact-checking techniques for AI-generated content. The most direct mechanism is the Retrieval-Augmented Generation (RAG) architecture available through PAIS. RAG workloads combine a large language model with an external knowledge base, grounding model responses in organizational data rather than relying solely on the model's training data. Data scientists can build knowledge bases that link to data sources hosted in external content management systems, including Microsoft SharePoint sites and Amazon S3 compatible stores, with a maximum of 10 data sources per knowledge base and each data source bound to a fixed type at creation. PAIS Data Indexing and Retrieval enables automatic collection and indexing of data updates from linked sources over time, which helps keep the grounding data current. This architecture provides a structural approach to improving the accuracy of AI-generated information by anchoring responses to authoritative source material rather than unconstrained generation.

The validate-then-publish workflow for ML models supports pre-deployment testing that can include accuracy verification. MLOps engineers validate ML models against the security, privacy, and technical requirements of their organization before storing them in PAIS. PAIS uses a Harbor registry service in the Supervisor to store validated ML models, with authentication and certificate-based trust required for model retrieval, and OCI-compliant registries from other vendors are also supported. Storing models in a controlled registry provides traceability for which model version was validated and deployed.

Agent Builder in PAIS integrates with Data Indexing and Retrieval to add business data from knowledge bases to agents, allowing teams to build generative AI applications where agent output is informed by curated, access-controlled knowledge bases. Agent Builder also maintains a list of approved tools for use in AI agents when connecting to MCP servers, and available tools are displayed in the tool gallery for namespace-level examination and approval before an agent can call them. MLOps engineers and application developers can monitor the health, quality, and behavior of models used in agents through observability platforms such as Grafana, and PAIS observability can be activated by updating the PAISConfiguration custom resource with metrics and OpenTelemetry trace parameters. The combination of RAG grounding, model validation, approved-tool gating, and observability provides the technical mechanisms organizations need to implement fact-checking techniques, while the specific fact-checking methodologies and acceptance criteria remain the responsibility of the deploying organization.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MS-2.6-005

> Verify that GAI system architecture can monitor outputs and performance, and handle, recover from, and repair errors when security anomalies, threats and impacts are detected.

**SCF Controls:** AAT-19

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.6-006

> Verify that systems properly handle queries that may give rise to inappropriate, malicious, or illegal usage, including facilitating manipulation, extortion, targeted impersonation, cyber-attacks, and weapons creation.

**SCF Controls:** TDA-09.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.6-007

> Regularly evaluate GAI system vulnerabilities to possible circumvention of safety measures.

**SCF Controls:** VPM-06

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides several built-in capabilities that support routine vulnerability scanning and configuration error detection across the infrastructure stack, though a complete vulnerability management program requires integration with dedicated scanning tools for guest operating systems and applications.

VCF Operations includes a diagnostics engine that automatically detects known issues and critical vulnerabilities within the VCF software stack. The engine scans the platform against VMware best practices, logs, and properties to identify diagnostic findings that match known issues, providing detailed descriptions, root cause insights, and actionable remediation steps. The Diagnostic Findings feature provides a consolidated view of known product issues, VMware Security Advisory (VMSA)-based security exposures, and best-practice recommendations across the environment. The Findings Catalog displays the complete list of diagnostic signatures checked at any given time, allowing administrators to see exactly what conditions are being evaluated. Administrators can manage diagnostics parameters through a JSON solution configuration file to customize which rules are active, adjust defaults, and control how findings are handled. These diagnostics build on the capabilities of several legacy tools and operational data to provide integrated issue detection and remediation.

VCF Operations also supports advanced query capabilities that can identify virtual machines running vulnerable operating systems, including specific detection for end-of-life platforms such as Microsoft Windows Server 2003, Microsoft Windows Server 2008, Red Hat Enterprise Linux 5 and 6, and SUSE Linux Enterprise 10. These queries can group results by VLAN for security assessment and compliance monitoring purposes.

The Security Operations dashboard consolidates user and infrastructure security elements into a single view, helping administrators identify areas that require attention. This dashboard highlights security-relevant findings across the VCF environment, providing a centralized starting point for security posture review.

For configuration error detection, VCF Operations monitors configuration errors generated from infrastructure components such as NSX networking, grouping findings by hostname. Alert definitions can be created to monitor virtual machines and hosts with custom symptom parameters, enabling identification of configuration problems before users encounter them. The Configuration Drifts feature in VCF Operations provides proactive monitoring of configuration changes across vCenter instances and vSphere clusters, comparing current values against configuration templates to identify drift. vSphere Configuration Profiles must be enabled on clusters to view drift status. Configuration drift detection compares each vCenter instance's current configuration against the defined template values, and the Configuration Drift dashboard allows administrators to view and monitor drift statuses across the environment.

For patch compliance scanning, vSphere Lifecycle Manager manages all hosts in a cluster collectively with a single image and tracks the current state of each host against the desired cluster image specification, reporting compliance status. The compliance check capability compares the current image on a host against the desired image and reports compatibility status. PowerCLI provides cmdlets for scanning virtual machines and hosts against defined baselines, including the Test-Compliance command to scan entities against downloaded patches and identify which hosts or components are missing security updates. Dynamic baselines update automatically based on specified criteria each time new patches are downloaded, allowing ongoing comparison of system state against current patch levels. The vCenter appliance can also be configured to perform automatic checks for available patches from a configured repository URL, enabling timely awareness of patch availability for the management plane itself. This automatic checking is configured through the vCenter Management Interface (the Check-for-updates-automatically setting) and supports proxy server configuration for environments without direct repository access.

VMware releases security advisories (VMSAs) for critical known vulnerabilities with step-by-step remediation instructions. VCF Operations Diagnostic Findings provides a consolidated view of VMSA-based security exposures alongside best-practice recommendations, connecting advisory information directly to the operational environment.

The DISA STIG Viewer tool provides automated checking of system configurations against STIG requirements, helping identify security vulnerabilities and configuration deviations for environments that follow DISA hardening guidance. This offers a structured approach to configuration compliance scanning against industry-standard best practices.

While VCF provides vulnerability detection and compliance scanning for its own infrastructure stack, scanning of guest operating systems and applications running on VCF requires integration with third-party vulnerability scanning tools. VCF's REST APIs and PowerCLI support enable integration with external scanners and security information and event management platforms to extend scanning coverage beyond the infrastructure layer.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to vulnerability awareness through Security Services Platform analytics and IDS/IPS threat detection, though it does not perform host-based or authenticated application-layer vulnerability scanning.

The Security Services Platform generates Security Segmentation Reports and Blast Radius Reports as part of the vDefend Security Assessment workflow. The Security Segmentation Report assesses security posture by analyzing network traffic over a configurable time range, identifying workloads running obsolete operating systems and using risky protocols, and providing specific improvement recommendations. Blast Radius Reports break down at-risk workloads, communication chains, and network flows to support protection planning. The Security Services Platform also provides an application monitoring view that displays information about running applications and identifies potential security risks, enabling assessment and remediation planning.

The IDS/IPS subsystem contributes vulnerability-specific context by detecting exploitation attempts against known vulnerabilities. IDS/IPS event monitoring records Common Vulnerability Scoring System (CVSS) scores and CVE reference information for vulnerabilities targeted by active exploits. Administrators can search the signature library by specific CVE IDs to assess whether detection coverage is in place for known vulnerabilities. The Security Services Platform provides IDS/IPS performance metrics to monitor detection readiness across the environment.

Because vDefend operates at the network layer, dedicated host-based and authenticated application-layer scanning tools are required to fully satisfy this control. Coverage remains at Contributes.

#### **VMware Avi Load Balancer (Contributes)**

VMware Avi Load Balancer (Avi) supports vulnerability detection for web applications through its Web Application Firewall (WAF) Dynamic Application Security Testing (DAST) integration. The Avi SDK includes a DAST vulnerability scanner script, delivered in the DAST directory on the Avi Controller, which integrates with OWASP ZAP Attack Proxy and Qualys Web App Scanning to assess web application vulnerabilities and drive virtual patching. When a DAST scan identifies vulnerabilities, the `avi-iwaf-vpatch.py` tool automates virtual patch creation by generating Positive Security location rules for each vulnerable URL and Positive Security rules for each supported issue type. This allows the WAF to block requests targeting known vulnerable application paths while underlying code remediation proceeds.

In 9.1, the Avi Cloud Console adds an Application Rules service that provides rules specifically designed to block attacks on known application vulnerabilities, many correlated with CVE identifiers, and automatically updates those rules on the Avi Controller. This complements DAST-driven virtual patching with a continuously refreshed, CVE-mapped rule set covering known application vulnerability classes.

The DAST integration has acknowledged limitations: it does not detect all cookie-related security issues, and some flagged vulnerabilities may require manual remediation rather than automated virtual patching. Organizations should validate scan results and supplement Avi's application-layer DAST capability with platform-level scanning of the Avi Controller infrastructure through VCF platform vulnerability management tooling.

Avi also supports configuration error detection through its inventory fault monitoring system. The Controller's `inventoryfaultconfig` setting allows independent tracking of license faults, migration faults, backup scheduler faults, SSL profile faults, and deprecated API version faults, with alert generation on configured conditions. This supports detection of misconfigured components before they affect application delivery.

The Avi Application Security Report consolidates security findings for a selected virtual service. The report includes ranked lists of top attack types such as SQL injection and cross-site scripting, lists of top attacking IP addresses, and trend summaries showing total and flagged requests. Reports can be generated through the Avi UI or the Avi Controller CLI and downloaded in PDF format, supporting auditor review and periodic vulnerability assessment documentation workflows.

Organizations running Avi on VCF should also lock the Avi Controller Linux OS to a specific version to reduce false-positive CVE scanner findings that arise from inactive OS package versions present on the system but no longer in active use.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-001

> Apply established security measures to: Assess likelihood and magnitude of vulnerabilities and threats such as backdoors, compromised dependencies, data breaches, eavesdropping, man-in-the-middle attacks, reverse engineering, autonomous agents, model theft or exposure of model weights, AI inference, bypass, extraction, and other baseline security concerns.

**SCF Controls:** AAT-10.5

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to evaluating the security and resilience of AI workloads through VCF Operations compliance dashboards that assess infrastructure security posture, configuration drift detection, and health monitoring across the compute, storage, and networking layers that AI workloads depend on. VCF Log Management aggregates event data that supports security assessment. The Security Configuration Guide and DISA STIG provide hardening baselines that can be validated against the infrastructure hosting AI workloads.

The Consumption layer of the VCF platform, delivered through VMware Kubernetes Service (VKS) and vSphere Supervisor, provides pre-deployment evaluation mechanisms for AI and machine learning workloads. DISA STIGs are available for both the Supervisor control plane and VKS cluster VKr images, supplying a structured body of security requirements against which AI workload infrastructure can be evaluated before production deployment. AI and machine learning workloads on Supervisor run on Ubuntu-based Kubernetes release images (VKrs), which are the designated runtime for such workloads in VKS clusters. Cluster readiness assessment is built into the VKS Controller, which reports status conditions covering cluster phase and component health; administrators can query these conditions using kubectl to verify that the infrastructure meets defined readiness criteria before AI workloads are scheduled.

Pod Security Admission is enforced on VKS clusters and provides a pre-execution gate for workload pods. Starting with VKr v1.25, the `kubernetes.security.podSecurityStandard` configuration variable selects Baseline, Restricted, or Privileged profiles to constrain what workload pods can execute. VKS Cluster Management adds a fleet-wide policy governance layer powered by OPA Gatekeeper, with out-of-box security policy templates that mirror industry-standard Pod Security Standards profiles; policies applied at the organization or project level are automatically inherited by all child resources, providing scalable governance across the VKS cluster estate. The VKS Cluster Management Policy Insights capability surfaces health alerts for infrastructure-level failures that would prevent policy enforcement, such as an unhealthy policy operator or a failed Gatekeeper installation, giving administrators visibility into the operational state of the security control.

The Kubernetes security documentation available through Supervisor includes guidance for pre-deployment security evaluation: threat modeling to identify trust boundaries and risks, cloud-native security lifecycle checklists organized around the develop phase, and recommendations for advanced security assessment techniques such as fuzzing and security chaos engineering where appropriate. The Kubernetes Security Response Committee publishes CVE feeds and tracks vulnerabilities in the Kubernetes platform, acknowledging reports within three working days, which gives teams visibility into known security issues in the AI and machine learning runtime infrastructure. For high-trust environments where AI workloads handle sensitive data, Supervisor supports deploying workloads on confidential virtual machines, adding hardware-level memory isolation as an additional element of the security profile that can be evaluated during a pre-deployment review.

The broader AI TEVV program, including evaluation criteria, result interpretation, and model-level testing for safety, fairness, and adversarial robustness, is an organizational responsibility. VCF provides the observable, policy-governed runtime environment that supports those activities but does not perform AI-specific evaluation itself.

VMware Private AI Services (PAIS) supports pre-deployment security and resilience evaluation of AI workloads through PAIS-native mechanisms in the model lifecycle workflow. MLOps engineers validate ML models against the organization's security, privacy, and technical requirements before onboarding them to the PAIS model gallery, with deep learning VMs and the PAIS model runtime available as the validation environment for functional and behavioral testing.

PAIS observability integrates with platforms such as Grafana and VCF Operations so that MLOps engineers, application developers, and VI administrators have ongoing visibility into model and component health, quality, and behavior in deployed

AI applications. Metrics collection is activated through the PAISConfiguration custom resource, with a Prometheus runtime, a configurable storage class, a configurable retention period, and optional LLM traces forwarded through the OpenTelemetry (OTel) Collector. This telemetry provides the data inputs for continued security and resilience review of models in production, including tracking of anomalous model behavior over time.

PAIS deployment leases bound how long an AI workload deployment can exist, providing a control for time-limited evaluation environments where candidate models can be exercised before broader rollout. PAIS supports both connected and disconnected (air-gapped) deployment models, allowing organizations to perform security evaluation of AI workloads in isolated environments. A Harbor or other OCI-compliant registry is used as the artifact source for models and container images, giving organizations a controlled location from which validated artifacts are retrieved.

Resilience evaluation for AI workloads depends on the underlying VCF platform, which provides vSphere High Availability for automatic VM restart on host failure, Distributed Resource Scheduler for workload balancing, and vMotion for live migration of GPU-accelerated VMs. These capabilities are VCF platform mechanisms; see VCF Coverage for the underlying resilience infrastructure.

### **VMware vDefend (Contributes)**

VMware vDefend contributes to evaluating the security and resilience of AI and autonomous technology workloads by providing continuous network-level security assessment capabilities that operate during and after deployment.

The vDefend distributed firewall includes a dedicated Security Assessment workflow that generates Security Segmentation Reports and Blast Radius Reports. These reports identify at-risk workloads, communication chains, and traffic flows, providing structured input for evaluating whether network isolation is correctly applied to AI workload segments and identifying gaps in protection coverage.

Security Intelligence offers traffic flow analysis, a quantitative Security Segmentation Score, and environment-level monitoring that can inform resilience assessments. The Security Segmentation Score calculates posture by evaluating Distributed Firewall configuration and traffic rules; score values from 0 to 50 indicate low security, 50 to 80 indicate medium security, and values above 80 indicate a highly secure environment. The score breakdown report details total environments and environment pairs, protection rule actions, and highlights environment pairs lacking inter-environment policies. Security Intelligence generates policy recommendations by analyzing VM traffic flows over specified time periods and boundary definitions, and monitors inter-environment traffic to detect leakage and support lockdown rule implementation. The Security Intelligence dashboard displays environments, environment pairs, and segmentation state to help administrators understand current security posture.

The Security Services Platform collects and surfaces IDS/IPS readiness and performance metrics. Administrators can view intrusion details including severity, CVE identifiers, CVSS scores, and affected VMs through vDefend IDS/IPS to inform mitigation planning. Intelligent Assist assists with IDS policies, rules, and security profiles during remediation operations. The vDefend Threat Intelligence Service Portal supplies application-level threat intelligence that can inform distributed and gateway firewall policies targeting lateral and perimeter network threats.

The broader TEVV program for AI security and resilience, including defining evaluation criteria, establishing test plans, and interpreting results against organizational risk thresholds, is an organizational responsibility outside vDefend's scope.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-002

> Benchmark GAI system security and resilience related to content provenance against industry standards and best practices. Compare GAI system security features and content provenance methods against industry state-of-the-art.

**SCF Controls:** AAT-10.17

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides provenance tracking mechanisms for model artifacts and data sources used by AI workloads. Models are stored in Harbor registries integrated with PAIS as a model storage backend, with authentication and certificate-based trust required for model retrieval. PAIS is also compatible with OCI-compliant registries from other vendors, allowing organizations to use existing model storage infrastructure while preserving artifact lineage. Each model artifact stored as an OCI object carries an immutable manifest and a unique content digest, which provides verifiable lineage from a deployed model back to its specific revision and the registry of origin.

In disconnected (air-gapped) environments, a Harbor registry acts as a controlled intermediary between external model sources and the internal deployment environment. The artifact mirroring tool (AMT), distributed as part of the pais CLI plug-in, helps administrators populate the Harbor registry from external sources before catalog publication. PAIS requires HTTPS trust bundles configured for the OIDC provider, the Harbor registry, content management systems hosting knowledge base data, and Model Context Protocol servers providing tools to models, which establishes verified channels for the artifact and data sources entering the platform.

For knowledge base data used in retrieval-augmented generation, PAIS Data Indexing and Retrieval connects to enterprise content management systems such as Microsoft SharePoint sites and Amazon S3 compatible stores as data sources. Data sources are created with a specific type that cannot be changed after creation, and a knowledge base can be linked to a maximum of ten data sources, with one data source linkable to multiple knowledge bases. PAIS tracks document-level changes during indexing operations, capturing counts of crawled documents, new documents found, deleted documents, existing unmodified documents, modified documents requiring embeddings update, and skipped documents. Indexing operations also record megabytes downloaded, number of new chunks indexed, final index size after removal of deleted documents, and timing metrics for download, embedding generation, and the index operation. PAIS supports OpenTelemetry collector integration for metrics collection and large language model traces, including knowledge base indexing traces, which records observable evidence of content provenance at the data layer.

PAIS gives a foundation for content provenance through OCI-based artifact immutability and digest-based integrity verification, combined with knowledge base indexing telemetry. The platform does not implement a formal content provenance benchmarking standard such as SLSA (Supply Chain Levels for Software Artifacts) or SPDX (Software Package Data Exchange). Organizations requiring benchmarking against industry-recognized provenance standards layer those frameworks on top of PAIS-native artifact and data source management.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



### Control MS-2.7-003

> Conduct user surveys to gather user satisfaction with the AI-generated content and user perceptions of content authenticity. Analyze user feedback to identify concerns and/or current literacy levels related to content provenance and understanding of labels on content.

**SCF Controls:** AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-004

> Identify metrics that reflect the effectiveness of security measures, such as data provenance, the number of unauthorized access attempts, inference, bypass, extraction, penetrations, or provenance verification.

**SCF Controls:** GOV-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-005

> Measure reliability of content authentication methods, such as watermarking, cryptographic signatures, digital fingerprints, as well as access controls, conformity assessment, and model integrity verification, which can help support the effective implementation of content provenance techniques. Evaluate the rate of false positives and false negatives in content provenance, as well as true positives and true negatives for verification.

**SCF Controls:** AAT-10.17, AAT-12.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to protecting the integrity of data sources used by AI workloads through storage-level encryption and access controls. vSAN encryption at rest and VM encryption protect AI training data stored on VCF infrastructure from unauthorized access at the storage layer. VMware vCenter RBAC restricts who can access or modify VMs containing AI data. Storage policies control datastore placement and encryption properties for AI workload VMs.

At the Consumption layer, VMware Kubernetes Service (VKS) on vSphere Supervisor extends these protections to containerized AI workloads. Harbor, available both as a Supervisor Service and as a standard package on VKS clusters, is the private container image registry, with images organized by vSphere Namespace. Harbor scans images for known vulnerabilities, enforces content trust so that only signed and verified artifacts are trusted, applies role-based access control to restrict which principals can push or overwrite model artifacts and pipeline images, and uses policy-based replication to control how artifacts move between registries. After Harbor is integrated with the Supervisor, all VKS clusters on the same Supervisor automatically trust it as a source of verified images.

Kubernetes admission controllers, including ValidatingAdmissionPolicy and validating webhook controllers, can be configured on VKS clusters to enforce requirements before workloads are admitted. Relevant policies include restricting image pulls to the trusted Harbor registry, requiring that images carry a valid signature, and blocking workloads that reference unscanned or unapproved artifacts. These controls reduce the risk that a workload carrying corrupted or tampered data processing logic reaches AI training data.

GitOps workflows, supported through the Argo CD Supervisor Service, store all workload and infrastructure configuration declaratively in a Git repository as the single source of truth. Every change to the deployed state flows through Git, creating a durable record of every authorized modification. Immutable infrastructure patterns complement this approach by making unauthorized changes identifiable through drift detection between actual cluster state and the declared configuration.

Kubernetes RBAC restricts which users and service accounts can read from or write to data volumes, ConfigMaps, and Secrets within VKS clusters. Supervisor namespace isolation with resource quotas contains workloads within defined boundaries, reducing the risk that one tenant can access or alter another tenant's data. Antrea-based network policies define namespace-level ingress and egress rules, scoping the network access surface for storage components that hold AI training data or inference inputs.

CSI Volume Snapshots for VKS clusters support crash-consistent backups with deduplication, compression, and encryption. The ability to restore from a known-good snapshot provides a recovery path when data corruption is detected. The VCF CLI binary, used to interact with VCF Services consumption, publishes a sha256sum.txt checksum file alongside each download so that administrators can verify the binary's integrity before use.

Validating the provenance and accuracy of AI training data at the application level is outside VCF's scope. Data poisoning detection, training data lineage, and AI-specific data provenance tracking require application-layer tooling or AI platform components built on top of the VCF platform.

VMware Private AI Services (PAIS) provides integrity controls for both model artifacts and data sources used by AI workloads. Model revisions in the Model Gallery use Harbor as a storage backend, and each push of the same model receives a unique digest so that successive revisions are content-addressed and distinguishable. Before upload, model files should be validated for integrity by checking hash codes, scanned for malware and serialization attacks, and tested for correct inference behavior.

using Triton Inference Server as part of the sandbox validation process in a Deep Learning VM. This pre-upload validation provides cryptographic verification and behavioral testing that helps prevent contaminated or tampered model data from entering production.

The Model Gallery uses Harbor project access capabilities to restrict access to sensitive data used to train and tune models. Harbor integration requires authentication and certificate-based trust for model retrieval, and PAIS requires CA trust bundles to be imported for the Private Harbor registry, content management systems used as data sources in Data Indexing and Retrieval, and MCP servers providing tools for agents. These access controls and verified chains of trust restrict unauthorized modification of model and data artifacts. The documentation recommends using the Model Gallery to reduce redundant copies of models and maintain model integrity in a controlled environment.

For knowledge base data sources used by retrieval-augmented generation, PAIS Data Indexing and Retrieval enables automatic collection and indexing of data updates from linked data sources over time, supporting external content management systems such as Microsoft SharePoint and Amazon S3 compatible stores. Each knowledge base data source is created with a specific type that cannot be changed after creation, which helps prevent silent reconfiguration of the underlying source provider. The content management system used as a data source must be supported, and valid credentials are required for access to the content location. SharePoint data sources require user name and password authentication, and service account key file data sources require the information from the service account key file during data source creation. PAIS uses a CA trust bundle for secure communication with external services and databases, establishing verified transport between PAIS and its data sources.

#### **VMware vDefend (Contributes)**

VMware vDefend contributes to protecting the integrity of source data used by AI workloads on VCF through network-level security controls that restrict access to data stores and pipelines and detect malicious activity targeting data repositories.

Distributed Firewall microsegmentation enforces least-privilege network access at the vNIC level, limiting which workloads and users can reach databases, object stores, and data pipelines used for AI training and operation. Attacks that attempt to contaminate or corrupt AI source data require network access to the stores where training data resides; microsegmentation restricts that access to authorized workloads and identities. Security Intelligence provides visibility into traffic flows between workloads, generates firewall rule recommendations, and validates that security policies are enforced. Security Intelligence administrators can monitor for traffic leakage between environments, establish exceptions for authorized communication paths, and implement lockdown protection rules to control unauthorized inter-environment traffic. Gateway Firewall provides an additional enforcement point at the perimeter of network segments containing sensitive data repositories.

vDefend IDS/IPS inspects traffic to and from data repositories for known exploit patterns, command-and-control traffic, lateral movement, and data exfiltration signatures. The IDS/IPS filestore capability stores matched files to disk when a signature rule fires, supporting forensic analysis and post-incident review of suspected data integrity compromises. IDS/IPS signature-based detection also uses file magic inspection, identifying file types by their binary structure via libmagic, to detect misrepresented or malformed files in transit to data repositories.

Malware Prevention intercepts and analyzes files transferred over the network to data repositories. Profiles can be configured to send files to the cloud for detailed analysis or to process them locally without cloud connectivity. Verdict decisions classify files as Benign, Trusted, Highly Trusted, or Malicious. Security Services Platform Malware Prevention collects file analysis data including file hash submissions, assigns an Analyst UUID to each cloud submission for tracking, and records in-memory script buffer inspection details with associated analysis reports. The Security Services Platform also provides backup and restore mechanisms covering hardware malfunctions, software malfunctions, data corruption, and malware incidents, providing a recovery path if SSP itself is compromised.

vDefend contributes to this control because its microsegmentation, threat detection, and file inspection capabilities reduce the attack surface and detection gap for data poisoning attacks targeting AI workloads. Protecting data integrity at the application layer, including content validation, provenance tracking, and checksums within data stores, is outside vDefend's domain and requires organizational processes and additional tooling.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer.  
This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-006

> Measure the rate at which recommendations from security checks and incidents are implemented. Assess how quickly the AI system can adapt and improve based on lessons learned from security incidents and feedback.

**SCF Controls:** VPM-05.3

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF provides mechanisms to track the effectiveness of remediation operations through metrics reporting, compliance management, diagnostics, and lifecycle management capabilities.

VCF Operations includes a compliance management function that detects violations, highlights risk areas, and provides actionable remediation recommendations. This gives administrators visibility into the current compliance posture of the environment and surfaces specific items requiring remediation. Each metric panel within VCF Operations includes a Check Recommendations button that provides guidance on remediation steps, linking metrics directly to corrective actions. Alert definitions can be configured with symptom conditions based on metrics or properties, each with associated remediation recommendations. When alerts trigger, VCF Operations maps out-of-the-box workflows to those recommendations and associates them with specific alerts for automated remediation. Actions can be defined to run on target objects and added as recommendations for alert definitions configured across different base objects, tying remediation activities directly to the alerts and metrics that triggered them. The Recommended Actions widget on the VCF Operations Home dashboard displays how many objects are in a critical state and how many require immediate attention, giving administrators a real-time summary of outstanding remediation work.

During incident investigation, administrators can flag individual metrics and mark specific metrics as root cause, creating a traceable link between the detected issue and the remediation action taken. This supports post-remediation analysis by recording which metrics drove the remediation and how they were resolved. The Recent Tasks screen allows administrators to confirm that optimization and remediation actions have completed and to filter actions by their status, identifying actions that succeeded, failed, or reached maximum time limits.

VCF Operations Diagnostics automatically detects known issues and critical vulnerabilities within the VCF software stack, providing detailed descriptions, root cause insights, and actionable remediation steps. This integrated diagnostics capability builds on several legacy tools and operational data to provide issue detection and remediation across the platform. Efficiency alerts identify resources that can be reclaimed, and system audit reports provide visibility into super metrics across the environment. The metric chart widget enables creation of ad-hoc reports when analyzing metrics, supporting custom views that track remediation trends and measure time to resolution.

Workload Optimization generates exact moves planned for compute and storage resources as part of optimization recommendations. The Workload Optimization UI pages enable monitoring of optimizing moves in fully automated systems and can be used to conduct research and run actions directly in systems that are not fully automated, allowing administrators to track whether automated or manual remediation actions achieved their intended results.

For host-level remediation, vSphere Lifecycle Manager (vLCM) tracks the current state of each host against the desired cluster specification. vLCM enables cluster remediation by applying a desired software state on each host whose current state differs from the desired specification. After remediation operations, administrators can check the compliance of a cluster or host against the desired state to determine whether additional remediation steps are required. When remediation fails, vSphere Lifecycle Manager provides information about the specific reasons for failure, supporting root cause analysis and follow-up corrective action. Performance metrics can be configured with redInterval and yellowInterval thresholds that trigger defined actions when sustained beyond specified durations, providing time-based tracking of whether remediation brought metrics back within acceptable ranges. For CPU resources, vSphere documentation identifies that CPU usage above 90 percent combined with a CPU ready value above 20 percent indicates that performance is being impacted and corrective action should be considered, providing a documented threshold that connects observed metrics to remediation decisions.

Custom dashboards with role-based access control allow organizations to build remediation-specific views. Dashboards support differentiated visibility for various user roles and can be assigned to specific user groups. Automated reports provide the ability to track remediation metrics over time, giving visibility into remediation trends and outcomes across the infrastructure.

#### **VMware vDefend (Contributes)**

VMware vDefend (vDefend) contributes to tracking the effectiveness of remediation operations through its network security metrics, remediation workflow tracking, and operational dashboards across its distributed firewall, IDS/IPS, malware prevention, and network detection capabilities.

When IDS/IPS detects intrusion events, administrators can initiate remediation using either a Targeted Strategy for surgical, safer-to-deploy policies with potentially lower effectiveness, or a Comprehensive Strategy for broader remediation with potentially lower safety. Intelligent Assist tracks these remediation actions by adding them as rules to the Intelligent Assist Remediation policy using the naming convention prefix 'ai-', providing a structured record of remediation actions taken. Objects generated during remediation that encounter errors require manual cleanup, meaning tracking must account for failed remediation attempts.

The Security Services Platform (SSP) provides a metrics service with Top N analysis, lifetime counters, and historical trend statistics for monitoring firewall operational state. The Metrics feature collects data on entities in NSX and SSP environments and presents it through the Platform dashboard. Metrics APIs support advanced server-side filtering, multi-dimensional aggregation, grouping, and related-metrics queries. Two metric models are available: a Status model that retains and overwrites the last reported value only when it changes, and a Point-in-Time model used in Top-N analysis where the last value is overwritten with new data points and times out after 24 hours. Bare Metal Servers report rule statistics to the Metrics Server every five minutes, extending rule-level visibility to bare metal infrastructure in addition to virtualized workloads. The Flow Retention metric displays the number of days of flow data retained based on ingestion configuration, giving operators visibility into the historical depth of network telemetry available for retrospective analysis.

The SSP also tracks operational data management metrics including records purged from Malware Prevention Service tables, covering INSPECTION\_EVENTS, INTERCEPTED\_ENTITIES, and MALWARE\_CLASS categories. The Process Analysis Report includes links to artifact reports on the VirusTotal portal, supporting cross-reference of malware findings against external threat intelligence.

The Security Segmentation Report provides security operations personnel with an assessment of the organization's segmentation status and a basis for prioritizing remediation efforts. Security Intelligence supports prioritizing critical workloads and throttling the ingestion of lower-priority flows to maintain system stability under load. In the NDR component, campaigns with higher impact scores are identified as higher priority to address and triage, enabling severity-based remediation tracking.

Under memory pressure, vDefend IDS/IPS follows a prioritized approach to event handling, dropping non-critical severity data (Low and Informational) first, followed by Medium, then High and Critical severity events and packet captures only as a last resort. This behavior affects the metrics available for remediation effectiveness analysis under high-load conditions.

These capabilities address the network security dimension of remediation metrics. Tracking of patching, compute, and infrastructure remediation is handled by other VCF components such as VCF Operations and vSphere Lifecycle Manager.

Not applicable for this control: VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-007

> Perform AI red-teaming to assess resilience against: Abuse to facilitate attacks on other systems (e.g., malicious code generation, enhanced phishing content), GAI attacks (e.g., prompt injection), ML attacks (e.g., adversarial examples/prompts, data poisoning, membership inference, model extraction, sponge examples).

**SCF Controls:** AAT-12.2, VPM-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MS-2.7-008

> Verify fine-tuning does not compromise safety and security controls.

**SCF Controls:** AAT-17.5

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VCF contributes to preserving security controls during AI model fine-tuning and updates by providing VM snapshots that capture point-in-time state before changes, resource pools that maintain resource boundaries during updates, and storage policies that persist encryption and placement properties regardless of workload changes. vCenter RBAC controls who can modify AI workload VMs during update operations.

For AI and machine learning workloads deployed through VMware Kubernetes Service (VKS) on the vSphere Supervisor, the Consumption layer adds enforcement mechanisms that operate at the Kubernetes API level. Kubernetes admission controllers, including validating and mutating webhooks, intercept API requests before workloads are scheduled. MutatingAdmissionPolicy resources allow platform teams to define declarative policies that automatically validate or transform AI workload configurations at admission time, with reinvocationPolicy controlling whether mutations apply once or conditionally on subsequent plugin modifications. MutatingAdmissionPolicyBinding objects scope enforcement to specific API kinds and namespaces, so admission controls can be targeted at the namespaces where fine-tuning jobs run. VKS Cluster Management extends this with OPA Gatekeeper-driven security guardrails that restrict pod admission to compliant configurations, and VCF Automation mutation policies with the pod-security template can automatically remediate non-compliant pods before admission rather than merely blocking them.

Pod Security Admission (PSA) enforces restrictions on what containerized workloads can do within a namespace. Administrators can configure the podSecurityStandard.enforce setting to restricted, which limits privilege escalation and restricts Linux capabilities for workloads in a given namespace; audit and warn modes can be applied simultaneously to observe policy deviations without interrupting workloads.

Kubernetes RBAC governs who can create, modify, or delete workload resources, including those used in fine-tuning operations. Roles and RoleBindings can be scoped to the namespaces hosting AI workloads, limiting the blast radius of any misconfiguration or unauthorized action. Platform teams should review default RBAC rights for hardening opportunities.

Kubernetes audit logging records all API requests, including creation and modification of AI workload resources, providing a trail of actions taken during fine-tuning operations. The immutable infrastructure pattern is supported in VKS: unauthorized changes can be overwritten by automated processes or blocked at the admission control layer, reducing the risk that side effects of fine-tuning operations modify cluster configuration in ways that affect other security controls.

VKS also supports MachineHealthCheck, a Cluster API resource that specifies node conditions such as NotReady status, MemoryPressure, DiskPressure, and PIDPressure, along with a timeout duration for each. When a node meets the unhealthy criteria, the controller triggers automatic remediation. For resource-intensive fine-tuning workloads that may degrade node health, MachineHealthCheck helps maintain the resilience of cluster infrastructure by returning unhealthy nodes to a compliant state without requiring manual intervention.

Harbor, included with Supervisor, serves as a private container image registry organized by vSphere namespace. VKS clusters on the same Supervisor automatically trust Harbor and can pull container images from it, supporting controlled supply chain integrity for AI workload images. In air-gapped deployments, Harbor Supervisor Service must be configured as the private registry for VKS images.

Managing AI model-level risks during fine-tuning (output quality, safety properties) is outside VCF's scope.

VMware Private AI Services (PAIS) provides AI-infrastructure controls that help protect existing safety and security properties during model fine-tuning. Deep learning VMs are the designated fine-tuning environment, where data scientists download models from public or organizational registries and validate or fine-tune them before storing the result in the Model Gallery. PAIS guidance is explicit that models distributed within an organization should be those validated on a deep learning VM

rather than models pulled directly from the Internet, since Internet-sourced models can contain malicious code or be tuned for malicious behavior.

The validate-then-publish workflow acts as a safety gate after fine-tuning. MLOps engineers validate ML models against the security, privacy, and technical requirements of the organization before storing them in the Model Gallery. Sandbox validation in deep learning VMs checks model file integrity by verifying hash codes, scans the files for malware, scans them for serialization attacks, and tests inference behavior using the Triton Inference Server. Model performance and safety are evaluated for the intended business use case by examining inference requests for malicious behavior and performing hands-on functional tests. A fine-tuned model passes the same validation gate as any new model before reaching production model endpoints.

The Model Gallery is the controlled repository for validated models, reducing redundant copies and maintaining model integrity across the environment. Hash code validation confirms that the revision deployed to a production endpoint is the one that passed sandbox validation, and the same hash references support a rollback path: if a fine-tuned model exhibits degraded safety or compliance behavior after deployment, operators can revert to a previously validated revision in the gallery. When PAIS is deployed in a disconnected air-gapped environment, the validated Model Gallery and a Harbor or OCI-compliant registry remain the only paths by which models reach production endpoints, which keeps fine-tuning activity inside the controlled boundary.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.7-009

> Regularly assess and verify that security measures remain effective and have not been compromised.

**SCF Controls:** AAT-11.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.8-001

> Compile statistics on actual policy violations, take-down requests, and intellectual property infringement for organizational GAI systems: Analyze transparency reports across demographic groups, languages groups.

**SCF Controls:** AAT-07, AAT-12

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.8-002

> Document the instructions given to data annotators or AI red-teamers.

**SCF Controls:** AAT-26.4

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-2.8-003

> Use digital content transparency solutions to enable the documentation of each instance where content is generated, modified, or shared to provide a tamper-proof history of the content, promote transparency, and enable traceability. Robust version control systems can also be applied to track changes across the AI lifecycle over time.

**SCF Controls:** AAT-20.1, AAT-26.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.8-004

> Verify adequacy of GAI system user instructions through user testing.

**SCF Controls:** AAT-17.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.9-001

> Apply and document ML explanation results such as: Analysis of embeddings, Counterfactual prompts, Gradient-based attributions, Model compression/surrogate models, Occlusion/term reduction.

**SCF Controls:** AAT-26, TDA-22

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MS-2.9-002

> Document GAI model details including: Proposed use and organizational value; Assumptions and limitations, Data collection methodologies; Data provenance; Data quality; Model architecture (e.g., convolutional neural network, transformers, etc.); Optimization objectives; Training algorithms; RLHF approaches; Fine-tuning or retrieval-augmented generation approaches; Evaluation data; Ethical considerations; Legal and regulatory requirements.

**SCF Controls:** AAT-01.1, AAT-04.1, AAT-10, AAT-20.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.10-001

> Conduct AI red-teaming to assess issues such as: Outputting of training data samples, and subsequent reverse engineering, model extraction, and membership inference risks; Revealing biometric, confidential, copyrighted, licensed, patented, personal, proprietary, sensitive, or trade-marked information; Tracking or revealing location information of users or members of training datasets.

**SCF Controls:** AAT-19, AAT-19.8, VPM-10

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.10-002

> Engage directly with end-users and other stakeholders to understand their expectations and concerns regarding content provenance. Use this feedback to guide the design of provenance data-tracking techniques.

**SCF Controls:** AAT-11.1, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-2.10-003

> Verify deduplication of GAI training data samples, particularly regarding synthetic data.

**SCF Controls:** AAT-10.18, AAT-12.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-2.11-001

> Apply use-case appropriate benchmarks (e.g., Bias Benchmark Questions, Real Hateful or Harmful Prompts, Winogender Schemas<sup>15</sup>) to quantify systemic bias, stereotyping, denigration, and hateful content in GAI system outputs; Document assumptions and limitations of benchmarks, including any actual or possible training/test data cross contamination, relative to in-context deployment environment.

**SCF Controls:** AAT-06, AAT-10.8, AAT-26

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.11-002

> Conduct fairness assessments to measure systemic bias. Measure GAI system performance across demographic groups and subgroups, addressing both quality of service and any allocation of services and resources. Quantify harms using: field testing with sub-group populations to determine likelihood of exposure to generated content exhibiting harmful bias, AI red-teaming with counterfactual and low-context (e.g., “leader,” “bad guys”) prompts. For ML pipelines or business processes with categorical or numeric outcomes that rely on GAI, apply general fairness metrics (e.g., demographic parity, equalized odds, equal opportunity, statistical hypothesis tests), to the pipeline or business outcome where appropriate; Custom, context-specific metrics developed in collaboration with domain experts and affected communities; Measurements of the prevalence of denigration in generated content in deployment (e.g., sub- sampling a fraction of traffic and manually annotating denigrating content).

**SCF Controls:** AAT-10.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-2.11-003

> Identify the classes of individuals, groups, or environmental ecosystems which might be impacted by GAI systems through direct engagement with potentially impacted communities.

**SCF Controls:** AAT-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.11-004

> Review, document, and measure sources of bias in GAI training and TEVV data: Differences in distributions of outcomes across and within groups, including intersecting groups; Completeness, representativeness, and balance of data sources; demographic group and subgroup coverage in GAI system training data; Forms of latent systemic bias in images, text, audio, embeddings, or other complex or unstructured data; Input data features that may serve as proxies for demographic group membership (i.e., image metadata, language dialect) or otherwise give rise to emergent bias within GAI systems; The extent to which the digital divide may negatively impact representativeness in GAI system training and TEVV data; Filtering of hate speech or content in GAI system training data; Prevalence of GAI-generated data in GAI system training data.

**SCF Controls:** AAT-10.8

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



## Control MS-2.11-005

> Assess the proportion of synthetic to non-synthetic training data and verify training data is not overly homogenous or GAI-produced to mitigate concerns of model collapse.

**SCF Controls:** AAT-10.18

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.12-001

> Assess safety to physical environments when deploying GAI systems.

**SCF Controls:** AAT-17, AAT-17.1, EMB-15

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.12-002

> Document anticipated environmental impacts of model development, maintenance, and deployment in product design decisions.

**SCF Controls:** AAT-17.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides PAIS-native mechanisms that help organizations assess the environmental footprint of AI workloads. Metrics collection for PAIS is activated by uncommenting the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource, after which DevOps and MLOps engineers can visualize PAIS health and performance metrics for components running in a VCF Automation namespace through observability platforms such as Grafana. The same observability pipeline lets MLOps engineers and application developers monitor models used in agents, giving operators visibility into the operational characteristics of individual AI workloads across deep learning VMs, VKS clusters, and RAG applications. This telemetry is the raw operational data that organizations use to quantify the energy and resource footprint of AI activity.

PAIS also supports resource efficiency through deployment leases. A lease controls how long a PAIS deployment can exist, so that AI workloads provisioned from VCF Automation catalog items are reclaimed at the end of a defined period rather than continuing to consume GPU and compute resources indefinitely. Disconnected (air-gapped) and connected deployment modes both rely on the same observability and lease controls, so the same sustainability-relevant data and lifecycle controls apply regardless of connectivity model.

Broader sustainability and green-metric monitoring at the cluster and host level is a VCF platform capability and is covered under VCF Coverage. The organizational activity of setting sustainability targets, analyzing collected metrics, and documenting environmental impact is a process obligation outside PAIS itself, which is why the rating is Contributes rather than Meets.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.12-003

> Measure or estimate environmental impacts (e.g., energy and water consumption) for training, fine tuning, and deploying models: Verify tradeoffs between resources used at inference time versus additional resources required at training time.

**SCF Controls:** AAT-17.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides PAIS-native mechanisms that help organizations assess the environmental footprint of AI workloads. Metrics collection for PAIS is activated by uncommenting the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource, after which DevOps and MLOps engineers can visualize PAIS health and performance metrics for components running in a VCF Automation namespace through observability platforms such as Grafana. The same observability pipeline lets MLOps engineers and application developers monitor models used in agents, giving operators visibility into the operational characteristics of individual AI workloads across deep learning VMs, VKS clusters, and RAG applications. This telemetry is the raw operational data that organizations use to quantify the energy and resource footprint of AI activity.

PAIS also supports resource efficiency through deployment leases. A lease controls how long a PAIS deployment can exist, so that AI workloads provisioned from VCF Automation catalog items are reclaimed at the end of a defined period rather than continuing to consume GPU and compute resources indefinitely. Disconnected (air-gapped) and connected deployment modes both rely on the same observability and lease controls, so the same sustainability-relevant data and lifecycle controls apply regardless of connectivity model.

Broader sustainability and green-metric monitoring at the cluster and host level is a VCF platform capability and is covered under VCF Coverage. The organizational activity of setting sustainability targets, analyzing collected metrics, and documenting environmental impact is a process obligation outside PAIS itself, which is why the rating is Contributes rather than Meets.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-2.12-004

> Verify effectiveness of carbon capture or offset programs for GAI training and applications, and address green-washing concerns.

**SCF Controls:** AAT-17.2

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides PAIS-native mechanisms that help organizations assess the environmental footprint of AI workloads. Metrics collection for PAIS is activated by uncommenting the `spec.observability.prometheusRuntime` section of the `PAISConfiguration` custom resource, after which DevOps and MLOps engineers can visualize PAIS health and performance metrics for components running in a VCF Automation namespace through observability platforms such as Grafana. The same observability pipeline lets MLOps engineers and application developers monitor models used in agents, giving operators visibility into the operational characteristics of individual AI workloads across deep learning VMs, VKS clusters, and RAG applications. This telemetry is the raw operational data that organizations use to quantify the energy and resource footprint of AI activity.

PAIS also supports resource efficiency through deployment leases. A lease controls how long a PAIS deployment can exist, so that AI workloads provisioned from VCF Automation catalog items are reclaimed at the end of a defined period rather than continuing to consume GPU and compute resources indefinitely. Disconnected (air-gapped) and connected deployment modes both rely on the same observability and lease controls, so the same sustainability-relevant data and lifecycle controls apply regardless of connectivity model.

Broader sustainability and green-metric monitoring at the cluster and host level is a VCF platform capability and is covered under VCF Coverage. The organizational activity of setting sustainability targets, analyzing collected metrics, and documenting environmental impact is a process obligation outside PAIS itself, which is why the rating is Contributes rather than Meets.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-3.2-001

> Establish processes for identifying emergent GAI system risks including consulting with external AI Actors.

**SCF Controls:** AAT-07

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-3.3-001

> Conduct impact assessments on how AI-generated content might affect different social, economic, and cultural groups.

**SCF Controls:** AAT-07.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-3.3-003

> Evaluate potential biases and stereotypes that could emerge from the AI- generated content using appropriate methodologies including computational testing methods as well as evaluating structured feedback input.

**SCF Controls:** AAT-06

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.



### **Control MS-3.3-004**

> Provide input for training materials about the capabilities and limitations of GAI systems related to digital content transparency for AI Actors, other professionals, and the public about the societal impacts of AI and the role of diverse and inclusive content generation.

**SCF Controls:** AAT-05

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-3.3-005

> Record and integrate structured feedback about content provenance from operators, users, and potentially impacted communities through the use of methods such as user research studies, focus groups, or community forums. Actively seek feedback on generated content quality and potential biases. Assess the general awareness among end users and impacted communities about the availability of these feedback channels.

**SCF Controls:** AAT-10.8, AAT-11

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-4.2-001

> Conduct adversarial testing at a regular cadence to map and measure GAI risks, including tests to address attempts to deceive or manipulate the application of provenance techniques or other misuses. Identify vulnerabilities and understand potential misuse scenarios and unintended outputs.

**SCF Controls:** AAT-10, AAT-26

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) provides infrastructure that supports AI Test, Evaluation, Validation and Verification (TEVV) activities throughout the model lifecycle. Deep learning VMs provisioned from PAIS images provide dedicated testing environments for AI prototyping, fine-tuning, validation, and inference workloads. These DL VMs run on the same GPU-accelerated workload domains, vGPU profiles, and VM classes used in production, so TEVV activities occur in conditions comparable to the deployment environment.

The validate-then-publish workflow creates a formal gate for AI deployment. MLOps engineers validate models for inference functionality using the Triton Inference Server and evaluate performance and safety against business use cases, including examination of inference requests for malicious behavior and functional testing. Models must pass this validation before being uploaded to the Model Gallery for production use. Model integrity is verified through hash code validation, and each revision is assigned a unique digest stored as an OCI artifact with an immutable manifest, giving cryptographic verification that the tested model is the same artifact that gets deployed.

The platform also supports TEVV through its monitoring stack. VCF Operations monitors GPU consumption at cluster, host system, and host properties levels. Each DL VM includes a pre-installed DCGM Exporter with Prometheus collection at 5-second scrape intervals and Grafana visualization, supplying performance telemetry during testing and evaluation. The software stack for running AI applications on top of NVIDIA GPUs is validated in advance, and NVIDIA NGC containers are pre-tested and ready to run, reducing variables during TEVV by providing a known-good baseline.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-4.2-002

> Evaluate GAI system performance in real-world scenarios to observe its behavior in practical environments and reveal issues that might not surface in controlled and optimized testing environments.

**SCF Controls:** AAT-25

**Aggregate Coverage:** Contributes

### VCF (Contributes)

VMware Private AI Services (PAIS) defines a structured, multi-stage value chain for creating and deploying AI workloads, with distinct stakeholder roles at each stage. The platform separates responsibilities across VI administrators, organization administrators, MLOps engineers, DevOps engineers, and AI application developers, with each role scoped to a specific phase of the deployment lifecycle.

Infrastructure provisioning begins with VI administrators configuring GPU-accelerated workload domains, namespaces, and VMware Kubernetes Service (VKS) Supervisors in VMware vCenter and VMware ESX. Organization administrators set up the VCF Automation organization. PAIS must be activated in organization namespaces by an organization administrator or MLOps engineer after namespace creation, establishing the foundation before any AI workloads can be deployed.

Model acquisition is registry-driven. A Harbor administrator creates a dedicated Harbor project for PAIS in the private Harbor registry, into which PAIS artifacts are uploaded as part of the installation process. OCI-compliant registries from other vendors are also supported. The Harbor project's user access controls restrict who can push or pull artifacts, creating an auditable record of which images are available and how they arrived. PAIS deployments can run in connected environments with internet access or in disconnected (air-gapped) environments, with disconnected operation requiring the Harbor registry to be pre-populated with the AI catalog images in advance.

Compute provisioning is driven by VCF Automation catalog items created through the Private AI Services Quickstart. The catalog items include AI Workstation, DSM Database, Triton Inferencing Server, and AI Kubernetes Cluster, and are provisioned by users in selected namespaces. Catalog item visibility is verified per project so that PAIS catalog items are available only to members of the selected project. A machine retrieving information about PAIS must have access to VCF Automation, the VCF Consumption CLI, and kubectl, which scopes the provisioning interfaces to the responsible stakeholder.

PAIS provides a UI and API for AI application developers to interact with deployed models and services. Data scientists and MLOps engineers compose applications by using PAIS Knowledge Bases linked to external data sources such as Microsoft SharePoint sites and Amazon S3 compatible stores. A Knowledge Base data source is created with a specific type that cannot be changed after creation, and one data source can be linked to multiple Knowledge Bases. DevOps engineers visualize PAIS component health and performance metrics in observability platforms such as Grafana and VCF Operations, providing accountability for each stage of the value chain.

Not applicable for this control: VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

### Control MS-4.2-003

> Implement interpretability and explainability methods to evaluate GAI system decisions and verify alignment with intended purpose.

**SCF Controls:** AAT-20.1

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-4.2-004

> Monitor and document instances where human operators or other systems override the GAI's decisions. Evaluate these cases to understand if the overrides are linked to issues related to content provenance.

**SCF Controls:** AAT-15.2

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

## Control MS-4.2-005

> Verify and document the incorporation of results of structured public feedback exercises into design, implementation, deployment approval (“go”/“no-go” decisions), monitoring, and decommission decisions.

**SCF Controls:** AAT-11.1, AAT-11.3

**Aggregate Coverage:** Not Applicable

Not applicable for this control: VCF, VMware vDefend, VCF Protection and Recovery, VMware Data Services Manager, VMware Avi Load Balancer. This control addresses an end user activity or process, a design decision, or activity outside the scope of these products.

